OPENBOT / ENGINEERING BASELINE

OpenBot 开发任务与验收手册

可直接交给 Codex 或 Claude Code 的任务分解与交接规则

版本 1.2 2026 年 11 月 4 日

96 个工作任务按依赖、风险、实现步骤、正向与负向验收拆分。原88个ID保留，新增8项准入与验证任务。任务状态全部从 TODO 开始；本手册指导开发与验收，不表示应用已经实现。

任务卡	依赖与范围	验收证据
稳定ID与机器可读JSON	M0 至 M4 及后续能力	实际行为、失败路径、真实环境限制

每轮只推进一个可审查增量

- 先检查依赖与真实仓库状态，再交给编码助手执行。
- 合同、迁移、锁文件与安全策略由唯一负责人统一变更。
- 代码生成、mock通过与真实平台通过分别报告，不互相替代。

使用边界

这是建议实施基线。未提供应用源码仓库，真实飞书租户、模型与三平台安装尚未验证。SQL、接口、任务与图示的离线检查结果随交接包提供。

目录

M0 规格与工程基线 3

M1 本地内核与安全工具 13

M2 飞书远程闭环 42

M3 完整产品 MVP 50

M4 桌面 Beta 与发布 68

P2 后续扩展能力 71

OpenBot 需求与任务追踪矩阵 75

AI 编码启动与交接 97

首次交给编码助手的提示 97

单任务执行模板 97

独立评审模板 97

阶段交接模板 98

持续实施到MVP的交接提示 98

单个组件接入与升级提示 99

M0 规格与工程基线

本阶段 13 项任务。按 depends_on 拓扑推进；编号顺序不替代依赖关系。

OB-001 冻结用户场景与MVP边界

优先级 P0 规模 S 职责 Lead 状态 TODO

前置依赖 无

需求映射 RQ01、RQ12

风险 HIGH / 范围漂移会让编码代理提前实现多租户或GUI并挤占安全闭环。

交付路径 docs/00_scope.md；docs/adr/0001-scope-baseline.md

复用方式 自研控制语义

复用要求 保留单owner/profile/device和阶段边界；把组件建议与已准入实现分开，复用不扩大产品范围。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 将U1/U2需求映射为S01–S06与M0–M4/P2交付边界，区分原要求、默认假设和未确认项。；写清单owner/profile/device、单活动gateway以及三平台逐个取得支持资格的规则。；按输入约束冻结本轮范围，并记录变更必须同步ADR、合同、任务与验收。

正向验收 冻结一个OS用户、profile、owner、设备和单活动gateway；M0至M4/P2边界与S01–S06场景明确；三平台支持根据真实能力报告授予，MVP不要求桌面GUI控制。

负向验收 不得把本地Alpha当作完整MVP，或把未测OS标为supported。

验证方法 用3个主场景和5个失败场景逐项映射到需求ID；评审不出现“支持所有任务”。

完成证据 提供更新后的范围/ADR/清单及决策理由，明确原要求、建议和未验证假设。；给出与任务验收对应的评审检查结果；涉及spike时记录环境、最小命令和实际观察，不以文档代替实测。

设计依据 docs/00_scope.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md

OB-002 定义信任边界和动作副作用类别

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-001

需求映射 RQ04、RQ05、RQ06

风险 CRITICAL / 错误威胁模型会把高风险能力当作默认安全。

交付路径 docs/04_security_approvals.md；docs/adr/0002-trust-and-effects.md

相关组件 model-runner

复用方式 自研控制语义

复用要求 明确任何组件、源码片段、重试器、MCP hints均不拥有身份/授权/派发权；增加组件主动联网、执行、下载和遥测威胁。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 列资产、攻击者、信任边界与数据出口，明确同一OS用户完全失陷的边界。；分别定义effect与五种retry_class，为每类附失败窗口及处理办法。；将路径、任意代码、工具注入和审批残余风险映射到负责模块与验证任务。；把SDK自动工具/Provider托管工具、隐藏重试、运行期下载、网络验证、配置/hook执行和源码摘取纳入信任边界。

正向验收 资产/边界/攻击者假设可核对；效果与retry_class分开定义；使用SAFE_READ、IDEMPOTENT_WRITE、PROVIDER_IDEMPOTENT、RECONCILE_ONLY、NON_RETRYABLE，说明审批不等于执行隔离。 组件品牌、许可证、annotations或官方helper均不赋予执行权；明确已观察网络范围与同用户失陷的残余边界。

负向验收 不能把Docker、argv、审批或schema pinning中的任一项描述成完整安全保证。；不得因组件来自官方就放开其所有API、remote MCP、服务端工具或自动工具循环。

验证方法 列出入站、模型、网页、MCP、文件、操作系统各边界及防护/残余风险；每类有失败用例。

完成证据 提供更新后的范围/ADR/清单及决策理由，明确原要求、建议和未验证假设。；给出与任务验收对应的评审检查结果；涉及spike时记录环境、最小命令和实际观察，不以文档代替实测。；组件边界图和威胁条目到现有Policy/Broker/隔离门禁的映射。

设计依据 docs/02_architecture.md；docs/04_security_approvals.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-003 冻结daemon与客户端生命周期

优先级 P0 规模 S 职责 Runtime 状态 TODO

前置依赖 OB-001

需求映射 RQ01、RQ11

风险 HIGH / 生命周期相互绑定会破坏远程可用性并遗留worker。

交付路径 docs/02_architecture.md；docs/adr/0003-daemon-lifecycle.md

相关组件 profile-locks；processkit-process-wrap；windows-sys；ur-taking-me-with-you；service-manager

复用方式 原生原语适配

复用要求 生命周期ADR不变；锁/用户服务/进程监管允许复用经过OB-093实测的OS原语封装，不许宣称通用crate自动保证整树清理。；实际OS、架构、backend和配置组合须独立提供证据；统一API、正常退出或进程组不能自动证明所有强杀与逃逸场景均可回收。

实施步骤 写用户级supervisor、daemon、gateway、worker和UI的父子及连接关系。；定义常驻/ephemeral、关闭窗口、stop、logout、睡眠、重启和崩溃的事件矩阵。；用最小监督spike确认首发OS的锁与清理能力，未知能力写入限制。；将profile锁、原生进程清理和用户级服务分为独立原语；指定唯一锁持有者，父子交接/健康检查不得再次争抢同一排他锁。

正向验收 默认常驻模式由用户级supervisor托管；CLI/Tauri退出不停止daemon；开发ephemeral模式显式标识；显式stop执行drain、停止新dispatch和worker回收。 监督与状态归属由OpenBot定义，原语候选经OB-093后决定；不把command-group作为新增默认依赖。

负向验收 关闭Tauri或断开CLI不得终止常驻daemon；不得把正常退出回调当成SIGKILL保证。；父supervisor持锁时daemon不得阻塞式重取同一profile排他锁；不能以Rust Drop或管道EOF保证所有强杀场景。

验证方法 生命周期表覆盖关闭窗口、登出、休眠、daemon崩溃、worker崩溃和重启；无相互矛盾要求。

完成证据 提供更新后的范围/ADR/清单及决策理由，明确原要求、建议和未验证假设。；给出与任务验收对应的评审检查结果；涉及spike时记录环境、最小命令和实际观察，不以文档代替实测。；标出锁拥有者、句柄/凭据交接、重启接管和每类清理对象的生命周期矩阵。

设计依据 docs/02_architecture.md；docs/00_scope.md；docs/08_desktop_release.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-004 核验依赖和许可证

优先级 P0 规模 M 职责 Lead 状态 TODO

前置依赖 OB-001

需求映射 RQ01、RQ11、RQ12

风险 HIGH / 依赖错误和许可证缺口会在实现或发布阶段造成返工。

交付路径 docs/dependency-evidence.md；THIRD_PARTY_NOTICES.md；docs/spikes/component-selection.md

相关组件 command-group；service-manager；pathspec；pyinstaller；astrbot

复用方式 独立资格验证

复用要求 核验当前阶段最小组合；后续候选不提前安装或标已锁定。command-group不新增默认依赖；许可证按具体文件/版本/分发方式评估。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 从官方来源为当前候选记录精确版本或待锁定状态、包/文件许可证、分发方式、接口、可替换实现和已知副作用。；冻结M0实际需要的最小工具/合同组合，后续SDK/浏览器/桌面候选留待各自阶段PoC；仅做必要可行性spike，不预认证全套依赖。；区分直接依赖、原语参考、源码摘取及不采用项；将证据交OB-089机器清单，复杂原生能力交OB-093、真实飞书协议交OB-047。

正向验收 当前M0实际使用的Python/SQLite/工具/合同组件有明确版本及许可证证据；后续SDK、浏览器、OS组合登记为待所属阶段准入，未实测不标通过。区分原材料建议、官方可见事实与本项目真实PoC；不凭star数、Issue标题或报告版本范围选架构。

负向验收 不得运行时拉取latest或复制许可证不明代码；单个Issue不能替代真实版本验证。；不得把候选清单变成M0批量安装命令，或把AGPL/GPL笼统宣称为违法；MPL、双许可、bootloader例外和非包资产逐项核验。

验证方法 依赖清单逐个可追溯官方URL与版本；复制代码时记录原许可证与归属。 核对command-group弃用与service-manager平台边界，保留未决证据；后续组件不因报告列出版本就标已锁定。

完成证据 提供更新后的范围/ADR/清单及决策理由，明确原要求、建议和未验证假设。；给出与任务验收对应的评审检查结果；涉及spike时记录环境、最小命令和实际观察，不以文档代替实测。；当前阶段来源/许可证证据、后续候选状态及每个否决或延期决定的理由。

设计依据 docs/00_scope.md；docs/01_gap_review.md；docs/02_architecture.md；docs/06_tools_providers.md；docs/07_feishu.md；docs/08_desktop_release.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-005 建立最小仓库和工具链

优先级 P0 规模 M 职责 Platform 状态 TODO

前置依赖 OB-001、OB-004

需求映射 RQ01、RQ11、RQ12

风险 MEDIUM / 工具链不可复现会放大多代理集成冲突。

交付路径 pyproject.toml；uv.lock；services/core/src/openbot；apps/cli；.github/workflows/pr.yml；tests/contracts

相关组件 cli-toolchain

复用方式 独立资格验证

复用要求 uv及必要开发工具先锁；仅安装当前bootstrap需要的批准依赖，禁止M0一次uv add全部候选；CI从第一批PR执行组件清单一致性。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 建立services/core、apps/cli、contracts及当前任务必需的可导入最小包，使用uv锁定当前已核准工具；不建立全部业务空壳。；配置lint/type/单元与合同测试及三OS基础CI，把依赖准入检查接到后续OB-089提供的检查器。；提供version/health样例和fake入口；验证最小依赖安装，模块import不联网、不创建daemon、不读取用户秘密。

正向验收 建立Python 3.12初始验证基线、uv锁、最小CLI和domain导入；lint/type/test统一；只建当前任务必需模块；M0已有三OS基础CI。 依赖按dev-contracts/core等分组，M2/M3/M4/P2组件不进入M0默认环境；后续缺可选组不会破坏核心导入。

负向验收 导入模块不得联网、创建daemon或读取用户秘密；不能一次生成全部业务空壳冒充实现。；不得在M0一次安装lark、Playwright/MCP、全部Provider、Tauri或GUI/调度候选；不得运行期自动补包。

验证方法 三个OS运行安装、版本输出、一个有效测试；锁文件可复现；模块import无网络或外部进程。 空环境记录实际安装包树、锁和import网络/进程观察范围。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留最小可运行样例或golden fixture，以及对应静态/合同验证输出。；M0最小锁文件及安装清单，后续组未被默认解析/导入的验证。

设计依据 docs/02_architecture.md；docs/00_scope.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-089 建立组件准入目录和分阶段依赖门禁

优先级 P0 规模 M 职责 Lead 状态 TODO

前置依赖 OB-004、OB-005

需求映射 RQ07、RQ11、RQ12

风险 HIGH / 候选组件被自动安装、许可证/传递依赖不明、import或首次使用发生副作用。

交付路径 components/catalog.json；components/dependency-lock.template.json；scripts/check_components.py；tests/components/admission

相关组件 cli-toolchain；sbom-tools

复用方式 独立资格验证

复用要求 本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 依照components/catalog.json合同记录候选来源、复用方式、所属阶段/依赖组、选择类别和NOT_RUN资格状态；实际版本/摘要/文件许可证/NOTICE在实施准入时填入，不伪造锁定结果。；检查器比较catalog、各生态实际锁及资产清单；只允许当前阶段通过准入的功能组进入目标环境，后续候选不进入core默认依赖。；建立版本/配置/源码更新的差异和受影响Q门禁规则；license/来源/资产缺失或状态不符阻止该能力启用，不自动换备用库。

正向验收 空环境bootstrap只装当前最小dev-contracts/core集合；Feishu/Browser/MCP/Tauri/P2候选仍可登记而不安装。实际启用组件可追溯来源、精确锁、LICENSE/NOTICE、配置/平台与资格证据；未准入、跨阶段默认安装和锁/目录不一致fixture能够阻断。

负向验收 不得把报告推荐/宽松许可证/star数当作准入批准；不得因安装方便把全部候选放入core默认组。

验证方法 分别生成最小bootstrap与一个选定后续组的安装/导入清单，模拟未核准包、错误阶段、遗漏资产hash和许可证不明，验证检查器拒绝；NOT_RUN不能自动变为通过。

完成证据 组件目录样例、每组解析清单、锁diff、许可证原文定位、拒绝fixture运行记录。；记录精确来源/版本、OS/架构/配置、测试命令与限制；本包只定义门禁，真实结果未实施前保持NOT_RUN。

设计依据 docs/00_scope.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

OB-006 定义事件与命令协议

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-002、OB-005、OB-089

需求映射 RQ02、RQ10

风险 HIGH / 协议漂移可能破坏去重、授权与恢复。

交付路径 contracts/schemas；services/core/src/openbot/domain/events.py

相关组件 pydantic-jsonschema

复用方式 依赖适配

复用要求 用Pydantic/jsonschema做边界校验，领域对象深层不可变；拒绝未知权威字段、重复JSON键，完整合同一致性在OB-090验证。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 按docs/05定义Inbound/Runtime事件字段、版本、作用域与错误。；实现边界校验和golden样例，建立DB seq与客户端去重规则。；明确业务事件持久化、token流临时化以及未知版本处理。；以准入的Pydantic/jsonschema封装严格JSON边界：进入dict前拒绝重复键，约束类型转换/extra，深层冻结或保存不可变canonical bytes；格式/refs合同交OB-090验证。

正向验收 事件有schema_version、event_id、trace/correlation和source；RuntimeEvent使用DB seq；入站身份由可信边界产生；任务状态表权威，events仅审计与增量流。 Pydantic frozen不充当深层不可变证明；外部修改嵌套dict/list不能改变已持久化提案。Draft2020-12完整验证、使用中的format显式检查，引用只来自审核本地注册表。

负向验收 外部is_owner/role字段不得成为可信身份；回放事件不得发起工具调用。；禁止静默保留重复键最后值、自动强制类型转换权威字段或联网获取远程Schema。

验证方法 黄金JSON双向验证；未知字段/版本策略明确；恶意外部身份字段不能成为授权依据。 测试嵌套变异、重复键、错误UUID/时间、未知字段、未知/远程ref与有界schema解析。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留最小可运行样例或golden fixture，以及对应静态/合同验证输出。

设计依据 docs/05_storage_api.md；docs/03_runtime_recovery.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-008 定义配置与网络模式

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-002、OB-005、OB-089

需求映射 RQ01、RQ06

风险 CRITICAL / 模式歧义会造成用户未授权的数据离机。

交付路径 contracts/schemas/config.schema.json；services/core/src/openbot/config.py；config/openbot.example.toml

相关组件 model-ollama；model-runner

复用方式 依赖适配

复用要求 配置/目录原语可复用；M0定义模式和runner禁云/egress资格合同并用fake验证，真实本地证明到OB-026完成，localhost不单独作保证。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 定义带版本的profile配置和CONNECTED/LOCAL_MODEL/OFFLINE语义。；实现启动校验、显式能力禁用和最小权限默认值。；把各连接工厂接到模式策略，输出冲突和不可用原因。；M0定义各依赖组/连接工厂、runner禁云、允许模型和egress证据字段，用fake连接/空缓存资产fixture验证冲突与拒绝；真实Provider/runner和实际出口分别留在其所属阶段完成。

正向验收 CONNECTED、LOCAL_MODEL、OFFLINE三个枚举及独立数据出口规则一致；OFFLINE禁用飞书和外网Browser/MCP；本地模型失败不云回退；配置版本化并默认最小权限。 localhost和模型名不单独证明本地推理；LOCAL_MODEL限定实际本地模型，OFFLINE约束OpenBot及受管执行域的全部出口。无可核验证据返回CAPABILITY_UNAVAILABLE，不声称整台电脑断网。 本任务交付配置合同与最小fake拒绝门禁；真实Ollama/model/runner资格在OB-026验证，不要求M0安装或调用M3组件。

负向验收 OFFLINE不得仍连飞书；LOCAL_MODEL失败不得自动切云模型。；不得让loopback服务转云模型/web search或隐式代理绕过模式；运行期不得拉取模型或资产。

验证方法 M0测试配置冲突、空secret、错误目录、非法权限、假连接工厂与空缓存资产缺失；OFFLINE和LOCAL_MODEL错误配置/转云请求在fake合同中被拒绝，最小启动无意外网络。真实本地runner/模型及实际egress证据由OB-026/Q04提供。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留最小可运行样例或golden fixture，以及对应静态/合同验证输出。；模式配置/依赖组/runner准入字段、fake拒绝与最小启动的网络观察范围；真实本地模型证据明确标为OB-026待验证。

设计依据 docs/00_scope.md；docs/04_security_approvals.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-007 定义工具和模型Provider契约

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-002、OB-006

需求映射 RQ05、RQ07、RQ09

风险 HIGH / 适配器绕过统一合同会形成隐藏执行路径。

交付路径 contracts/schemas/tool_proposal.schema.json；services/core/src/openbot/domain/tools.py；services/core/src/openbot/domain/providers.py

相关组件 pydantic-jsonschema；model-runner

复用方式 自研控制语义

复用要求 Provider/Tool合同保留自有权威字段；完整Draft2020-12验证、明确format策略、只用本地受控refs；半包或schema失败无派发。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 定义Text/ImageRef/ToolCall/ToolResult、Provider能力和标准错误。；定义ToolProposal与manifest，标注模型可填字段和daemon补齐的权威字段。；用两个fake Provider和一个fake executor验证同一合同。；固定Provider允许的基础请求API/字段和完整schema验证，普通function只产生提案；禁自动tool_runner/Agent Runner、未纳管Provider托管工具及任意extra_body/extra_headers透传。

正向验收 工具与Provider使用明确的proposal/result与message块；manifest声明effect、retry_class、取消、reconcile和限制；模型仅填工具参数，不能伪造权威身份、policy或dispatch token。 校验器支持约定的Draft2020-12组合/本地ref/format与输入上限；模型、页面或插件不能改endpoint、认证头、policy或server-side tools。

负向验收 半包tool args、未知工具或外部自报readOnlyHint不得直接派发。；任何官方SDK自动工具helper、remote MCP或托管执行工具均不得绕过Broker；工具Schema不直接注册可执行Python函数。

验证方法 两种不同Provider的fake实现共用同套契约；原始模型消息不会直接传给executor。 用canary函数计数验证批准前为0；恶意extra_body/remote MCP/认证覆盖请求被拒绝。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留最小可运行样例或golden fixture，以及对应静态/合同验证输出。

设计依据 docs/06_tools_providers.md；docs/05_storage_api.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-009 统一错误与时钟语义

优先级 P0 规模 S 职责 Runtime 状态 TODO

前置依赖 OB-006、OB-007

需求映射 RQ03、RQ10

风险 HIGH / 错误与时间语义不一致会造成误重试和过期授权继续执行。

交付路径 contracts/schemas/error.schema.json；services/core/src/openbot/domain/errors.py

复用方式 自研控制语义

复用要求 错误/UTC/单调钟语义自研；SDK timeout/取消映射不得直接等于可重试或已回滚。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 冻结错误码、retryable与UNKNOWN关联，区分业务失败、拒绝和结果不明。；抽象UTC clock与monotonic clock，并定义休眠/回拨/重启处理。；为接口、工具和日志建立一致的序列化。；区分调用方等待超时、数据库实际提交、SDK取消确认和外部效果状态；deadline覆盖排队/连接/读取/提交相关等待，不能只设置busy_timeout。

正向验收 错误code/message/retryable/trace_id一致；OUTCOME_UNKNOWN指Operation UNKNOWN、Task RECONCILING；持久时间用UTC毫秒，进程timeout用单调钟，重启敏感TTL需复验。 超时不自动推断回滚或可重试；已进入提交段的结果必须能按稳定请求标识核对。

负向验收 timeout不能默认当FAILED可重试；客户端时间不能决定授权有效性。；不得将CancelledError统一映射为“未执行”或把所有Exception交通用retry装饰器。

验证方法 覆盖时钟回拨、睡眠后过期、Provider超时与策略拒绝；不会把所有Exception都重试。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留最小可运行样例或golden fixture，以及对应静态/合同验证输出。

设计依据 docs/03_runtime_recovery.md；docs/05_storage_api.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-010 建立确定性系统测试夹具

优先级 P0 规模 M 职责 QA 状态 TODO

前置依赖 OB-005、OB-006、OB-007、OB-009

需求映射 RQ03、RQ12

风险 HIGH / 没有可控故障夹具会遗漏最危险的提交窗口。

交付路径 tests/fakes；tests/scenarios；tests/chaos/faults

相关组件 httpx；pydantic-jsonschema

复用方式 独立资格验证

复用要求 pytest/respx/hypothesis按开发组准入；夹具计数真实HTTP尝试与外部副作用，能模拟返回前成功、调用方取消后提交、SDK重试。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 实现fake模型、平台、时钟、执行器和supervisor端口。；让测试可在指定事务前后崩溃并统计真实模拟副作用次数。；建立seed和fixture隔离，使同一场景可复现。；增添fake HTTP逐次请求计数、分片/退避取消、Writer等待取消后实际commit和隐式下载夹具；respx仅证明其拦截transport，另记录进程/网络探针覆盖范围。

正向验收 提供fake模型、fake飞书、fake时钟、可控executor和崩溃点；场景断言面向用户结果和副作用次数。 夹具能检测SDK重试叠加、取消后新请求、外部成功本地未知以及caller取消后实际事务结果；实际SDK接入验证在所属阶段执行；不以单一HTTP mock声称全进程无网络。

负向验收 测试不得依赖生产账号；fake永远成功不能作为恢复验证。；不得使用永远成功的Mock掩盖未知效果，也不能把普通Python异常当断电实测。

验证方法 同一seed重复执行输出一致；夹具可模拟“外部成功但本地超时”。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留最小可运行样例或golden fixture，以及对应静态/合同验

证输出。；可重放seed、网络尝试/副作用计数器、writer提交前后取消与反例fixture。

设计依据 docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-090 验证Schema与JCS标准合同向量

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-006、OB-007、OB-010、OB-089

需求映射 RQ02、RQ04、RQ07、RQ09、RQ12

风险 HIGH / 浅不可变、JSON歧义或不一致规范化导致批准绑定发生变化。

交付路径 tests/contracts/canonicalization；tests/contracts/schema；contracts/golden

相关组件 pydantic-jsonschema；rfc8785

复用方式 独立资格验证

复用要求 本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 用完整Draft2020-12校验器与审核本地Schema Registry，明确strict/coercion、extra、format与大小/递归/引用上限；进入普通dict前拒绝重复JSON键，未知/远程ref不联网。；Python权威Canonicalizer调用获准RFC8785实现，使用独立标准golden vectors验证UTF-16码元排序、负零/指数、数值域、Unicode及非法输入；不在测试中重写同样排序算法充当oracle。；测试深层不可变/规范字节持久化和对外拷贝，frozen=True不替代嵌套变异防护；若实际存在第二JCS实现才跨实现比较字节/hash，不要求不用JCS的UI另实现。

正向验收 Python权威端的canonical bytes与SHA-256匹配经过核实的标准向量；覆盖非BMP与BMP键排序、负零/指数、嵌套、大整数边界，拒绝重复键、非有限数、非法Unicode/键和合同不支持数值。完整schema组合/本地refs/extra/指定format有反例；已批准内容不受外部嵌套变异影响。只有实际第二实现才比较同值字节与hash。

负向验收 不得用json.dumps(sort_keys=True)或Unicode码点排序代替JCS；不得让远程refs、重复键、隐式类型转换或默认忽略format放行。；不得把Pydantic frozen当深层不可变，也不得为了测试人为新增UI哈希授权逻辑。

验证方法 固定向量断言规范字节和hash，输入解析层拒绝重复键；注入嵌套变异、错误UUID/时间/格式、未知ref/远程URL、过深schema，观察零网络。第二实现不存在时明确NOT_APPLICABLE，不能伪报跨语言测试通过。

完成证据 标准向量来源及所选库版本/hash、正负fixture和Python输出；schema/format/ref边界与深层变异结果。；实际第二实现存在时附跨实现比较；不存在时记录NOT_APPLICABLE及Python权威边界。；记录网络观察范围，证明被拒绝ref没有触发下载。

设计依据 docs/04_security_approvals.md；docs/05_storage_api.md；docs/06_tools_providers.md；docs/09_testing_operations.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

OB-091 交付最小claim/dispatch崩溃协议PoC

优先级 P0 规模 M 职责 QA 状态 TODO

前置依赖 OB-009、OB-010、OB-090

需求映射 RQ02、RQ03、RQ04、RQ12

风险 HIGH / 等真实组件全部完成才发现claim/dispatch协议不可恢复。

交付路径 tests/protocol/early_recovery_poc；docs/evidence/protocol-poc.md

相关组件 sqlite3；rfc8785

复用方式 独立资格验证

复用要求 本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 在测试目录用FakeChannel/Provider、FakeClock、真实临时SQLite、标准JCS及计数MockWorker组成最小协议模型；不增加正式表/API或第二生产调度器。；在claim前后、CLAIMED→DISPATCHING前后及fake外部成功后本地确认前注入崩溃；插入取消/epoch/resource变化和caller等待取消。；保存不变量与反例供M1重用，分别核验CONSUMED、Attempt/Operation标识、未知效果/quarantine与证据核对；OB-029仍做真实本地端口/隔离路径完整集成。

正向验收 不需任何云key、飞书、完整CLI或容器；CONSUMED不逆转，同Attempt重传ID不变、新Attempt新ID且provider键稳定；派发前复核失败效果计数0，已派发无回执保持UNKNOWN/RECONCILING并阻断资源；无证据人工success不能强改。

负向验收 不得省略第二事务，不能把fake成功证明M1系统完成；不把PoC表加入正式23表基线或新增API。；禁止把M0临时测试模型或MockWorker通过写成完整M1实现/真实OS隔离已经完成。

验证方法 一条离线命令运行固定seed/故障矩阵；查询临时库与MockWorker效果计数，验证派发前失败为0、未知结果不重发、换Task/Operation也不能越过quarantine。无需真实Provider、完整CLI、飞书或容器。

完成证据 一条可运行PoC命令、seed/故障位置、SQLite快照、dispatch与效果计数、失败反例。；记录精确来源/版本、OS/架构/配置、测试命令与限制；本包只定义门禁，真实结果未实施前保持NOT_RUN。

设计依据 docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/05_storage_api.md；docs/09_testing_operations.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

M1 本地内核与安全工具

本阶段 37 项任务。按 depends_on 拓扑推进；编号顺序不替代依赖关系。

OB-011 实现带版本的数据库迁移

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-006、OB-009、OB-091

需求映射 RQ02

风险 CRITICAL / 迁移或约束错误会丢失任务与授权证据。

交付路径 db/migrations；services/core/src/openbot/storage/migrate.py；tests/integration/storage

相关组件 sqlite3；aiosqlite；yoyo-migrations

复用方式 依赖适配

复用要求 优先标准库sqlite3，aiosqlite仅经过PoC后可选；顺序checksum迁移自有，禁止ORM隐式写入/级联或无理由再加迁移框架。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 逐项实现docs/05表、唯一键、外键、状态约束和查询索引。；编写顺序迁移和checksum记录，提供旧版本fixture及损坏版本拒绝。；验证全新建库、升级、中断与重启后的完整性。；优先sqlite3专属writer线程，aiosqlite仅是经准入的驱动可选项；版本/checksum迁移器继续自有，不因选库引入隐式ORM写入或第二迁移框架。

正向验收 实现docs/05逻辑表和约束、版本与checksum迁移；MVP不提前建embedding/schedule；旧11表如存在仅走显式迁移；迁移前后完整性可检查。 每个实际连接明确设置并读回WAL/FULL/foreign_keys，不凭任何驱动默认值断言耐久性。

负向验收 不能覆盖用户现有库、跳过不兼容版本或静默修改已发布migration。；不得将基线DDL直接等同完整迁移器，或宣称ORM必然不安全来替代本项目事务证据。

验证方法 新库→最新与旧版本→最新均成功；中断迁移不留下半版本；不支持版本启动时明确退出。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；所选驱动/SQLite构建版本和实际PRAGMA读回、迁移失败恢复记录。

设计依据 docs/05_storage_api.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-092 建立组件副作用和重试取消故障契约

优先级 P0 规模 M 职责 QA 状态 TODO

前置依赖 OB-007、OB-008、OB-009、OB-010、OB-089、OB-090、OB-091

需求映射 RQ03、RQ06、RQ07、RQ08、RQ09、RQ12

风险 HIGH / SDK隐藏重试/下载/网络/取消语义绕开预算与恢复账本。

交付路径 tests/components/contracts；tests/components/probes；docs/evidence/component-fault-contract.md

相关组件 httpx；model-openai；model-ollama；model-anthropic；model-runner；detect-secrets

复用方式 独立资格验证

复用要求 本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 建立有界子进程/网络探针和fake HTTP计数器，覆盖import、初始化、首次实际调用、DNS/代理/下载/线程、流/取消/关闭；分别说明respx与平台审计覆盖。；默认SDK max_retries=0并关闭transport隐式重试，由OpenBot唯一管理次数/退避/deadline/预算；任何委托SDK例外须逐次可观测且不得叠加tenacity。；限定SDK允许API，canary验证tool_runner/Agent Runner/Provider托管工具和remote MCP不执行；加入localhost转云、scanner联网验证/allowlist与取消后新请求反例。；当前M1候选完成实际合同，后续每个SDK在自己的阶段填真实证据；提供可重用runner与失败样例，fake通过不自动认证后续组件。

正向验收 实际HTTP请求数与Gateway request-attempt/预算一致，取消或流中断终止当前调用后不会由隐藏层自动新发；应用主动新尝试必须走显式策略。导入/首用意外联网下载、自动工具执行、网络验证或外部allowlist旁路都能触发门禁；每个真实组件的结果独立记录。

负向验收 不能仅patch httpx就声称拦住requests/urllib/子进程全部网络；fake测试通过不代表lark、Playwright或MCP真实实现通过。；官方SDK来源、loopback地址、扫描阴性或单一httpx mock均不能自动证明没有隐藏执行/云外发。

验证方法 以fake server产生连接失败、429/503、退避取消、首块后中断/取消与未知usage；计数SDK/transport/Gateway层，对网络探针未覆盖路径显式记录限制。后续适配器逐个重用该合同。

完成证据 探针覆盖范围/局限、attempt计数、fault traces、组件合同runner使用说明与反例。；记录精确来源/版本、OS/架构/配置、测试命令与限制；本包只定义门禁，真实结果未实施前保持NOT_RUN。

设计依据 docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/06_tools_providers.md；docs/09_testing_operations.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

OB-093 验证首发OS的Supervisor与隔离后端能力

优先级 P0 规模 M 职责 Platform 状态 TODO

前置依赖 OB-003、OB-004、OB-007、OB-008、OB-010、OB-089、OB-091

需求映射 RQ01、RQ03、RQ05、RQ11、RQ12

风险 HIGH / wrapper名称掩盖原生能力差异、客户端退出后容器或子孙仍运行。

交付路径 tests/components/native_poc；native/supervisor/src/platform；docs/evidence/backend-capabilities.md

相关组件 profile-locks；windows-sys；processkit-process-wrap；ur-taking-me-with-you；service-manager；python-on-whales；command-group

复用方式 独立资格验证

复用要求 本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 在首发OS选择一个原生进程实现和一个Docker隔离组合，记录实际版本/feature/权限；不新引command-group，不推断service-manager Windows具备User后端。；确定profile唯一排他锁持有者并测试父子交接/独立启动，防父supervisor与daemon互相争锁自锁。；测试实际进程创建/Job或对应OS控制、父/子孙/监督进程强杀、Job分配失败/逃逸与独立容器残留；记录归属id与清理证据。；验证容器stop/wait→受限导出校验→remove，无法证实旧执行域失效则拒绝新dispatch；其他OS仍NOT_RUN，交OB-069—071完成资格。

正向验收 首发OS原语成功与失败路径有可重复证据，profile锁无父子自锁；容器不依赖CLI存活，被登记的遗留执行域可核对与停止，无法确认时保持隔离。不支持的OS/backend路径明确CAPABILITY_UNAVAILABLE，不给通用crate全平台/100%保证。

负向验收 不得据processkit/service-manager等宣传宣称100%清理或三平台兼容；不能把杀掉docker客户端当成销毁容器，不能回退高权限或宿主执行。；禁止父子同时获取同一profile排他锁；service-manager不支持的Windows用户会话不得以系统服务代验。

验证方法 构造第二实例/父死/锁交接失败和多代子进程；Windows适用时核对挂起→入Job成功→恢复与失败不执行；kill容器CLI后单独核对容器最终状态和导出次序。

完成证据 OS/arch/版本、可重放命令、父子PID/容器id前后清单、失败样本与能力矩阵。；记录精确来源/版本、OS/架构/配置、测试命令与限制；本包只定义门禁，真实结果未实施前保持NOT_RUN。

设计依据 docs/02_architecture.md；docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

OB-012 实现串行写事务与数据库背压

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-011

需求映射 RQ02、RQ03

风险 CRITICAL / 提交与执行顺序破坏会使系统做过动作却无记录。

交付路径 services/core/src/openbot/storage/writer.py

相关组件 sqlite3；aiosqlite

复用方式 依赖适配

复用要求 sqlite3默认、aiosqlite可选；完整WriterCommand事务由唯一writer独占，稳定request_id关联持久结果，caller取消不等于回滚。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 以稳定request_id的完整WriterCommand作为唯一写入口，writer独占BEGIN到COMMIT/ROLLBACK；业务协程不能获得可写连接。；实现有界队列、审批/取消/入站/结果的保留容量与公平性、总deadline及读回WAL/FULL/FK；驱动串行SQL不替代完整事务所有权。；caller取消/timeout只结束等待，不假称底层回滚；通过已有幂等记录及Task/Operation/事件关联重查持久结果，实际提交后才能ACK。；注入入队、事务开始、commit前后取消和队列拥塞，确认命令不相互提交/回滚；提交结果不明时禁盲重放和新派发。

正向验收 单writer队列有界、短事务、关闭/背压协议；审批/取消/入站有配额；WAL、FULL、foreign_keys实际校验；busy_timeout不超过调用剩余deadline；提交失败阻止新派发。 WriterCommand携带稳定请求ID并关联可重查的持久结果；使用aiosqlite也不把共享写连接暴露给适配器。caller等待取消、deadline与实际commit结果分别记录。

负向验收 事务内不得await网络/人工或嵌套等待writer；队列满不得静默丢弃。；不得因Future取消或超时回复“已回滚”，也不得重发同一非幂等写命令猜测结果；父/子协程不得穿插同一连接事务。

验证方法 并发读写与队列满验证无任务静默丢弃；故障时调用方收到确定错误；事务回滚后可继续。 同时运行两个写命令，在入队/执行/commit前后取消调用者并按同一请求ID重查；普通队列满时取消/结果仍可提交，高优洪峰不无限饿死其他请求。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；稳定request_id与权威结果关联、提交点日志、队列配额/公平性和取消反例。

设计依据 docs/05_storage_api.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-013 实现持久inbox与作用域去重

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-006、OB-011、OB-012

需求映射 RQ02、RQ08

风险 HIGH / 去重作用域错误会丢任务或重复创建任务。

交付路径 services/core/src/openbot/storage/inbox.py

相关组件 sqlite3

复用方式 自研控制语义

复用要求 持久作用域去重与ACK提交边界不变；不能改用SDK内存去重。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 规范source_scope与外部event幂等键，保存payload hash。；把inbox、Task与初始event/outbox封成一个事务用例。；实现重复返回与同key异payload冲突，并注入ACK前后崩溃。

正向验收 source_scope包含channel、tenant、app与profile；inbox与TaskQueued同事务；成功只在提交后返回；同幂等键不同payload返回冲突，重复请求查询原Task。

负向验收 未持久提交不得ACK成功；不同tenant/app相同event ID不能互相去重。

验证方法 100次同源事件只创建1任务；不同app相同event_id不互相误去重；落盘前后崩溃结果一致。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/05_storage_api.md；docs/02_architecture.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md

OB-014 实现任务状态与事件原子提交

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-011、OB-012、OB-013

需求映射 RQ02、RQ03

风险 CRITICAL / 状态权威不清会造成虚假完成与重复执行。

交付路径 services/core/src/openbot/application/state_machine.py

相关组件 sqlite3

复用方式 自研控制语义

复用要求 Task、状态版本CAS、event/outbox同事务保留自研；不得交给外部Agent状态机。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 将docs/03 Task跃迁表编码为domain规则与version CAS。；实现状态+审计+outbox的原子application用例。；实现只读审计回放与状态快照，验证非法跃迁拒绝。；将WriterCommand稳定请求ID和幂等结果关联到既有持久记录；调用方timeout/断连后使用相同标识读取实际状态，不新增第二权威账本。

正向验收 实现docs/03 Task合法跃迁与version CAS；权威task/operation、event、outbox同事务；Task使用QUEUED/RUNNING等定义，审计回放绝不执行历史工具。 caller取消不破坏状态/event/outbox原子性；只有确认实际commit才返回成功，重复请求先查原结果而不重新执行事务语义。

负向验收 模型final不得直接把Task标SUCCEEDED；事件回放不得执行副作用。；HTTP断连或协程取消不能充当“事务未发生”的证据，也不能回ACK后让writer静默丢弃写命令。

验证方法 对每条合法/非法跃迁验证；崩溃后状态和event版本不分裂；重放不会启动executor。 commit完成前后断开调用者，重查同一请求ID的状态/event/outbox一致且无重复副作用。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/03_runtime_recovery.md；docs/05_storage_api.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-015 实现单实例daemon和调度租约

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-003、OB-014、OB-093

需求映射 RQ01、RQ03

风险 CRITICAL / 双调度可重复执行已批准的危险动作。

交付路径 services/core/src/openbot/application/scheduler.py；native/supervisor/src/instance_lock.rs

相关组件 profile-locks；windows-sys

复用方式 原生原语适配

复用要求 OS锁候选filelock/fd-lock等只能封装底层锁；profile唯一实例、epoch/fence/旧worker隔离自研。；实际OS、架构、backend和配置组合须独立提供证据；统一API、正常退出或进程组不能自动证明所有强杀与逃逸场景均可回收。

实施步骤 由supervisor获取profile OS锁并生成runtime_epoch。；实现单活动Task调度、claim租约、等待释放槽位和旧epoch拒绝。；用双实例与失联worker场景验证唯一执行者边界。；选定唯一profile排他锁拥有者及显式交接协议；父supervisor持锁时daemon验证受管身份而不重取同一锁，独立daemon启动路径另测。

正向验收 每profile默认一个活动Task和唯一daemon；runtime_epoch及fence拒绝陈旧提交；等待审批释放计算槽位；不能确认唯一实例或旧worker失效时不开始新执行。 OS锁原语只能证明持有关系，epoch与旧worker隔离仍自有；父子启动不会自锁。

负向验收 无法确认旧worker停止时不得凭租约超时开第二执行者。；禁止supervisor和daemon同时等待同一profile排他锁；租约到期不能单独证明旧进程已失效。

验证方法 两个daemon竞争只有一个获得实例锁；过期worker不能提交新状态；机器重启后可接管。 父子正常启动、第二实例、父死重启和锁交接失败均验证有界返回，不出现永久等待。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/03_runtime_recovery.md；docs/02_architecture.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-017 实现动作意图与执行attempt日志

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-011、OB-014

需求映射 RQ02、RQ03

风险 CRITICAL / 这是外部副作用可能重复的核心窗口。

交付路径 services/core/src/openbot/application/operations.py

复用方式 自研控制语义

复用要求 保持Operation级provider幂等键、Attempt级dispatch_id与CONSUMED不可逆；组件自动重试须映射到受控尝试而非绕开账本。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现不可变Operation与Attempt分表：provider_idempotency_key属于Operation，dispatch_id属于Attempt；同Attempt传输重试固定dispatch_id，新Attempt生成新dispatch_id。；首次CLAIMED事务消费批准并建立Attempt；Approval一旦CONSUMED永不退APPROVED。CLAIMED到DISPATCHING使用第二个短事务再次检查取消、runtime_epoch与资源版本，再持久化后发包。；保存接收ledger、receipt与UNKNOWN；同Operation安全重试只能由恢复器批准并沿用既有消费关系，仍复验原授权期限、policy、actor/identity、取消及resource，不二次消费或授权其他Operation。；覆盖claim后取消、同Attempt重传、新Attempt重试、外部成功后本地崩溃；记录ID与grant关系作为故障证据。

正向验收 Operation与Attempt严格分离；provider_idempotency_key在Operation内稳定，dispatch_id在同Attempt重传时不变、在新Attempt中重新生成。批准首次消费后永久保持CONSUMED历史关系，不退APPROVED。CLAIMED→DISPATCHING第二短事务复核取消、epoch与资源，成功提交后才能派发。安全重试仅由恢复器对同Operation复验原期限、policy、actor/identity、cancel与resource后允许，任一条件变化则新建Operation；结果不明进入UNKNOWN。

负向验收 禁止把CONSUMED改回APPROVED、二次消费或借给其他Operation；通用重试按钮/adapter不能自行判定已消费grant可重用。；禁止给同Attempt传输重试换dispatch_id，或让新Attempt沿用旧dispatch_id；不得在创建新

Attempt时更换同Operation的provider幂等键。；claim之后、DISPATCHING提交之前发生取消/epoch失效/resource变化必须阻止派发；仅claim时检查不满足验收。

验证方法 注入intent、CLAIMED、DISPATCHING前后、外部成功和结果提交故障；断言同Attempt重传只接受同dispatch_id，新Attempt用新dispatch_id且保留Operation的provider_idempotency_key；CONSUMED无逆向状态变化；claim后取消/epoch或资源变化没有任何worker接收。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；提供Operation/Attempt/dispatch/provider幂等键/grant关联快照，证明CONSUMED单向性与两次短事务的检查点。

设计依据 docs/03_runtime_recovery.md；docs/05_storage_api.md；docs/09_testing_operations.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md

OB-016 实现执行资源锁与会话排队

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-015

需求映射 RQ03、RQ05、RQ09

风险 HIGH / 资源竞争会覆盖用户改动或操作错误页面。

交付路径 services/core/src/openbot/application/resources.py

复用方式 自研控制语义

复用要求 资源锁与UNKNOWN quarantine保持权威账本定义，库的进程内mutex不替代持久资源隔离。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 定义四类资源键、锁owner/epoch/fence和固定获取顺序。；在单活动Task基线上实现等待、释放与重获后的版本核对。；为人工审批和接管设计不长期持锁的释放点。

正向验收 workspace、browser_profile、desktop_session与external_account资源键明确；MVP活动执行默认串行；锁不跨人工等待，恢复后重获并校验版本；未来并发需有序多锁。

负向验收 等待审批不得长期占DB事务或资源锁；同profile两个浏览器写动作不能并行。

验证方法 并发任务不互相覆盖文件或抢浏览器标签；取消/崩溃释放或安全回收锁；无无限饥饿。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/02_architecture.md；docs/03_runtime_recovery.md；docs/14_revision_v1_2.md

OB-018 实现审批决定与一次性授权

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-002、OB-014、OB-017、OB-090

需求映射 RQ04

风险 CRITICAL / 错误绑定会让旧批准授权新动作。

交付路径 services/core/src/openbot/policy/approvals.py

相关组件 rfc8785；pydantic-jsonschema

复用方式 依赖适配

复用要求 Python为binding摘要权威，复用标准JCS与深层不可变字节；标准向量验证，不强制UI另写JCS。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 由Python权威端构造固定字段/版本的绑定对象，严格JSON校验后调用获准rfc8785生成并持久化canonical bytes与SHA-256。；实现审批预览、nonce/actor/TTL/policy/identity CAS和READY跃迁；深层不可变或拷贝防止批准后嵌套参数被改变。；记录决定与outbox，重复决定返回现状而不再授权；执行前核对同一规范字节/摘要与资源版本。；使用OB-090标准向量验证UTF-16排序、数值/Unicode边界；UI展示服务端hash，不强制为不使用JCS的UI再实现哈希。

正向验收 认证actor、profile、task、binding、nonce、TTL、identity_epoch及policy一起CAS；批准只将Operation改READY；Approval消费与执行结果分开；RFC8785 golden vectors验证binding hash。 Approval从APPROVED首次消费为CONSUMED后永不回退；同Operation是否可安全重试只能由恢复器复验既有消费关系，普通批准接口不能复活或再次消费授权。 RFC8785属性按UTF-16码元排序；非有限数、重复键、非法Unicode与超出合同数值域的输入拒绝。只有实际加入第二JCS实现时才要求跨实现字节一致。

负向验收 action.value中的actor/role、过期nonce、旧policy和变化参数必须拒绝。；禁止通过重复批准callback、API或人工核对把CONSUMED记录改回APPROVED。；不得用json.dumps(sort_keys=True)模拟JCS或只依赖frozen=True防嵌套变更；客户端重算hash不替代服务端授权。

验证方法 同一PENDING/version的并发互斥决定最多一个成功；后续针对尚未消费授权的合法撤销可按新version独立成功，并阻止claim/dispatch；错主体、错设备、过期、变更参数全拒绝；授权状态可审计。 嵌套变异与标准向量通过，错误代码点排序会失败；ApprovalPreview与执行绑定指向同一不可变内容。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/04_security_approvals.md；docs/05_storage_api.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-021 实现durable outbox及投递状态

优先级 P0 规模 M 职责 Integration 状态 TODO

前置依赖 OB-012、OB-014、OB-017

需求映射 RQ02、RQ08

风险 HIGH / 外发乱序或重试会造成错误状态和重复消息。

交付路径 services/core/src/openbot/application/outbox.py；services/core/src/openbot/storage/outbox.py

相关组件 tenacity

复用方式 自研控制语义

复用要求 outbox语义/调度自研；SDK退避仅在已审定投递类型内由一个所有者执行，计数可见，不能假称远端exactly-once。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现outbox语义键、revision、receipt、重试期限与dead letter。；把远端发送移到DB事务外，按接口幂等能力处理IN_FLIGHT恢复。；实现可合并进度和终态保护，提供后续gateway发送端口。；对SDK/HTTP/应用退避选一个所有者，逐次记录投递attempt、预算/deadline和receipt；库异常不得让outbox消费者重放原业务动作。

正向验收 持久化语义键、revision、IN_FLIGHT、attempt/deadline及远端receipt；发送在事务外；状态更新可合并，旧版本不能覆盖终态；远端结果不明按能力核对。 重试次数真实可数，迟到或重复回执不覆写更高revision，未知远端效果继续按既定能力核对。

负向验收 通知重试不能重执行业务；没有远端幂等保证不得声称exactly-once通知。；通用tenacity装饰器不能无界重试所有异常或驱动未知副作用再次提交。

验证方法 断网重启后通知仍存在；重复重试不倒退卡片状态；不能声称无远端幂等支持时exactly-once。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/05_storage_api.md；docs/03_runtime_recovery.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-023 实现任务预算和熔断

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-014、OB-017

需求映射 RQ03、RQ07

风险 HIGH / 预算竞争可造成无限循环与不受控费用。

交付路径 services/core/src/openbot/application/budgets.py

相关组件 tiktoken；tenacity

复用方式 依赖适配

复用要求 预算账本自研；tokenizer按模型选择、离线资源需预置与校验，不能把OpenAI词表当全模型精确计数；重试每次计费尝试都纳入预算。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 定义各预算与保守上限，调用前reserve并持久记录。；响应后settle真实用量；超时未知费用留待核对。；实现重复提案/连续错误/空转熔断与PAUSED恢复条件。；将估算/预留/真实usage/未知费用分开；tokenizer与模型、离线词表固定映射，实际HTTP重试逐次预留/结算，取消后不再发新请求。

正向验收 steps、模型调用、时间、tokens、费用、重试、工具与artifact大小均有限额；模型/工具调用前reserve，结果后settle；未知费用保守保留；预算不足进入PAUSED。 只有一个请求重试策略所有者；SDK与transport不得产生账本外请求。tiktoken不充当所有Provider完整请求的精确计费器，未知用量保守保留。

负向验收 并发或重试不得超卖预算；预算耗尽不得静默继续调用付费服务。；不得给未知模型套统一精确token数、在断流后清零费用，或把SDK重试叠加tenacity扩大预算。

验证方法 runaway模型无法无限循环；并发预算不超卖；预算不足任务进入可解释暂停而非静默结束。 429/503/连接断开与首块后取消逐次计数，实际请求数等于预算attempt记录；空缓存禁网词表首用成功或明确不可用。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；模型/编码器/词表hash、估算与usage偏差和每次请求的预留/结算证据。

设计依据 docs/06_tools_providers.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-024 实现上下文快照与摘要

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-014、OB-017、OB-023

需求映射 RQ06、RQ07

风险 HIGH / 上下文压缩可能丢约束或洗白注入内容。

交付路径 services/core/src/openbot/application/context.py

相关组件 tiktoken

复用方式 自研控制语义

复用要求 上下文裁剪/provenance/污点继承自有；复用tokenizer不替代上下文授权，也不额外引入Agent memory框架。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 建立有限上下文选择、消息与tool_call_id关联及来源标签。；实现保留目标、授权范围、待办和source refs的摘要。；验证长会话、跨重启和注入传播，输出用于模型的最小数据集。；按已声明模型使用准入tokenizer并记录估算误差；裁剪或摘要不得让外部内容获得权威字段，且不引入独立Agent memory执行循环。

正向验收 上下文来自目标、约束、状态、已批准范围与必要证据；摘要保留source refs与未决动作；数据分类和provenance不被摘要洗白；不持久化隐藏推理。 额外消息包装、tool schema和多模态开销有预算策略，不以纯文本分词数冒充最终费用。

负向验收 摘要、memory或模型转述不得把外部文字升级为系统/用户授权。

验证方法 长会话截断后仍能恢复待办与工具关联；注入文本经摘要后不会获得更高信任。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-031 实现确定性策略评估器

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-002、OB-007、OB-008、OB-018

需求映射 RQ04

风险 CRITICAL / 策略是全部执行能力的强制边界。

交付路径 services/core/src/openbot/policy/evaluator.py

相关组件 opa-casbin；pathspec

复用方式 自研控制语义

复用要求 不默认引入OPA/Casbin；pathspec只能辅助忽略/展示规则，不得作为安全路径白名单或授权判定。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现actor/resource/action/data/destination/backend组合规则。；冻结决策与理由码，明确硬拒绝和本地设置权限。；用表驱动输入和未知能力场景验证确定性。；维持纯代码表驱动策略；OPA/Casbin不作默认runtime，pathspec只做忽略/展示辅助，不能承担路径授权。

正向验收 以actor/resource/action/data_class/destination/backend和有效授权做纯确定性判断；输出ALLOW、ASK、DENY、REQUIRE_LOCAL及原因码；未知能力默认拒绝，硬拒绝不能被远程批准覆盖。 SDK helper、源码模板与工具metadata不能产生额外权限；未知工具/网络目标/执行器仍按确定性规则拒绝。

负向验收 模型risk评分、MCP hint或远程批准不得覆盖DENY/REQUIRE_LOCAL。；不得以pathspec匹配成功、官方包身份或第三方readOnlyHint替代六维授权判断。

验证方法 同一输入重复判定一致；未知工具默认deny；策略单元用例覆盖强制deny优先级。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/04_security_approvals.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-019 实现执行前授权claim和再校验

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-016、OB-017、OB-018、OB-031

需求映射 RQ03、RQ04、RQ05

风险 CRITICAL / 批准与派发之间的竞态可绕过用户决定。

交付路径 services/core/src/openbot/application/dispatch.py

复用方式 自研控制语义

复用要求 claim及CLAIMED→DISPATCHING两短事务自研，取消/epoch/resource复核不变；任何库不得在第二事务提交前发外部请求。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 Broker首次执行检查未消费批准；恢复重试只有恢复器能发出同Operation的安全复用决定。两条路径均复验原授权期限、policy、actor/identity、cancel和resource，CONSUMED永不复活为APPROVED。；首次claim短事务原子消费Approval、创建Attempt并进入CLAIMED；随后CLAIMED→DISPATCHING的第二短事务再次校验取消、runtime_epoch和resource，在持久化DISPATCHING后才允许发送。；dispatch token绑定本Attempt的固定dispatch_id、epoch、executor和资源；同Attempt重传保持ID，新Attempt生成新ID；Operation级provider_idempotency_key保持稳定，由worker ledger去重传输。；通过并发claim、claim后取消/撤销、原授权到期和资源变化验证派发门禁，确保普通CLI/gateway/adapter不能冒充恢复器复用CONSUMED。

正向验收 首次claim原子复验授权/任务/资源、消费Approval并创建Attempt，Operation进入CLAIMED；仅恢复器批准的同Operation安全重试可沿用匹配CONSUMED关系且不二次消费，仍复验期限、policy、actor/identity、cancel与resource。CLAIMED→DISPATCHING第二短事务再查取消、epoch和资源，提交成功才可派发。dispatch_id固定在Attempt，重传不变、新Attempt新ID；provider幂等键属于Operation。任何绑定条件变化都新建Operation重新审查。

负向验收 一个批准不得并发首次claim两次；CONSUMED不能退APPROVED、用于其他Operation或由普通客户端直接指定复用。；不能只在claim时检查取消/epoch/resource；DISPATCHING提交前已取消或资源失效必须零派发。；同Operation重试不能绕过原授权到期、身份撤销、policy变化或资源变化，不能通过刷新TTL延长原授权。

验证方法 对初次claim与恢复claim分别验证；在两事务之间插入取消、runtime_epoch变更和resource版本变化，断言无worker收到指令；并发首次claim最多一次消费；非法CONSUMED复用与原TTL/policy/actor/cancel/resource变化全部拒绝；检查Attempt级dispatch与Operation级provider幂等键。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；保存claim与DISPATCHING两次事务的version/epoch/cancel/resource快照，以及恢复器判断来源和拒绝理由；不得以模型日志代替。

设计依据 docs/04_security_approvals.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md

OB-032 实现工作区路径与文件访问守卫

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-002、OB-008、OB-031

需求映射 RQ04、RQ05

风险 CRITICAL / 路径绕过可能读取密钥或覆盖工作区外文件。

交付路径 services/core/src/openbot/tools/filesystem_guard.py

相关组件 pathspec；git-worktree

复用方式 原生原语适配

复用要求 路径/句柄守卫继续自有；Win32/OS库为原语，不能机械删除\?\前缀或仅字符串normalize后放行，保留拒绝与原生攻击语料。；实际OS、架构、backend和配置组合须独立提供证据；统一API、正常退出或进程组不能自动证明所有强杀与逃逸场景均可回收。

实施步骤 定义受管工作区与真实路径/句柄策略，并列各OS不支持路径类型。；实现读取/创建/替换前核验及执行时复验。；跑symlink、junction、ADS、UNC、父目录变化等原生OS语料。；审查快照构造和搜索适配器的实际路径/配置行为；git worktree准备须隔离或验证禁hooks/filter，不能因“创建快照”就视为无执行。

正向验收 宿主ACI使用路径对象与可用OS句柄防护，拒绝根外、设备/UNC/ADS和不支持的reparse point；创建时验证父目录和旧hash；同用户恶意竞态边界明确，必要时只开放受管工作树。 pathspec/.gitignore仅筛选内容；Windows路

径拒绝策略和真实句柄复核不能简化为去前缀或大小写归一。

负向验收 仅靠resolve或字符串prefix不能通过验收；根外与敏感路径必须拒绝。；不把rg、Git或dulwich绕过FileGuard；不可在未审查的仓库配置下执行post-checkout/filter等宿主代码。

验证方法 各目标OS原生攻击路径语料；替换链接竞态不能写到授权根外；没有承诺仅normalize即可彻底沙箱。 使用恶意Git hook/filter与rg配置canary，确认守卫/隔离先于任何潜在执行。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-038 实现密钥存储与最小注入

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-008、OB-031、OB-092

需求映射 RQ06、RQ11

风险 CRITICAL / 凭据泄漏会扩大到用户外部账户。

交付路径 services/core/src/openbot/policy/secrets；native/supervisor/src/credential_transport.rs

相关组件 keyring；crypto-storage

复用方式 依赖适配

复用要求 keyring择已验证OS后端；缺服务/锁定/交互错误明确失败，不把任意插件或自制Fernet存储作为自动fallback。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 实现OS凭据引用与凭据不可用的明确错误。；为gateway/模型/worker划分最小secret注入和短时IPC交接。；实现轮换、撤销与测试key canary扫描。；锁定keyring允许后端并验证锁定、无D-Bus/无图形会话/取消；不加载不明插件，不把缺独立主密钥设计的加密文件作为自动fallback。

正向验收 OS凭据存储或明确加密替代，配置仅secret_ref；gateway只有飞书secret，模型网关仅被选Provider key，worker用单用途secret handle；token不入argv或日志。 各OS凭据backend实际可用才启用能力；secret_ref失效可解释且不默默重新生成或扩大注入范围。

负向验收 不能继承全env、挂宿主HOME或把token写argv；钥匙串失败不能静默明文保存。；不得自动回退明文或未评审的cryptography/Fernet文件存储，也不得继承父进程全部env。

验证方法 测试凭据丢失/锁定；child env、日志、异常栈和诊断包均无测试密钥；无法调用钥匙串时不默默明文保存。 钥匙串不可用/权限撤销/用户取消/恢复旧引用后对应能力拒绝，输出保持无秘密。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/04_security_approvals.md；docs/02_architecture.md；docs/08_desktop_release.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-020 实现按副作用类型恢复

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-009、OB-015、OB-017、OB-019

需求映射 RQ02、RQ03

风险 CRITICAL / 错误恢复可能造成重复发送、覆盖或不可逆动作。

交付路径 services/core/src/openbot/application/recovery.py

复用方式 自研控制语义

复用要求 UNKNOWN/RECONCILING、证据核对、资源quarantine及唯一恢复器安全重试不变；人工文本success不能改账本，CONSUMED不退APPROVED。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 按docs/03检查唯一实例、schema和旧worker隔离，扫描权威Task/Operation/Attempt/Approval与dispatch ledger；未证明旧执行者失效就不接管派发。；区分未派发CLAIMED与可能执行过的DISPATCHING，按retry_class查询receipt或进入UNKNOWN/RECONCILING；只有恢复器可以判断同Operation是否满足安全重试。；安全重试沿用既有CONSUMED消费关系但永不退APPROVED、不二次消费；重新检查原期限、policy、actor/identity、cancel和resource。新Attempt使用新dispatch_id，保留operation_id与provider_idempotency_key；同Attempt重传才复用dispatch_id，派发前仍执行第二短事务检查。；人工reconcile接口仅接收并保存带身份、来源、hash/ref的核对证据；由恢复器/OutcomeVerifier按证据规则作状态决定，不接受用户一句success或指定目标状态覆盖数据库。不能确认时继续UNKNOWN/RECONCILING。

正向验收 恢复扫描权威表并隔离旧epoch，区分CLAIMED与DISPATCHING/UNKNOWN，按retry_class核对。仅恢复器可允许同Operation复用已有CONSUMED grant，永不退APPROVED且每次复验原期限、policy、actor/identity、cancel及resource；条件变化需新Operation。新Attempt新dispatch_id、同Attempt重传ID不变，Operation级provider_idempotency_key保持不变；CLAIMED→DISPATCHING再次复验取消/epoch/resource。人工reconcile仅记录核对证据，状态变更由验证规则决定，不接受用户指定success覆盖账本；无充分证据继续UNKNOWN/RECONCILING。 未核对UNKNOWN持有相关资源quarantine，普通resume或新Task/Operation ID不得绕过；取消终态必须无在途或结果未知操作。

负向验收 未解决UNKNOWN不能被模型、用户一句“success”、HTTP目标状态参数或普通管理按钮直接改为SUCCEEDED/CANCELLED，也不能以“忽略”触发重发。；CONSUMED不得退APPROVED、重复消费或供不同Operation使用；恢复器以外模块不得批准安全复用；原TTL/policy/actor/cancel/resource变化必须阻止复用。；同Attempt重传不能换dispatch_id，新Attempt不能复用旧dispatch_id，同Operation重试不能换provider幂等键；不具备核对语义的外部动作不得盲重发。

验证方法 逐崩溃点验证五类retry_class；测试原授权已到期、policy更新、actor撤销、取消、resource变化及无法隔离旧worker均拒绝安全重试。分别验证同Attempt重传与新Attempt ID关系、CONSUMED无回退。人工提交无证据success、伪造目标状态、重复证据或冲突receipt不得直接改账本；通过核验的证据保留审计来源。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；提供恢复器安全重试决定、原grant全部复验字段、Attempt/dispatch/provider key关系，以及人工reconcile原始证据引用和验证决定；证明人工说明未直接覆盖权威状态。

设计依据 docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md

OB-033 实现list read search文件工具

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-019、OB-032、OB-092

需求映射 RQ05、RQ06

风险 HIGH / 读取与搜索既能泄漏数据也能耗尽资源。

交付路径 services/core/src/openbot/tools/workspace/read.py

相关组件 ripgrep；pathspec；encoding-detectors

复用方式 依赖适配

复用要求 rg --json在受管快照/范围内受控调用，禁用户rg配置/危险链接与环境继承；UTF-8边界不因候选charset/binary包自动扩张；可不加ripgrepy。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 封装固定来源/摘要的rg二进制与结构化查询，显式--no-config、清理RIPGREP_CONFIG_PATH和代理/执行环境；不开放原始flags。；用-e绑定pattern、--分隔受控路径，禁--pre及动态外部预处理；在受管快照和FileGuard范围内运行。；分别限制深度、文件数、单文件、全局命中数/总字节/耗时；--max-count的按文件限制不代替全局上限。；验证UTF-8、二进制/权限/无匹配/恶意配置和符号链接，输出路径/行/hash/provenance并经Artifact策略。

正向验收 workspace.list/read/search有范围、深度、文件大小、时间和结果上限；UTF-8为MVP文本边界；返回路径/行号/hash/provenance，不把外部文件文字当指令。 MVP仍为UTF-8文本，不因encoding-detectors候选默认扩张或重写编码；ignore不授予根外权限。

负向验收 目录递归、regex或大文件不得无限占用资源；外部文件指令不得执行。；--pre、用户rg配置和以--开头的查询不能导致任意参数或进程执行；不得自动装ripgrepy等不必要包装。

验证方法 大文件、二进制、权限错误、无匹配可解释；根外读取拒绝；结果上限不绕过Artifact策略。 恶意配置预处理器canary为0；海量小文件命中/超长行受全局限额约束，所有路径重新验证。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；实际argv/最小env、二进制hash、全局限额与preprocessor拒绝证据。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-036 实现Artifact存储与可信元数据

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-011、OB-017、OB-032

需求映射 RQ02、RQ06

风险 HIGH / Artifact通道可绕过大小、权限和数据出口控制。

交付路径 services/core/src/openbot/artifacts

复用方式 自研控制语义

复用要求 hashlib、平台原子文件原语可用；content-addressed对象、fsync/rename、分类/引用和限额自有，不无理由加MIME/对象存储框架。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现内容写入、hash、原子注册及artifact_refs。；施加字节预算、classification、TTL与受限下载。；实现孤立对象回收、缺失对象状态与引用保护。；把审批所用确切新内容Artifact和backup GC pin纳入引用/保留合同；hashlib/平台原子文件原语不替代注册与分类一致性。

正向验收 artifact对象不可变且有hash、MIME、bytes、classification、TTL与artifact_refs；临时文件→原子rename→注册；预览、单产物、单任务大小限额可配置，下载不暴露宿主路径。 已批准新内容hash变化必须失效，GC不能删除待审批或正在备份的引用对象。

负向验收 不得作为任意宿主路径文件服务器；HTML/脚本不得默认内联执行。；MIME/检测库结果不能降低classification或让普通预览访问SECRET。

验证方法 注册前崩溃可回收孤立文件；登记后缺失文件明确标记；大输出不能无限耗尽磁盘。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/05_storage_api.md；docs/04_security_approvals.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-022 实现取消和停止传播

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-014、OB-016、OB-019、OB-020

需求映射 RQ03、RQ04

风险 CRITICAL / 取消假成功会误导用户并继续产生外部效果。

交付路径 services/core/src/openbot/application/cancellation.py

相关组件 sqlite3；aiosqlite

复用方式 自研控制语义

复用要求 取消先落盘、派发前再查；库取消不等于效果撤回，仍可能UNKNOWN。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 持久化取消请求与revision，撤销未开始Operation及未消费批准。；向运行worker传播取消并阻止所有后续dispatch。；按剩余DISPATCHING/UNKNOWN进入核对或确定终态，保留已发生效果。；取消写命令有稳定请求ID；caller超时/断连后先核对实际cancel_revision持久状态，不把等待取消当成撤销请求回滚。

正向验收 cancel_requested_at和cancel_revision先持久化并阻止新dispatch；撤销未消费批准；有DISPATCHING/UNKNOWN时保持RECONCILING，仅完成核对后可标CANCELLED，过去效果不伪称回滚。 取消与CLAIMED→DISPATCHING第二短事务串行判定；该事务提交前已取消必须不发包，提交后只能如实核对并尽力停止在途动作。 commit已发生的取消继续阻断派发；未确认落盘不能谎报取消成功，重复API请求只核对/返回原幂等结果。

负向验收 运行中外部提交不能因为收到取消就显示已回滚；取消后的旧批准不能启动动作。；claim之后尚未提交DISPATCHING的取消不能因“此前已claim”而被忽略。；不得因取消响应超时复活授权、重新发动作或宣称外部效果已经撤回。

验证方法 在规划、等审批、执行、结果提交同时取消；无新高风险动作启动；终态和残余效果明确。 在取消入队/commit前后断开客户端，重查取消版本并验证后续DISPATCHING复核一致。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、

event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-030 实现数据库备份恢复与保留策略

优先级 P1 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-011、OB-012、OB-014、OB-020

需求映射 RQ02、RQ06、RQ11

风险 CRITICAL / 备份/清理错误会毁坏唯一任务与证据副本。

交付路径 services/core/src/openbot/storage/maintenance.py

相关组件 sqlite3

复用方式 依赖适配

复用要求 使用SQLite backup接口；manifest/密钥排除/引用保留与恢复判定自研，不因库copy成功就宣称备份一致。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 使用SQLite backup或一致停写方案形成DB快照，取得并保持Artifact GC pin/retention保护，复制版本/配置和一致的引用manifest；不复制孤立db文件。；校验Artifact实际hash/大小、备份范围、保留secret_ref但排除真实秘密的规则；完成验证后释放GC保护，失败备份保留可核对状态。；恢复时先停止新dispatch，核验DB/Artifact、实例/授权/未决UNKNOWN及secret_ref可解析性；凭据失效进入显式重配置，不恢复秘密或重放未知动作。；注入活跃写、并发GC、磁盘满、缺产物、失效secret_ref和迁移中断，验证恢复可查询、无悬空引用和无未批准效果。

正向验收 使用SQLite在线backup或一致停写备份；包含artifact manifest与版本，普通备份无凭据；磁盘配额/清理保护未完成任务和审批引用；M1完成基础恢复，M3跨平台实测。 在线backup不自动覆盖Artifact/凭据/外部效果；备份期间GC不能删除快照引用。失效秘密引用使对应能力不可用，UNKNOWN/DISPATCHING恢复仍需核对。

负向验收 不能漏WAL、把密钥写普通备份或清理被待审批Operation引用的产物。；不得仅凭backup API成功标记完整备份；恢复旧DB不得复活授权、忽略缺秘密或重复执行未知副作用。

验证方法 活跃写期间备份可恢复；磁盘满不会先执行再失败写intent；迁移失败可还原可用副本。 并发GC与备份交错、恢复缺失Artifact/钥匙串项以及含UNKNOWN库，核对manifest和实际执行次数。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；GC pin生命周期、快照/manifest校验、secret_ref失效与UNKNOWN恢复反例。

设计依据 docs/05_storage_api.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-034 实现补丁提议与受授权应用

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-016、OB-019、OB-032、OB-033、OB-036、OB-092

需求映射 RQ04、RQ05

风险 CRITICAL / 编辑副作用可能造成用户数据丢失。

交付路径 services/core/src/openbot/tools/workspace/patch.py；
services/core/src/openbot/tools/workspace/commit_journal.py

相关组件 unidiff；patch-ng；git-worktree；dulwich

复用方式 依赖适配

复用要求 解析库不写宿主；审批前冻结old/new hash和确切新字节Artifact，禁止审批后fuzz/换行修正，多文件依变更日志恢复。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 用unidiff解析或difflib生成展示Diff；patch-ng仅在通过支持子集PoC后可于受控暂存区变换，禁止直接充当宿主写入器。；在审批前确定每个目标的旧hash、确切新字节Artifact/hash和变更manifest；解析后的路径、创建/删除/重命名支持范围均经FileGuard。；apply仅写入已绑定新字节并复验旧hash/资源/授权；审批后不再模糊匹配、纠正换行或重算新内容，保护用户已有修改。；实现本任务自有最小提交journal及部分失败恢复，按文件受控原子替换，不依赖OB-035才能安全提交；OB-035后续复用和扩展。git worktree准备隔离或明确禁hooks/filter，绝不自动reset/commit/push。

正向验收 workspace.propose_patch只生成不可变Diff及确切新内容Artifact，不改用户原目录；workspace.apply_patch绑定旧文件hash、新内容hash、目标和工作树，批准后复验并按文件受控原子替换。默认受管快照/工作树，不自动commit/push；多文件可能部分提交，必须使用本任务自己的最小提交日志和部分恢复策略，OB-035复用并扩展语言验证/撤回策略，不能宣称跨文件原子性。

负向验收 多匹配或old hash变化必须拒绝；禁止git reset --hard、自动commit/push和覆盖用户改动。；不得将patch-ng apply返回true当安全提交证据，或批准后更改CRLF/fuzz匹配；多文件提交不能冒充单个文件系统原子事务。

验证方法 用户在审批间修改同文件时拒绝旧patch；多处匹配不猜；写中断恢复原文件或完整新文件。 旧hash变化、新Artifact变化、重复匹配、恶意路径、行尾改变和第二文件提交失败均检查实际文件与恢复记录；hook/filter canary不执行。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；审批绑定的old/new hash、不可变新字节Artifact、逐文件提交/恢复manifest和具体解析库版本。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-037 实现统一数据外发策略

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-002、OB-008、OB-031、OB-036

需求映射 RQ04、RQ06

风险 CRITICAL / 无统一出口会让安全文件工具仍把敏感内容发送远端。

交付路径 services/core/src/openbot/policy/egress.py

相关组件 httpx；model-runner；model-ollama

复用方式 自研控制语义

复用要求 统一egress守卫仍覆盖SDK/网页/MCP及本地模型runner；审查HTTP客户端、DNS、代理、tokenizer缓存下载；localhost不能证明无云转发，脱敏不能替代出口限制。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 定义各数据类与目的地组合，并在所有出口前调用策略。；将模型上下文、通知预览、文件上传和MCP参数统一标记。；验证摘要/Artifact/流式输出仍保留限制，以及OFFLINE全出口拒绝。；将SDK/HTTP环境代理、模型runner云路由、tokenizer/grammar下载、Scanner联网验证和浏览器子进程纳入受管出口；明确探针覆盖及不可证明部分。

正向验收 模型、飞书通知、Browser、MCP、上传和消息工具共享数据出口策略；PUBLIC/WORKSPACE/SENSITIVE/SECRET按目标和动作评估；敏感预览不能默默上传，OFFLINE禁外网。 允许loopback不等于允许其转发云请求；本地模型需选定model/禁云/真实egress证据，未确认时拒绝本地保证。HTTPX等客户端关闭隐式环境读取或只注入获准代理。

负向验收 SENSITIVE不得因放进卡片或摘要而自动外发；只限制LLM不算OFFLINE。；任何Provider托管web search/remote MCP、扫描器网络验证、隐式price map/词表下载或未批准代理不得绕过出口。

验证方法 敏感文件经摘要/Artifact仍保持限制；OFFLINE阻断所有远端连接；允许域名不等于允许任意数据发送。 实际网络隔离/审计结合各transport fixture；仅mock httpx不作为所有requests/Rust/子进程零网络证据。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；受管进程/runner/浏览器出口范围、代理配置及绕过反例。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-039 实现敏感数据输出过滤

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-036、OB-037、OB-038、OB-092

需求映射 RQ06、RQ12

风险 CRITICAL / 日志和诊断是常被遗漏的秘密出口。

交付路径 services/core/src/openbot/observability/redaction.py

相关组件 detect-secrets；structlog

复用方式 依赖适配

复用要求 detect-secrets默认CI辅助，运行时只用离线已审查检测器；关闭网络验证/动态插件，外部allowlist不生效，不承诺128字节/100%。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不

能穿透到领域或事务层。

实施步骤 定义运行时redactor的已注册secret精确匹配、规则范围、最大长度/编码、跨任意chunk和flush策略，先过滤再持久化/外发。；detect-secrets默认仅开发/CI辅助；若复用运行时检测器，只用审核的离线插件，关闭网络验证和动态插件，不采外部文本/项目配置allowlist。；将stdout/stderr、SDK debug、exception、header、UI事件、Artifact、诊断和模型入口接同一过滤链；不确定敏感内容拒绝外发。；用不同切分点/编码/超长秘密/allowlist注释和检测器错误测试canary集合，记录范围与残余风险，不承诺100%识别。

正向验收 secret过滤在模型、日志与artifact持久化之前，流式跨chunk处理；只保留必要诊断；合成canary覆盖所有出口；明确正则无法识别全部隐私，访问策略仍是首道边界。 网络验证关闭且有真实请求计数/拒绝证据；外部pragma allowlist secret等注释不能让测试secret通过。固定128字节窗口不构成通用保证，扫描阴性不降低SECRET/SENSITIVE分类。

负向验收 截断前后或分chunk的测试密钥不得出现在模型、普通日志和Artifact。；不得发送真实secret到第三方验证端点；不得让页面、日志或仓库allowlist控制出口，也不得以正则扫描通过替代egress。

验证方法 把密钥切成两chunk或嵌入JSON异常仍不泄漏；测试stdout、stderr、HTTP header、UI事件和导出。 构造任意分片、Unicode/编码、超过窗口长度、allowlist注入和联网验证canary，所声明规则均通过且探针无额外网络。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；redactor规则/长度/flush合同、网络验证禁用配置、canary矩阵及明确未覆盖风险。

设计依据 docs/04_security_approvals.md；docs/05_storage_api.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-043 实现本地消息草稿

优先级 P1 规模 S 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-036、OB-037

需求映射 RQ04、RQ06

风险 HIGH / 收件人歧义会导致隐私发送给错误对象。

交付路径 services/core/src/openbot/tools/messages/draft.py

复用方式 自研控制语义

复用要求 本地不可变消息草稿、明确收件人与附件hash自有，不复用上游自动发送或首次sender当owner逻辑。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 要求稳定收件人ID和目标账户，无法解析时WAITING_INPUT。；生成正文/附件不可变草稿artifact及digest。；提供本地预览和修订版本，不进行网络发送。

正向验收 message.draft仅生成本地不可变草稿artifact；稳定recipient ID、channel、正文与附件固定；名称歧义需WAITING_INPUT；未明确收件人不能生成可发送提案。

负向验收 仅有同名联系人或旧草稿hash不得进入可发送READY状态。

验证方法 草稿编辑产生新版本；旧approval不能批准新内容；没有网络调用。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/14_revision_v1_2.md

OB-025 实现首个云模型适配器

优先级 P0 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-008、OB-009、OB-023、OB-024、OB-037、OB-038、OB-039、OB-092

需求映射 RQ06、RQ07

风险 HIGH / Provider格式差异可触发错误工具或泄漏上下文。

交付路径 services/core/src/openbot/providers/openai_compatible.py

相关组件 model-openai；httpx；tiktoken；tenacity；litellm；model-runner

复用方式 依赖适配

复用要求 优先官方openai异步SDK+薄转换；显式关闭或统一管理SDK内建重试，禁止叠加tenacity；fake HTTP计数、流中断/取消/半包/usage缺失契约齐全。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 锁定首个云Provider与允许的SDK基础请求API/字段；首选官方openai薄适配，明确能力、错误和timeout映射。；显式设置SDK max_retries=0并控制HTTP transport重试/环境代理，由OpenBot唯一管理有界重试；每次真实请求先reserve并通过egress。；累积流到完整JSON/schema后仅返回ToolCall提案；禁自动runner、Provider托管执行工具、remote MCP与任意extra_body/extra_headers透传。；fake server验证429/503/中断/退避取消/首块后取消和usage不明，计数与预算一致后做受控真实smoke。

正向验收 首个真实云Provider通过统一模型网关，文本/工具/流式/usage/取消/超时有映射；完整JSON和schema通过前不派发；每次请求先经过出口策略与预算；compatible差异写能力表。 允许的SDK API白名单可检查；取消后新请求为0，半包丢弃不等于服务端未计费。固定版本支持的重试关闭项实测有效，不叠加tenacity。

负向验收 畸形/半包tool call不执行；Provider重试不能重放已执行工具。；官方SDK也不得自动执行函数、启用未纳管web search/remote MCP，或让外部内容覆盖endpoint/认证头；默认重试不能藏在Gateway账本外。

验证方法 fake server覆盖分片参数、畸形JSON、429、tool ID缺失、流中断；真实provider仅额外smoke。 可控服务器计数与SDK配置、Gateway attempt、预算三者一致；canary函数批准前调用为0；mock覆盖范围与真实smoke分别列出。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。；SDK允许API/字段清单、显式重试/timeout/代理配置、实际HTTP尝试和usage记录。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-040 实现结构化进程执行协议

优先级 P0 规模 M 职责 Platform 状态 TODO

前置依赖 OB-007、OB-009、OB-019、OB-031、OB-038、OB-039

需求映射 RQ03、RQ05

风险 CRITICAL / 结构化argv不能阻止任意程序读写或触网。

交付路径 services/core/src/openbot/tools/executors/process.py；contracts/schemas/dispatch.schema.json

相关组件 ripgrep；git-worktree

复用方式 自研控制语义

复用要求 容器/进程SDK不能增添未批准argv/env/mount/network；协议仍锁定输入、执行器、镜像与backend。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 定义不可变process执行计划和干净环境，不开放裸shell字符串。；实现fake/受控worker通信、流式输出、timeout与取消结果映射。；等待隔离后端通过后才启用真实代码执行，并记录快照和镜像digest。；把rg --pre、Git worktree post-checkout、filters和其他配置驱动进程列为隐藏执行入口；适配器固定命令/参数/环境并经相同隔离策略。

正向验收 process.run合同锁定可执行文件/argv、输入快照、backend、镜像digest、干净HOME/TMPDIR、env和资源限制；任意解释器、测试、构建和Git钩子均视为代码执行。 容器客户端与容器各有受管标识，停止前者不自动认定后者结束；实际镜像与网络/挂载能力纳入可查询结果。

负向验收 pytest、python、npm或Git不能以“只读白名单”绕过隔离；失败不能自动加网或提权。；不得因动作名叫search/snapshot/lint就允许任意宿主程序或透传CLI参数。

验证方法 先用fake worker验证控制协议和输出洪泛；真实执行仅在OB-041隔离后端通过后开放；分别断言exit code、signal、timeout、取消与UNKNOWN。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-044 实现消息发送用例与受控适配端口

优先级 P1 规模 M 职责 Security 状态 TODO

前置依赖 OB-017、OB-018、OB-019、OB-020、OB-037、OB-043

需求映射 RQ03、RQ04、RQ06

风险 CRITICAL / 外部发送通常不可撤回且可能泄露数据。

交付路径 services/core/src/openbot/tools/messages/send.py

相关组件 lark-oapi

复用方式 自研控制语义

复用要求 发送用例仍由Broker批准并判UNKNOWN；SDK只实现transport，M1 fake/M2真实启用次序不变。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现发送用例与受控transport端口，绑定草稿和稳定目的地。；接入审批、dispatch、receipt与RECONCILE_ONLY默认语义。；先fake验证成功后断连，真实adapter通过M2验证再启用。

正向验收 message.send绑定草稿hash、destination account和稳定recipient；走独立外发审批；fake transport先证明receipt/UNKNOWN语义，真实平台发送到M2经对应适配器验证后才启用。

负向验收 未知发送结果不能自动重发；普通owner进度授权不能复用为第三方发送授权。

验证方法 fake服务覆盖错收件人、旧草稿、成功后断连和重复请求；无已验证发送适配器时CAPABILITY_UNAVAILABLE；owner进度通知不复用第三方发送授权。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/06_tools_providers.md；docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/07_feishu.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md

OB-081 在M1实现认证本地HTTP与SSE控制API

优先级 P0 规模 M 职责 Desktop 状态 TODO

前置依赖 OB-006、OB-008、OB-014、OB-018、OB-020、OB-022、OB-031、OB-038、OB-039、OB-092

需求映射 RQ04、RQ06、RQ10

风险 CRITICAL / 该API是所有客户端入口，若后置会诱发各通道绕过内核。

交付路径 services/core/src/openbot/adapters/local_api；contracts/openapi.yaml；tests/contracts/local_api；tests/security/local_api

相关组件 fastapi-stack；pydantic-jsonschema

复用方式 依赖适配

复用要求 FastAPI/Uvicorn/sse-starlette按M1需求择准入；认证、scope、Host/Origin、API用途、SSE一致性/背压/取消仍自有，proxy头不能绕过loopback。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 M1先实现loopback HTTP、认证scope、Host/Origin/profile/体积限制及受保护token交接。；按application端口提供health/tasks/approvals/cancel/resume/reconcile与SSE，gateway使用独立内部scope。；验证幂等冲突、version CAS、跨源拒绝、事件断点与保留期410；CLI和gateway据此接入。 reconcile只接收证据而非受信结果状态；禁止客户端指定grant恢复许可。；FastAPI/Uvicorn和按需SSE库只提供传输原语；禁宽泛CORS/隐式proxy信任，限定body/速率/事件队列；测试断开连接时writer实际提交和SSE取消/背压。

正向验收 M1提供loopback HTTP、Host/Origin校验、profile绑定、限额和受保护token交接；最小health/tasks/events/approvals/cancel/resume/reconcile供CLI和gateway使用；内部gateway接口scope独立。 审批查询使用独立ApprovalPreview，SECRET不在任何预览暴露；本地challenge端点仅限有效PENDING和owner范围，gateway不能获取；OperationSnapshot提供Operation.version；KEEP_UNKNOWN可无新增证据，确认结果需可追踪证据；证据导入只接收受限文件内容，不接受宿主路径。 Host/Origin/profile/scope由OpenBot判定；未知/远程refs与重复JSON键拒绝。after_seq与Last-Event-ID冲突拒绝，保留期外410后客户端取快照。

负向验收 不得匿名暴露任务/审批或允许WebView持广域token；不允许UI/CLI/gateway直开SQLite。；reconcile API不得接受用户指定SUCCEEDED/CANCELLED覆盖Operation账本；仅保存证据并交恢复器/OutcomeVerifier判断，客户端不能授权CONSUMED复用。；不得让框架Dependency/客户端断连替代持久事务和授权结果；proxy头不能把非loopback请求伪装本地owner。

验证方法 跨源网页、非loopback网络、错误profile、失效token、越权scope、旧version、同幂等键不同payload均拒绝；CLI与gateway不得直连DB；SSE断点与410恢复可重复。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；实际监听/Host/Origin/proxy与scope反例、writer断连重查、SSE游标/背压测试。

设计依据 docs/02_architecture.md；docs/05_storage_api.md；docs/04_security_approvals.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-028 提供CLI任务和审批操作

优先级 P0 规模 M 职责 Platform 状态 TODO

前置依赖 OB-008、OB-014、OB-018、OB-020、OB-022、OB-081、OB-092

需求映射 RQ10

风险 HIGH / 本地管理入口也可能成为授权绕过路径。

交付路径 apps/cli；tests/integration/cli

相关组件 cli-toolchain；httpx

复用方式 依赖适配

复用要求 Typer/Rich/httpx可复用；命令语义和审批预览不变，只有认证API访问，无SQLite旁路，JSON输出可稳定测试。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 实现CLI配置与受保护本地API会话连接。；提供task/approval/cancel/resume/reconcile与稳定JSON输出。；覆盖无daemon、认证失败、版本冲突和等待核对的用户路径。；用Typer/Rich/httpx薄适配；稳定JSON输出与人类视图分离，转义外部ANSI/富文本控制，受控代理/超时/取消不导致新动作或重复批准。

正向验收 CLI通过认证本地HTTP API创建/查看/取消/恢复任务、查看审批及提交决定、核对UNKNOWN；JSON与人类输出稳定；不直连SQLite或绕过application。 依赖仅负责命令解析、呈现和HTTP；外部日志/路径不能注入终端控制或被当作命令。

负向验收 CLI不能打开SQLite绕过policy；没有证据不能提供ignore-and-rerun未知动作选项。；reconcile命令只提交核对证据，不提供force-success或复活CONSUMED的客户端开关。；不得把富文本/ANSI输入直接渲染为可执行或伪造审批提示；CLI不得凭等待超时宣称动作未执行。

验证方法 无飞书和UI也能运行整条fake任务；错误返回码稳定；approve仅由本地受信用户接口可调用。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/05_storage_api.md；docs/02_architecture.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-041 实现worker隔离与资源上限

优先级 P0 规模 M 职责 Platform 状态 TODO

前置依赖 OB-002、OB-016、OB-036、OB-040、OB-093

需求映射 RQ04、RQ05、RQ06

风险 CRITICAL / 隔离配置错误会把远程执行扩大为宿主权限。

交付路径 services/core/src/openbot/tools/executors/sandbox.py；native/supervisor/src/worker_control.rs

相关组件 python-on-whales；podman-nerdctl；bubblewrap

复用方式 原生原语适配

复用要求 容器backend逐组合认证；容器归属独立于CLI，stop/wait→受限导出校验→remove，无自动host/引擎兜底。；实际OS、架构、backend和配置组合须独立提供证据；统一API、正常退出或进程组不能自动证明所有强杀与逃逸场景均可回收。

实施步骤 通过OB-093先认证一个Docker后端，python-on-whales或受控CLI择一；固定引擎/镜像digest/挂载/网络/资源与非root/drop-capabilities配置。；Broker登记容器ID/标签与profile/Operation/Attempt/epoch归属，输入只读、独立输出；host端控制接口不进入不可信容器。；完成或取消时先stop仍运行容器并wait确认，再经限额/类型/路径/链接/权限检查导出Artifact，最后remove；不让auto-remove先删证据。；分别验证客户端死亡、容器存活、恶意导出和恢复清理；Podman/nerdctl/bubblewrap不自动兜底，缺已验证backend返回CAPABILITY_UNAVAILABLE。

正向验收 默认受控容器以非root、drop capabilities、无privileged/宿主socket、只读输入快照、独立输出区、资源上限和默认禁网执行；无后端就返回CAPABILITY_UNAVAILABLE，不回退宿主机。 容器生命周期独立于CLI；导出在已停止/wait后进行，校验成功或按已记录失败处理后remove。POSIX权限和Windows ACL按平台验证，不能统一chmod替代。

负向验收 禁止privileged、Docker socket、宿主全HOME和无后端自动host回退。；不得仅kill docker CLI就标worker回收完成；不得导入符号链接/路径穿越/特殊文件或删除未登记用户容器。

验证方法 容器无secret/宿主socket；越界文件和非授权网络失败；无已验证隔离环境时相关动作返回CAPABILITY_UNAVAILABLE，不进入宿主执行模式。 kill客户端后检查容器仍否存活，随后按登记ID停止、wait、导出验证、remove；恶意tar/link/权限与缺backend反例可重复。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；backend能力记录、实际容器ID/标签及完整stop→wait→export校验→remove时序、恶意导出拒绝证据。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-035 实现显式语言验证与修改事务

优先级 P1 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-034、OB-041、OB-092

需求映射 RQ05、RQ12

风险 HIGH / 自动回滚或验证脚本可能破坏用户状态或执行任意代码。

交付路径 services/core/src/openbot/tools/workspace/validation.py

相关组件 tree-sitter；tree-sitter-language-pack；git-worktree

复用方式 依赖适配

复用要求 只用固定grammar/原生资产，安装期预置、禁网首次parse；独立有界worker承受native解析风险。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 只选择明确支持语言的tree-sitter/grammar并锁定原生资产版本/hash；检查language-pack所选版本的按需下载，安装期预置、运行期禁止下载和任意workspace grammar。；在受资源/时间/输入/输出限制的独立parser worker解析；native崩溃或深嵌套只影响worker，不破坏daemon/审批账本。；ruff/mypy/pytest/tsc及项目配置插件、Git hooks/filter均视为代码执行，走已准入隔离process.run；无backend不能宿主兜底。；多文件变更用已批准新字节manifest与恢复记录，仅撤回本Operation变更；语法树无ERROR/lint通过不等于功能正确。

正向验收 仅对已支持语言做显式语法/静态验证；验证脚本也走隔离执行；多文件变更有manifest与本次变更撤回策略，不把lint成功等同于功能正确。 干净安装首次真实parse在禁网环境成功；未安装语言明确不可用，native parser资产可对应release清单。

负向验收 lint通过不能标功能正确；验证失败不能无条件恢复整个仓库。；不得因为不执行目标语言就把任意native grammar放入可信daemon；不得在首次parse偷偷下载parser或加载工作区提供的二进制。

验证方法 两个文件中后一个验证失败时不会丢掉用户修改；验证命令自身走进程权限策略。 超大/深嵌套/畸形输入、native崩溃/超时、缺grammar及多文件第二项失败有实际隔离和恢复证据。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；实际加载grammar文件hash、禁网首次parse、worker故障和多文件恢复记录。

设计依据 docs/06_tools_providers.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-042 实现worker进程树取消与回收

优先级 P0 规模 M 职责 Platform 状态 TODO

前置依赖 OB-003、OB-022、OB-040、OB-041、OB-093

需求映射 RQ01、RQ05、RQ11

风险 CRITICAL / 孤儿worker可能继续未授权动作或占用资源。

交付路径 native/supervisor/src/process_tree.rs；services/core/src/openbot/tools/executors/supervision_port.py；tests/integration/platform

相关组件 windows-sys；processkit-process-wrap；ur-taking-me-with-you；command-group；python-on-whales

复用方式 原生原语适配

复用要求 仅封装原生原语；command-group不新用。核验Job/进程组/容器最终状态，强杀与协作清理边界明确。；实际OS、架构、backend和配置组合须独立提供证据；统一API、正常退出或进程组不能自动证明所有强杀与逃逸场景均可回收。

实施步骤 实现受管worker/容器归属和epoch/PID身份；选择一个获准process-wrap/processkit类封装或最小原生实现，command-group不新引入。；Windows用挂起创建→Job分配成功→恢复，禁止breakaway逃逸；Linux/macOS按实测cgroup/进程组/监督能力描述限制。；graceful后强制清理并核验子孙最终状态；容器按登记ID独立stop/wait、导出校验与remove，不能仅清理CLI。；测试daemon/supervisor/worker强杀、子孙、容器残留、PID复用和UI退出；无法确认旧执行域失效时保持quarantine并拒绝新dispatch。

正向验收 用户级supervisor按实际OS能力监督worker；Windows Job、Linux可用cgroup/进程组、macOS相应受控进程组/监督逻辑均有边界说明；graceful后强制清理，UI退出不停止daemon。 每个清理对象有最终状态或无法确认的证据；pipe EOF/Drop只作为有限协作机制，不宣称100%清理。

负向验收 单纯Python finally/pipe EOF不能作为强制死亡后的唯一清理保证。；不得以统一crate API、父PID退出或lease到期替代真实OS隔离证据；不能误杀未登记进程/容器。

验证方法 派生子孙进程、daemon崩溃、worker挂死均有原生OS验证；UI关闭不杀daemon。 原生平台记录创建顺序、Job分配失败、进程组逃逸/强杀和独立容器残留，确认失败时不开新执行。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；OS/arch/原语版本，PID身份/Job/容器归属与前后进程树清单及清理失败决定。

设计依据 docs/02_architecture.md；docs/03_runtime_recovery.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-029 交付首条持久化垂直切片

优先级 P0 规模 M 职责 QA 状态 TODO

前置依赖 OB-010、OB-020、OB-021、OB-022、OB-023、OB-025、OB-028、OB-036、OB-041、OB-042

需求映射 RQ02、RQ03、RQ04、RQ10、RQ12

风险 HIGH / 没有首个闭环证据会使后续适配器建立在未验证核心上。

交付路径 tests/integration/scenarios/first_vertical_slice；docs/demos/m1.md

相关组件 sqlite3；rfc8785

复用方式 独立资格验证

复用要求 完整M1 API/权限/Artifact/真实受限执行集成不变；OB-091承担早期MockWorker协议PoC，演示仍可FakeProvider/OFFLINE。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 保留完整M1 CLI/认证API/application/权限/产物链路；演示使用FakeProvider和受控测试数据，默认OFFLINE且无需真实租户/模型密钥。；在首发已验证backend执行真实受限文件/进程效果，另用fault executor制造外部成功但本地回执丢失；两类证据分开。；演示审批、一次有效dispatch、结果/outbox、取消与资源隔离；在规定提交点崩溃重启并重查稳定请求ID。；复用OB-091早期反例并提供真实本地端口/Artifact/隔离路径结果；不能用M0 PoC或全MockWorker代替完整M1门禁。

正向验收 CLI→认证API→持久Task→fake模型提案→policy/审批→fake可验证效果→结果/outbox构成可重启切片；默认OFFLINE，无真实租户或模型密钥也能演示。 OB-091只负责早期协议PoC；本任务必须同时给出实际本地API、Artifact、受控文件与隔离worker的集成证据。真实模型/飞书能力仍由对应适配任务另验。

负向验收 演示不得调用真实生产服务；fake通过不能声称真实飞书/模型/平台已验证。

验证方法 相同场景覆盖5个崩溃点与重复输入；人工演示给出命令、预期状态和验收证据。 记录真实本地效果和fault executor计数各自的证据，不混成生产服务成功；原有全部前置依赖保留。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。；真实本地受限效果、Artifact hash、worker/container归属与stop/wait/导出/回收证据。

设计依据 docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/05_storage_api.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-045 交付安全工具威胁回归

优先级 P0 规模 M 职责 QA 状态 TODO

前置依赖 OB-029、OB-031、OB-032、OB-034、OB-037、OB-039、OB-041、OB-042

需求映射 RQ03、RQ04、RQ05、RQ06、RQ12

风险 CRITICAL / 未验证的强制边界不能进入远程运行。

交付路径 tests/security；docs/demos/m2.md

相关组件 rfc8785；ripgrep；git-worktree；detect-secrets

复用方式 独立资格验证

复用要求 在M1加入导入联网、嵌套修改、隐式重试、非法refs、rg/git配置、parser下载与后端清理失败的可验证用例。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 把M1每个安全/恢复不变量变成固定攻击与故障语料。；断言实际文件、进程、网络、secret与副作用次数，而非模型文字。；接入PR必跑门禁并保存失败复现方法。；把组件引入的新边界反例加入相应M1必跑集合：深层变异/JCS、writer取消、隐藏SDK执行/重试、rg/Git配置、parser下载、scanner验证与backend残留。

正向验收 M1即运行路径、注入、授权竞态、secret、输出洪泛、隔离与恢复回归；用真实文件/进程/网络效果断言；不把安全测试延后至M3发布。 以实际网络/进程/文件/请求计数证明门禁，不要求所有后期真实组件提前安装；后期SDK随接入复用同合同。

负向验收 安全用例失败不得通过放宽policy、删除断言或mock掉实际效果来解决。；不得把未安装的M2/M3组件伪报测试通过，或通过删除边界检查让复用库更易接入。

验证方法 所有必阻断case均无未授权副作用；不能以模型是否拒绝的文本作为通过证据。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/04_security_approvals.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-046 发布最小本地Alpha边界说明

优先级 P0 规模 S 职责 Lead 状态 TODO

前置依赖 OB-029、OB-033、OB-034、OB-040、OB-041、OB-045

需求映射 RQ01、RQ05、RQ10、RQ12

风险 HIGH / 阶段命名不准确会掩盖尚未验证的危险能力。

交付路径 docs/releases/local-prototype-acceptance.md；tests/integration/scenarios/local_prototype

复用方式 独立资格验证

复用要求 本地Alpha报告列出启用的精确组件/资源、未支持backend与残余风险；不把候选列表当已实现能力。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 按M1范围准备本地原型演示和能力清单。；从空配置用CLI和mock完成读/提案/审批/隔离测试与重启。；记录未支持能力及下一阶段依赖，作为M2入口门禁。；Alpha验收列精确启用组件/资产/OS/backend、准入证据和未支持项；解释OB-091早期PoC与OB-029完整M1证据差异。

正向验收 CLI可经认证API完成读文件、补丁提议、批准应用和隔离测试；mock/OFFLINE演示可运行；声明试点OS和未支持能力；完整MVP还需M2/M3。 任何NOT_RUN候选不列为已支持；复用收益只报告测量/范围，不写固定LOC/耗时/安全保证。

负向验收 未验证平台、真实飞书或完整MVP不得在原型说明中写成已完成。

验证方法 从空配置按文档跑通一次任务；生成版本化能力报告和已知限制清单。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/00_scope.md；docs/06_tools_providers.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

M2 飞书远程闭环

本阶段 11 项任务。按 depends_on 拓扑推进；编号顺序不替代依赖关系。

OB-047 核验飞书真实租户协议与权限

优先级 P0 规模 M 职责 Integration 状态 TODO

前置依赖 OB-004、OB-006、OB-008、OB-092

需求映射 RQ08、RQ12

风险 HIGH / 协议误读会导致授权回调失效和静默断连。

交付路径 docs/integrations/feishu-contract.md；tests/fixtures/feishu

相关组件 lark-oapi

复用方式 独立资格验证

复用要求 真实租户协议+锁定lark SDK的可重放样例；核验实际callback/传输/权限/时限，测冷启动与阻塞行为，不照抄24.27秒或固定超时。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 在专用测试自建应用确认所需权限与消息/callback字段。；捕获脱敏样例、SDK版本、ACK方式和错误返回。；用样例建立adapter contract，记录卡片与token真实限制。；在独立进程对锁定lark SDK做导入/凭据/发现/握手/ready分段测量，核对当前版阻塞/timeout与回调形状；修复需基于所选版本证据。

正向验收 真实自建应用核验消息事件、卡片callback、app/tenant/operator身份和最小权限；保存脱敏payload与SDK版本；该任务研究协议，授权权威仍在daemon。 不用固定24.27秒、固定模块数或历史Issue推导本机超时；普通卡/回调权限与实际更新时限有官方和真实租户依据。

负向验收 不得把HTTP响应样例直接当WebSocket回调合同，或把未经核实Issue当当前行为。；不得盲patch私有方法或强制线程预热作为万能修复；不得把WebSocket ACK与HTTP callback响应混同。

验证方法 样例脱敏可回放；不混淆HTTP响应和WebSocket SDK回调返回；不把未知Issue直接当需求事实。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。；所选SDK版本、脱敏真实payload、分段时序和当前缺陷/上游修复证据。

设计依据 docs/00_scope.md；docs/02_architecture.md；docs/05_storage_api.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-094 审查飞书模板的最小源码复用

优先级 P1 规模 S 职责 Integration 状态 TODO

前置依赖 OB-004、OB-047、OB-089、OB-092

需求映射 RQ08、RQ11、RQ12

风险 MEDIUM / 模板夹带Agent/owner/消息队列执行逻辑，许可证或归属记录不完整。

交付路径 docs/evidence/source-reuse-feishu.md；components/source-reuse/feishu.json

相关组件 nanobot；langbot

复用方式 源码参考审查

复用要求 默认REFERENCE_ONLY；比较后可给出NO_COPY及理由。只有选择有限摘取时才要求固定commit/path/hash、LICENSE/NOTICE、差异和回归，禁止整仓导入。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 对候选nanobot/LangBot的具体目标文件作收益/维护/边界比较；若考虑摘取，核实精确commit、文件许可证、依赖和副作用。；形成明确NO_COPY或有限摘取决定。NO_COPY只需比较依据与理由，不创建vendor目录或安装上游框架；普通卡实现仍由OB-051负责。；只有选择摘取时才保留commit/path/hash、LICENSE/NOTICE、本地diff、维护人与回归；只复制纯构造/展示，不复制owner/消息执行循环。

正向验收 NO_COPY有明确比较与理由即可通过源码审查任务，不强制vendoring。若实际摘取，每片段可追溯来源/许可/变更并用离线fixture证明无发送、配对授权或Agent执行；两分支都不引入整个上游runtime。

负向验收 不得为了完成任务强行复制源码/安装nanobot或LangBot；不得移植first-owner、channel bus、Agent loop或隐藏发送。；未获项目准入的copyleft源码不可擅自混入；不把GPL/AGPL一般描述为违法。

验证方法 评审比较表与NO_COPY理由；只有摘取分支运行模板输出/副作用fixture并核对NOTICE与源码diff，NO_COPY分支将摘取专属验证标NOT_APPLICABLE。

完成证据 明确的NO_COPY或有限摘取决定，所比较的候选/方案、收益与维护理由。；实际摘取时附精确commit/path/hash/许可证/NOTICE/diff及离线fixture；NO_COPY无需虚构这些已采用资产。

设计依据 docs/07_feishu.md；docs/09_testing_operations.md；docs/11_decisions_evidence.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

OB-048 实现安全配对与owner撤销

优先级 P0 规模 M 职责 Security 状态 TODO

前置依赖 OB-002、OB-008、OB-013、OB-018、OB-047、OB-081

需求映射 RQ04、RQ08、RQ10

风险 CRITICAL / 配对是远程执行权限的入口。

交付路径 services/core/src/openbot/policy/pairing.py；services/feishu_gateway/src/openbot_feishu/pairing.py；apps/cli

相关组件 nanobot

复用方式 自研控制语义

复用要求 只参考配对展示；本地challenge、待确认tenant/app/user与owner授权自有，不复制上游first-user/二维码自动授权。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 本地API/CLI生成短TTL限次挑战并绑定profile/app/tenant。；gateway转发远端claim，daemon仅保存待确认身份。；本地确认后授权owner，实现撤销和epoch更新。

正向验收 本地认证用户发起短时一次性随机挑战；飞书回传只形成待确认身份；本地展示tenant/app/user后确认owner；nonce限次、防重放、撤销提升identity_epoch。

负向验收 第一个远端消息人不得自动成为owner；旧二维码、跨租户claim和撤销身份须拒绝。

验证方法 偷看旧码、跨租户、重复claim、被撤销owner无法创建或批准任务；首次配对有本地确认。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/04_security_approvals.md；docs/07_feishu.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md

OB-049 实现飞书WebSocket入站适配

优先级 P0 规模 M 职责 Integration 状态 TODO

前置依赖 OB-013、OB-047、OB-048、OB-081

需求映射 RQ02、RQ08、RQ10

风险 CRITICAL / 接入越权会直接暴露本地执行能力。

交付路径 services/feishu_gateway/src/openbot_feishu/inbound.py

相关组件 lark-oapi；httpx

复用方式 依赖适配

复用要求 用lark-oapi协议能力；独立gateway、单消费者、受限HTTP/inbox ACK边界不变，SDK升级受契约fixture保护。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 实现单gateway SDK连接和消息规范化。；通过内部scope调用daemon inbox用例，持久化成功后ACK。；默认拒绝群聊执行、陌生身份与超限附件，并记录去重结果。；以lark-oapi承担握手/帧解析/事件类型，转换到自有Port；实际子进程环境和scope最小化，阻塞回调不进入daemon主循环。

正向验收 单活动gateway转换协议并通过范围受限内部HTTP接口交daemon；owner权限由daemon校验；入站持久提交后才ACK；默认禁用群聊执行，不在SDK回调中调模型。 SDK内部消息队列不拥有Task/owner/去重权威，协议升级需要重放脱敏fixture。

负向验收 gateway不能自己决定owner或直开SQLite；回调线程不能等待LLM。；不得重写不必要WebSocket协议或借SDK默认行为绕过inbox提交后的ACK规则。

验证方法 重复与乱序事件不重复创建任务；陌生sender、其他租户、附件超限被拒绝；ACK延迟单独记录。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/02_architecture.md；docs/05_storage_api.md；docs/04_security_approvals.md；docs/07_feishu.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-050 实现飞书审批callback处理

优先级 P0 规模 M 职责 Integration 状态 TODO

前置依赖 OB-018、OB-019、OB-047、OB-048、OB-049

需求映射 RQ04、RQ08

风险 CRITICAL / 审批callback是跨网络授权的关键边界。

交付路径 services/feishu_gateway/src/openbot_feishu/approval_callback.py；services/core/src/openbot/application/approval_use_case.py

相关组件 lark-oapi

复用方式 依赖适配

复用要求 card callback适配到daemon CAS；所有拒绝/超时/异常返回合法且及时，禁止等待模型/工具或库内队列旁路批准。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 映射真实callback operator、app/tenant、卡片上下文和opaque approval ID。；调用daemon审批用例并返回真实CAS结果的简短响应。；验证重放、并发点击、数据库延迟和旧卡，持久唤醒不靠内存。；为选定SDK的合法成功/拒绝/过期/数据库忙回调建立fixture，在剩余deadline内同步返回，不把未确认commit映射为批准成功。

正向验收 gateway转发真实operator和卡片上下文；daemon核验身份/nonce/binding并CAS、持久唤醒；同步回调仅回简短状态，不以内存queue或文本is_owner授权。 回调实际operator经daemon校验；未来SDK返回结构变化须先通过合同测试。

负向验收 提交失败不得回复已批准；action.value中伪造身份与已取消Task旧卡必须拒绝。；不得等待模型/worker或仅凭卡片payload中的owner字段放行。

验证方法 并发点击与超时再点安全；已取消任务旧卡无效；数据库阻塞时不谎报批准成功。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/04_security_approvals.md；docs/05_storage_api.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-051 实现普通卡片与结果回执

优先级 P0 规模 M 职责 Integration 状态 TODO

前置依赖 OB-021、OB-037、OB-047、OB-049、OB-094

需求映射 RQ06、RQ08

风险 HIGH / 卡片信息不足或泄漏会造成盲批和隐私外发。

交付路径 services/feishu_gateway/src/openbot_feishu/cards.py

相关组件 lark-oapi；nanobot；langbot

复用方式 依赖适配

复用要求 普通卡片先完成；只有OB-094审过的固定commit模板可移植，模板不得自带网络/Agent/owner逻辑。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 实现无CardKit依赖的普通任务/审批/结果卡。；预览走数据策略，不能安全展示影响范围时要求本地审阅。；按receipt/UNKNOWN/PARTIAL等真实状态更新展示。；先用自有最小普通卡完成闭环；只有OB-094选择有限摘取时才使用固定commit模板，NO_COPY同样允许，不引入上游channel bus或Agent循环。

正向验收 先普通卡片完成任务状态、脱敏提案、批准/拒绝和结果；无CardKit也可用；敏感影响范围无法安全展示时REQUIRE_LOCAL，不让用户盲批截断内容；UNKNOWN明确待核对。 卡片构造层离线无发送副作用，模板可替换；源码摘取有LICENSE/NOTICE/本地diff，否则记录NO_COPY及比较理由。

负向验收 不得外发敏感完整diff/截图或让用户批准被截断到看不出影响的动作。；模板不得携带owner授予、自动发送或隐藏SDK调用；不因上游许可宽松就整仓导入。

验证方法 无CardKit权限也可完成任务和审批；敏感diff默认不出本机；未知结果有明确提示。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/05_storage_api.md；docs/07_feishu.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-054 实现网关健康探测与重连

优先级 P0 规模 M 职责 Integration 状态 TODO

前置依赖 OB-009、OB-021、OB-049

需求映射 RQ01、RQ08、RQ12

风险 HIGH / 静默断连会使远程助手不可用并隐藏任务状态。

交付路径 services/feishu_gateway/src/openbot_feishu/health.py

相关组件 lark-oapi；httpx；tenacity

复用方式 依赖适配

复用要求 先检查选定SDK是否仍有问题；通过支持的timeout/session扩展或受控最小补丁处理；初始化与ready时限分开，独立进程watchdog能收回阻塞实例。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 分别限制SDK初始化/发现/连接/读取/业务ready，按所选版本优先采用上游修复；必要窄补丁记录commit/diff和退出条件。；在可能阻塞的gateway进程之外运行hard-deadline监督，内部heartbeat只提供观测；空闲无业务消息不视作故障。；按jitter有界退避重建，先确认旧实例退出再建立新消费者；SDK/HTTP层不得叠加不可见重试。；注入DNS停滞/TCP半开/SDK阻塞/休眠，确认审批/取消不受阻、每次重建有记录且只有一个活动gateway。

正向验收 gateway独立健康、连接/读取deadline、heartbeat与带jitter退避可见；空闲无消息不算失联；daemon监督重启网关不产生第二消费者；阻塞SDK不拖慢审批/取消。 不同计时路径单独测量；同一个被阻塞的事件循环中的watchdog不能充当硬截止保证。

负向验收 空闲无消息不能自动判死；重连不得占住daemon writer或审批线程。；不得单靠asyncio.wait_for或线程预热声称能中断阻塞SDK；不能为更快恢复同时连接两个消费者。

验证方法 DNS停滞/TCP半开/断网/休眠恢复后可重连；不要求空闲消息出现；重连可观测。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；外部监督时序、旧进程退出证据、SDK配置/补丁差异和实际重试次数。

设计依据 docs/02_architecture.md；docs/03_runtime_recovery.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-052 实现进度卡节流与更新顺序

优先级 P1 规模 M 职责 Integration 状态 TODO

前置依赖 OB-021、OB-051

需求映射 RQ02、RQ08

风险 MEDIUM / 错误卡片状态会误导用户重复操作。

交付路径 services/feishu_gateway/src/openbot_feishu/progress.py

相关组件 lark-oapi

复用方式 自研控制语义

复用要求 card_revision、限流、合并和终态保护继续自有；不能原封不动复制上游内存流式循环。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 为任务卡定义revision和可合并进度类型。；节流中间更新并处理retry_after，终态优先。；模拟乱序、重复、断网恢复，确保最新终态保留。；复用纯卡片构造器，revision/节流/重试调度仍由outbox掌握；SDK/tenacity不能形成第二个更新循环。

正向验收 任务进度版本递增；可合并中间更新；最终状态不被迟到进度覆盖；处理API限流retry_after。 每次实际API更新、retry_after和合并原因可观察，取消不会留下无主后台更新任务。

负向验收 迟到进度不得把SUCCEEDED/FAILED等终态覆盖回RUNNING。

验证方法 快速生成100次进度更新后卡片保持最新终态；断网恢复不发送100条过时卡。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/05_storage_api.md；docs/07_feishu.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-055 实现死信检视与安全重投

优先级 P1 规模 M 职责 Integration 状态 TODO

前置依赖 OB-013、OB-020、OB-021、OB-049、OB-054

需求映射 RQ03、RQ08、RQ10

风险 HIGH / 人工恢复入口可能绕过正常幂等保护。

交付路径 services/feishu_gateway/src/openbot_feishu/dead_letter.py

复用方式 自研控制语义

复用要求 死信/通知重投通过application，不让SDK/tenacity重播UNKNOWN业务副作用。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 存dead-letter原因、attempt、任务关联及远端结果状态。；通过受限API提供查看、丢弃和条件重投。；将通知重投与业务Operation核对严格区分。

正向验收 dead letter有原因、attempt与关联Task；检查、丢弃和重投通过受限application/API；通知重投不重执行业务；UNKNOWN副作用必须先reconcile。

负向验收 dead letter操作不能删除未核对副作用或把UNKNOWN作为普通重试。

验证方法 拒绝重放未知副作用动作；通知死信重发只影响通知；跨owner不可读取死信。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/05_storage_api.md；docs/03_runtime_recovery.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md

OB-053 实现CardKit与更新通道降级

优先级 P1 规模 M 职责 Integration 状态 TODO

前置依赖 OB-047、OB-051、OB-052、OB-094

需求映射 RQ08

风险 MEDIUM / 卡片增强失败不应使核心审批不可用。

交付路径 services/feishu_gateway/src/openbot_feishu/cardkit.py

相关组件 lark-oapi；nanobot

复用方式 依赖适配

复用要求 复用已核验的CardKit构造模式；有效期/次数/权限来自实际平台与协议版本，不照抄报告硬编码28分钟/14天等。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 基于真实协议记录实现权限探测与更新路径选择。；从token生成时间跟踪期限和次数，而非从任务创建时间计算。；用受控时钟测试权限不足、过期、耗尽和原卡失效的降级。；以OB-094的采纳/NO_COPY结论决定模板来源，记录各卡通道实际协议版本/权限/生成时点；到期/次数/降级判断用可控时钟测试。

正向验收 按实际权限和协议能力选择CardKit/同步/延迟/API更新；token期限自生成起计算；路径不可用可降级普通卡或受控重发；不把卡片寿命写死为未经核验常量。

负向验收 无CardKit权限不能阻断普通审批；45分钟后点击不能被误当已生成token过期。；不得照抄报告28分钟/14天等常量代替当前平台合同，也不能让上游流式循环直接支配outbox。

验证方法 无权限、token过期、次数耗尽、原消息不可更新均可降级；“45分钟后点击”不被误判token过期。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；卡通道能力/时限依据、受控时钟反例与源码采纳或NO_COPY理由。

设计依据 docs/00_scope.md；docs/05_storage_api.md；docs/07_feishu.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-056 飞书端到端真实验收

优先级 P0 规模 M 职责 QA 状态 TODO

前置依赖 OB-025、OB-045、OB-048、OB-050、OB-051、OB-054

需求映射 RQ08、RQ12

风险 HIGH / 远程真实协议必须在发布前得到独立证据。

交付路径 tests/integration/feishu；docs/demos/m3.md

相关组件 lark-oapi

复用方式 独立资格验证

复用要求 保留真实租户闭环，新增所选SDK的启动、断线、取消与双消费者检测证据，分别报告各计时路径。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 用真实测试租户和M1一个Provider跑手机任务/审批/取消。；断网、重启、重复callback、旧卡和撤销owner逐场景验证。；记录冷启动、连接、ACK与callback分位及失败截图/日志的脱敏证据。；真实租户验收固定SDK与协议组合，分别测冷/热启动、发现、握手、callback；补双消费者与SDK阻塞被外部watchdog回收反例。

正向验收 M2用一个已验证Provider在真实测试租户完成手机发任务、审批、取消、重启与断网恢复；记录独立延迟；第二Provider到M3验证，不反向阻塞远程闭环。 结果带版本、环境和样本数；普通卡可用不等于CardKit全部能力已验证。

负向验收 mock通过不算真实飞书验收；第二Provider未到M3不阻塞本阶段但不得宣称完整MVP。

验证方法 完成主流程和6个失败场景；冷启动与3秒callback响应分别报告，不给未经测量延迟保证。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/00_scope.md；docs/03_runtime_recovery.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

M3 完整产品 MVP

本阶段 25 项任务。按 depends_on 拓扑推进；编号顺序不替代依赖关系。

OB-066 实现只读技能指令加载

优先级 P1 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-002、OB-008、OB-024、OB-031

需求映射 RQ04、RQ07

风险 HIGH / 技能文字是常见持久化注入入口。

交付路径 services/core/src/openbot/application/skills.py；contracts/schemas/skill_manifest.schema.json

复用方式 自研控制语义

复用要求 技能来源/版本/license与组件来源台账格式协调，但技能文本不获得依赖准入或权限修改权。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现只读技能manifest与来源/版本/license/capabilities字段。；把说明作为受限上下文载入，不开放内部管理工具。；验证恶意README/技能文本、自动生成draft和权限声明变化。；技能与组件来源台账关联但互不授予权限；技能不能安装未准入依赖、加载workspace原生插件或改变运行模式。

正向验收 技能保留来源/版本/license和capabilities，MVP只读说明加载；文字不能改policy、扩大workspace或调内部管理工具；自动生成只留draft，不自动安装。

负向验收 技能不能增加workspace、关闭policy或自动安装执行生成代码。；源码注释/AGENTS/README不能把REFERENCE_ONLY候选升级成默认runtime。

验证方法 仓库AGENTS/README中恶意指令不能改系统策略；用户安装技能有来源和权限展示。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-062 实现MCP版本协商与生命周期

优先级 P1 规模 M 职责 Integration 状态 TODO

前置依赖 OB-004、OB-007、OB-009、OB-038、OB-092

需求映射 RQ09

风险 HIGH / MCP进程协议故障可阻塞任务或引入未经审核代码。

交付路径 services/core/src/openbot/tools/mcp/client.py

相关组件 mcp-sdk

复用方式 依赖适配

复用要求 采用锁定官方MCP SDK/stdio协议；适配到自有有界进程与流，不默认升级transport或自动安装包。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 固定stdio server与SDK兼容版本，完成initialize和能力协商。；实现bounded请求、取消、断连和process退出映射。；对不支持版本/transport给出明确错误，HTTP能力单独开关。；使用所选官方MCP SDK最低所需API与固定stdio协议组合；初始化/取消/close和实际派生进程均受统一deadline/监督，默认SDK行为须实测。

正向验收 MVP先实现固定版本stdio MCP、SDK协商与compatibility manifest；初始化、取消、断连和输出有界；Streamable HTTP另立能力开关，不以旧SSE假设为唯一协议。 SDK选定版本而不是报告mcp>=范围是兼容性证据；早期trusted fixture不等于允许任意server未隔离启动。

负向验收 不能自动以uvx/npx latest启动server，或遇到版本不匹配无限等待。；不得任意切旧SSE/新transport以掩盖协议不匹配，或在任务中npx/uvx latest补安装。

验证方法 使用受控MCP服务器测试初始化、异常、取消与版本不匹配；无无限等待或secret日志。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/06_tools_providers.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-063 实现MCP注册与工具元数据锁定

优先级 P1 规模 M 职责 Security 状态 TODO

前置依赖 OB-002、OB-031、OB-037、OB-062、OB-090

需求映射 RQ04、RQ09

风险 CRITICAL / 工具动态变更会在用户批准后改变实际行为。

交付路径 services/core/src/openbot/tools/mcp/registry.py

相关组件 mcp-sdk；rfc8785；pydantic-jsonschema

复用方式 依赖适配

复用要求 JCS hash覆盖完整manifest、package、命令/env/transport；refs本地化与Draft2020-12校验；list_changed隔离，annotations仅外部数据。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 为server包、启动命令、环境和完整工具定义生成manifest digest。；启动及list_changed先隔离相关工具，再产生差异审阅。；将批准绑定tool manifest版本，更新后撤销不兼容旧提案。；manifest由Python权威规范化，使用OB-090向量与本地schema registry；固定完整定义并对schema大小/引用/递归/时间设限。

正向验收 pinning覆盖包digest、命令、环境、transport、完整tool definition与input/output schema/annotations；启动与list_changed隔离重审；元数据固定不等于server可信。 未经允许的远程/未知ref不联网解析，format要求显式校验；完整元数据变更冻结相关能力并使旧绑定重新审查。

负向验收 schema hash一致不能作为server代码安全证明；工具名不得覆盖内建名称。；工具description/inputSchema/outputSchema/annotations的任何关键变化不能沿用旧批准；JCS hash不证明server实现安全。

验证方法 描述或schema改变后无法沿用旧批准；不能以schema hash证明server代码可信。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-026 实现Ollama或第二Provider

优先级 P1 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-008、OB-009、OB-023、OB-024、OB-037、OB-038、OB-039、OB-092

需求映射 RQ06、RQ07

风险 HIGH / 本地模式错误映射可隐式外发或产生能力误报。

交付路径 services/core/src/openbot/providers/ollama.py

相关组件 model-ollama；httpx；tiktoken；model-runner

复用方式 依赖适配

复用要求 Ollama SDK或httpx择一；loopback可能转云，验证model/runner配置与实际出口，不以名称或地址推断本地。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 到M3锁定Ollama SDK或受控httpx及实际本地model/runner组合，记录模型来源、能力与启动配置。；核验真实网络命名空间、关闭云功能并限制允许模型/服务工具；localhost、模型名或无云key均不单独证明本地推理。；统一处理流、usage、取消与有界重试；禁止自动工具helper、Provider托管搜索/remote MCP和隐式云回退。；在干净缓存/禁网环境执行首个真实模型请求，观测runner的实际egress并测试云模型/搜索/资产下载拒绝；再完成与云Provider相同合同场景。

正向验收 M3补齐本地Provider，使MVP具备一个云Provider和一个本地Provider；LOCAL_MODEL/OFFLINE均不云回退；无tool能力时明确CAPABILITY_UNAVAILABLE。 本地能力需要model、runner配置及网络证据共同成立；缺少可核验证据时CAPABILITY_UNAVAILABLE而不宣称LOCAL_MODEL/OFFLINE。任务中不拉取模型或词表。

负向验收 模型不支持工具时不能伪造成功；容器localhost不能未经验证当宿主本地服务。；不得只检查127.0.0.1或cloud名称后放行；不能让本机服务转发云模型/web search，不能在本地失败后转云。

验证方法 同一固定任务两Provider都可完成或给出能力拒绝；OFFLINE网络审计通过。 针对所选版本主动构造localhost转云/搜索请求，确认被配置和网络边界拒绝；记录本地模型实际推理与无额外网络的观察范围。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。；模型资产/runner版本、禁云配置、真实首次请求网络证据与取消后的尝试计数。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/00_scope.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-057 实现专用浏览器profile与会话锁

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-007、OB-016、OB-031、OB-037、OB-039、OB-042、OB-092

需求映射 RQ06、RQ09

风险 HIGH / 浏览器登录态拥有用户账户权限。

交付路径 services/core/src/openbot/tools/executors/browser/session.py

相关组件 playwright

复用方式 依赖适配

复用要求 直接Playwright原语、专用profile；Chromium sandbox显式配置/验证，不能暗加--no-sandbox；外层隔离另证。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 使用直接Playwright异步原语，建立专用profile目录/锁和用户手动登录；固定驱动与浏览器build，清理继承环境。；对所选Chromium后端显式配置并验证chromium_sandbox；检查实际启动参数及容器/OS边界，不依赖默认false或暗中--no-sandbox。；浏览器纳入统一supervisor与资源归属，用户cookie/凭据不出profile；不复制默认Chrome目录或接任意CDP。；验证并发/旧epoch/profile冲突/异常退出、sandbox不可用及登录态保护，按实际OS/engine/backend记录资格。

正向验收 直接Playwright原语配OpenBot专用user-data目录和profile锁；用户手动登录；不复制日常Chrome profile、解密cookie或接管任意CDP端口；能力按OS报告。 Chromium自身sandbox与外层OS/容器隔离分别有证据；需要的边界不可启用时拒绝能力，不静默去掉sandbox启动。

负向验收 不得复制用户默认Chrome profile、解密cookies或附着任意CDP端口。；不得通过--no-sandbox消除启动报错后仍声称强隔离；专用profile不是OS沙箱证明。

验证方法 并发任务不相互抢上下文；敏感cookie不进Artifact；profile锁冲突提示且不损坏用户profile。 核对实际argv/配置与探针，故意破坏sandbox前提时可解释拒绝；浏览器关闭/崩溃后执行域能被Supervisor核对。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。；Playwright/browser build与资产hash、sandbox配置/实际启动证据、OS/backend资格与profile锁记录。

设计依据 docs/06_tools_providers.md；docs/02_architecture.md；docs/08_desktop_release.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-064 实现MCP进程和网络权限

优先级 P1 规模 M 职责 Security 状态 TODO

前置依赖 OB-019、OB-037、OB-038、OB-041、OB-062、OB-063、OB-042

需求映射 RQ04、RQ05、RQ06、RQ09

风险 CRITICAL / MCP服务拥有代码执行能力，客户端校验不能替代隔离。

交付路径 services/core/src/openbot/tools/mcp/executor.py

相关组件 mcp-sdk；python-on-whales

复用方式 依赖适配

复用要求 stdio server必须经已验证隔离后端与Supervisor；SDK派生子进程不准继承全部env，也不能自行触发sampling/Agent loop。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 在隔离后端运行已安装stdio server并注入最小secret。；把每个调用包为普通Operation/dispatch，使用本地reviewed manifest。；禁用sampling、隐式提权和运行中安装，测试越权读取与网络。；显式构造stdio子进程env/HOME/TMP/PATH和固定启动命令，实测真实进程而不假设SDK默认全继承或全过滤；接入统一容器/进程监督。

正向验收 stdio server作为不可信程序隔离，无父进程全部env；MCP调用必须经过同一Broker和短期dispatch；本地reviewed manifest决定retry_class；MVP禁sampling与自动安装latest。 关闭采样与自动工具/Provider远端MCP旁路；server安装、来源审查与任务调用分离。

负向验收 第三方readOnlyHint/idempotentHint不得直接决定授权或重试；未知server不执行。；不得因MCP SDK自带spawn就绕过OB-041/042，或让annotations决定免审批/重试。

验证方法 恶意server读宿主secret或额外网络请求被隔离层拦截；缺少沙箱不宣称工具安全。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-068 实现用户级daemon安装与卸载

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-003、OB-005、OB-008、OB-028、OB-042、OB-093

需求映射 RQ01、RQ11

风险 HIGH / 安装生命周期错误会扩大权限或破坏用户数据。

交付路径 native/supervisor/packaging；apps/cli；docs/install

相关组件 service-manager；profile-locks；windows-sys

复用方式 原生原语适配

复用要求 service-manager仅在已验证launchd/systemd用户级场景复用；Windows用户登录会话独立实现，不用系统服务替代。；实际OS、架构、backend和配置组合须独立提供证据；统一API、正常退出或进程组不能自动证明所有强杀与逃逸场景均可回收。

实施步骤 按OS实现用户级安装/start/stop/status/uninstall；macOS LaunchAgent和Linux systemd --user可用已验证service-manager封装。；Windows独立实现登录用户会话机制，验证交互用户令牌/最低权限；所选service-manager的sc.exe/WinSW后端不支持User级能力，不能直接替代。；明确唯一自启/锁所有者、登录/登出/重启/显式stop规则；UI退出不停止daemon，重复安装不创建第二实例。；在原生环境验证服务描述、权限/目录、卸载保留数据与失败恢复；干净发行安装继续由OB-072证明。

正向验收 实现每目标OS用户级常驻服务的安装/启动/停止/自启/卸载；不以高权限system service运行用户桌面会话；基础服务验证后由OB-072补全打包安装证据。 组件跨平台API不等于跨平台用户会话语义；Windows不使用LocalSystem/root等高权限绕过缺能力。

负向验收 不得使用高权限system服务控制用户桌面；卸载不得误删工作区。；不得用service-manager Windows系统服务能力伪装用户会话支持，或让Tauri与原生服务各自启动一个daemon。

验证方法 全新用户环境安装后重启可恢复；卸载不误删工作区；UI退出不影响daemon。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；每OS实际服务/登录任务描述、用户令牌/权限/锁归属与启停卸载证据。

设计依据 docs/02_architecture.md；docs/00_scope.md；docs/08_desktop_release.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-058 实现浏览器网络与下载策略

优先级 P1 规模 M 职责 Security 状态 TODO

前置依赖 OB-032、OB-036、OB-037、OB-057、OB-041

需求映射 RQ06、RQ09

风险 CRITICAL / 浏览器可通过子请求或上传绕过表面导航限制。

交付路径 services/core/src/openbot/tools/executors/browser/network_policy.py

相关组件 playwright

复用方式 依赖适配

复用要求 BrowserContext.route / Page.route仅一层，Service Worker默认阻止绕过或由已验证更强边界覆盖；真实出口与上传下载同验。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 把导航/重定向/popup/iframe/subrequest、WebSocket及上传下载共同纳入数据/网络策略，禁止file/内部/metadata地址。；明确Service Worker策略：受控能力默认阻止其绕过route；若应用确需启用，必须由已验证更强网络边界覆盖并记录限制。；需要强隔离的能力使用实际OS/容器网络边界；BrowserContext.route / Page.route只作应用层防线，代理/DNS/浏览器进程不得有策略旁路。；验证SW发起请求、重定向/弹窗/下载路径穿越、未批上传与边界不可用的拒绝，不以路由handler覆盖率当隔离证明。

正向验收 导航、重定向、popup、iframe、subrequest、下载上传一起经过策略；禁止file/内部/元数据地址；需要强网络边界时用隔离后端，BrowserContext.route / Page.route不能当完整隔离证明。 BrowserContext.route / Page.route无法拦截的Service Worker等路径被明确禁用或受独立网络边界约束；缺少相应证据不标能力可用。

负向验收 仅BrowserContext.route / Page.route不能宣称完整隔离；无法强制必要边界就不得开放该任务。；不得静默启用Service Worker或增加代理来绕过拦截，也不得把route当整个浏览器网络沙箱。

验证方法 重定向到localhost/metadata、下载路径穿越、上传未批文件被阻断；运行模式能力不足时拒绝。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；Service Worker拒绝/独立边界策略、实际请求目标与下载/upload反例。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-065 建立MCP恶意与故障服务器测试

优先级 P1 规模 M 职责 QA 状态 TODO

前置依赖 OB-062、OB-063、OB-064

需求映射 RQ09、RQ12

风险 HIGH / 协议边界测试不足会让第三方工具绕过通用安全。

交付路径 tests/integration/mcp

相关组件 mcp-sdk；model-runner

复用方式 独立资格验证

复用要求 覆盖SDK取消语义、服务端断连、schema/refs洪泛与变更；独立计数请求/效果，执行后断连不自动再执行。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 实现恶意/故障MCP fixture，包括变更、洪泛、重复ID和执行后断连。；检查工具注册、输出过滤、timeout和UNKNOWN语义。；保存可复现案例并接入对应PR回归。；增加实际SDK取消/断连、恶意远程ref/格式、主动sampling、重复ID和server-side执行诱导；失败状态与真实副作用计数一致。

正向验收 模拟工具表更新、超长输出、schema洪泛、请求ID重复、server退出和未知结果；输出通过统一过滤。 所选MCP SDK与server组合有独立fault证据，模型托管remote MCP不充当本地受控MCP实现。

负向验收 server断连后的未知副作用不能无条件重试；大输出不得耗尽内存。

验证方法 全部客户端超时有界；工具名碰撞不会覆盖内建工具；执行后断连不无条件重试。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-069 建立macOS原生运行门禁

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-032、OB-042、OB-068

需求映射 RQ05、RQ11

风险 HIGH / 平台差异可能使安全与生命周期假设失效。

交付路径 .github/workflows/platform-macos.yml；tests/integration/platform/macos

相关组件 keyring；service-manager；playwright

复用方式 独立资格验证

复用要求 macOS实际arch/OS/钥匙串/原生轮子/浏览器/worker残余均记录；UI不需要的屏幕权限不提前索取。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 选择macOS ARM64原生测试环境并记录版本/权限。；验证路径、凭据、daemon与worker、Browser/MCP声明能力。；输出supported/experimental/unsupported矩阵并交打包任务。；对选定macOS/arch核验Keychain、LaunchAgent、原生wheel/grammar、浏览器sandbox及清理边界；不预先要求MVP无GUI能力的录屏/辅助权限。

正向验收 原生macOS受控开发环境验证路径、凭据、daemon、浏览器与worker清理；ARM64为试点，Intel是否支持据实记录；无GUI版本不要求录屏授权。 库发布平台声明不替代本机实际能力；Intel是否支持仍据证据判断。

负向验收 未测Intel不得标支持；无GUI版本不能要求录屏权限或宣称已有桌面控制。

验证方法 原生macOS集成测试与能力报告；此任务可用固定开发运行时，完全无开发环境的安装证明由OB-072补足。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/02_architecture.md；docs/00_scope.md；docs/06_tools_providers.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-070 建立Windows原生运行门禁

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-032、OB-042、OB-068

需求映射 RQ05、RQ11

风险 HIGH / Windows路径和进程归属是关键安全边界。

交付路径 .github/workflows/platform-windows.yml；tests/integration/platform/windows

相关组件 windows-sys；keyring；service-manager；playwright

复用方式 独立资格验证

复用要求 Windows原生验证Job创建序列、嵌套/拒绝、中文路径与依赖资产；不用WSL或crate宣传替代证据。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 选择原生Windows x64测试环境，不用WSL代替。；覆盖长路径/junction/中文空格、Job与凭据/用户会话。；输出能力与失败限制，供CLI安装验证使用。；验证挂起创建→Job分配→恢复顺序、Job失败/嵌套/PID复用、用户登录任务与Credential Manager；记录实际Windows wheel/CLI/浏览器资产。

正向验收 原生Windows x64验证长路径/junction/Job Object/凭据与用户会话；不用WSL代验；路径含中文空格可用；未支持的原生命令不伪装成容器能力。

负向验收 容器里Linux命令不能被写成Windows原生PowerShell/Win32支持。；service-manager缺User后端不能自动切LocalSystem；不得以WSL完成Windows资格。

验证方法 原生Windows受控环境跑平台测试与能力报告；干净安装由OB-072验证；检测worker脱离Job和PID复用风险。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/02_architecture.md；docs/00_scope.md；docs/06_tools_providers.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-071 建立Linux原生运行门禁

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-032、OB-042、OB-068

需求映射 RQ05、RQ11

风险 HIGH / 发行版与运行会话差异会破坏守护和隔离行为。

交付路径 .github/workflows/platform-linux.yml；tests/integration/platform/linux

相关组件 keyring；service-manager；python-on-whales

复用方式 独立资格验证

复用要求 Linux发行版/服务管理/rootless容器/cgroup与keyring不可用路径明确，其他backend不能因接口相似自动标supported。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 冻结Linux x64发行版和systemd user基线。；检查凭据、路径、cgroup/进程组、隔离后端和浏览器依赖。；记录无systemd或桌面会话差异，生成能力报告。；记录已测发行版、systemd user、可用cgroup/rootless引擎与Secret Service；缺组件/权限时能力拒绝，非systemd和其他引擎另给支持边界。

正向验收 明确受支持Linux x64发行版、systemd user与可选无systemd边界；验证文件/浏览器/隔离能力；X11/Wayland GUI不计入本MVP完成条件。

负向验收 X11测试不能代表Wayland桌面自动化，未支持能力不得静默失败。；不得把Docker/Podman/nerdctl统一API当等价保证，或无D-Bus时回退明文keyring。

验证方法 原生Linux固定运行时测试与能力报告；干净安装由OB-072验证；容器缺失、资源权限不足给CAPABILITY_UNAVAILABLE。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/02_architecture.md；docs/00_scope.md；docs/06_tools_providers.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-075 实现统一可观测性与诊断

优先级 P1 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-009、OB-015、OB-021、OB-023、OB-039、OB-054

需求映射 RQ06、RQ10、RQ12

风险 HIGH / 诊断泄漏和健康误报会掩盖运行风险。

交付路径 services/core/src/openbot/observability；docs/operations

相关组件 structlog；opentelemetry

复用方式 依赖适配

复用要求 structlog是格式/上下文管道，跨任务contextvars绑定/清理与脱敏自有；OpenTelemetry按需单独准入，不默认远程exporter。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 汇总M1结构日志、trace和ledger，增加跨进程关联。；提供队列、UNKNOWN、预算、连接和资源健康指标。；实现显式本地诊断导出并验证脱敏和容量。；structlog负责结构化管道；显式绑定/清除并发contextvars，前置过滤与异常处理统一。OpenTelemetry按需准入，默认无远程exporter。

正向验收 汇总M1已有结构日志和审计，关联Task/Operation/Attempt/event；增加inbox lag、outbox age、UNKNOWN、writer queue、预算和网关指标；默认不远程上报，不收集隐藏思维。 高基数Task/Operation等只用于有界日志/trace，不作为无界metrics标签；SDK调试日志同样受最小化/脱敏。

负向验收 不采集模型隐藏思维、secret或默认远传诊断；UI在线不等于系统健康。；不得声称装structlog即自动全链路安全，或通过默认exporter外发秘密/运行数据。

验证方法 每个主失败场景可由日志定位；诊断包需显式导出且脱敏；不收集隐藏推理内容。 并发任务上下文不串线，异常与SDK debug经过同一过滤；诊断包仍显式导出。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/02_architecture.md；docs/05_storage_api.md；docs/00_scope.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-072 建立可复现打包与运行资源清单

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-004、OB-005、OB-069、OB-070、OB-071、OB-089

需求映射 RQ11、RQ12

风险 HIGH / 开发机可运行不能证明用户能安装使用。

交付路径 scripts/build；packaging；docs/runtime-dependencies.md

相关组件 pyinstaller；cli-toolchain；playwright；tree-sitter-language-pack；tiktoken

复用方式 独立资格验证

复用要求 PyInstaller onedir是候选打包路线；每OS干净安装、首次离线运行、完整资源清单；可复现性按实测说明，不承诺bitwise一致。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 按各OS锁定工具链，优先评估PyInstaller onedir；列Python/Rust/前端包与rg、浏览器、grammar、词表、镜像和源码片段等完整资产。；在安装/构建准备阶段取得固定资产并校验，运行期不自动下载；缺后端/资产明确报错，默认环境不包含未来P2功能。；每OS干净机器安装、首次离线version/API/词表/支持grammar/浏览器smoke，观察网络、权限与secret/profile排除。；保存重建命令、输入/产物hash、平台差异和可复现范围；把完整资产交OB-096核验，不以“可重复构建”承诺未经证明bitwise一致。

正向验收 三平台CLI安装包构建可复现、附hash/版本/依赖清单；Python/浏览器/隔离后端如何提供或预检说明完整；M3可采用明确标注的未签名试点包，不能假称桌面签名Beta。 Python包锁之外的非包资产有精确版本/hash与来源；安装准备联网与OFFLINE首用明确分开。

负向验收 产物不得包含secret/profile/cache；不完整CLI安装不能把MVP标完成。；不得首次使用时暗中补浏览器/grammar/词表；未签名试点包仍按既有M3说明，不冒称M4认证。

验证方法 每OS干净机器安装smoke；runtime资源缺失明确报错；产物不含测试密钥/缓存profile。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。；三OS实际安装资源清单、禁网首次调用、可再建差异说明与全部产物hash。

设计依据 docs/00_scope.md；docs/02_architecture.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-078 建立断网休眠与崩溃浸泡

优先级 P1 规模 M 职责 QA 状态 TODO

前置依赖 OB-020、OB-022、OB-030、OB-042、OB-054、OB-075

需求映射 RQ03、RQ11、RQ12

风险 HIGH / 长时故障会暴露竞态与资源泄漏。

交付路径 tests/chaos/soak；docs/soak-report-template.md

相关组件 lark-oapi；python-on-whales；model-runner

复用方式 独立资格验证

复用要求 覆盖SDK阻塞、DNS半开、daemon/客户端/容器各类死亡与遗留资源；报告样本和清理边界，不用100%表述。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 把规定故障点扩展为三平台有界浸泡场景。；注入DNS/TCP半开、睡眠、磁盘满和进程死亡，记录恢复决定。；输出样本时间、环境、首故障和残余UNKNOWN报告。；补SDK真实取消/阻塞、runner本地转云、客户端死而容器存活、scanner联网验证、空缓存资产首用与native parser故障，按实际启用能力组合运行。

正向验收 扩展M1已覆盖的崩溃点为三平台长时网络/休眠/磁盘故障浸泡；记录版本、时间、硬件、未知效果与恢复决定；不把样本通过写成绝对无损保证。 强杀、休眠、普通异常和真实断电分别记录，不能把任一类通过当全部耐久性证明。

负向验收 有限样本不能宣称100%无损；恢复不能为了完成率盲重试危险动作。

验证方法 至少覆盖每OS已支持能力；恢复时不重复危险操作；报告时间/样本/硬件/版本。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/03_runtime_recovery.md；docs/00_scope.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-095 审查DOM提取脚本的最小源码复用

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-057、OB-058、OB-089、OB-092

需求映射 RQ06、RQ09、RQ11、RQ12

风险 HIGH / 被抽出的脚本仍依赖浏览器Agent执行网络/动作或包含过量隐私。

交付路径 docs/evidence/source-reuse-browser-dom.md；components/source-reuse/browser-dom.json

相关组件 browser-use；playwright

复用方式 源码参考审查

复用要求 默认REFERENCE_ONLY；比较后可给出NO_COPY及理由。只有选择有限摘取时才要求固定commit/path/hash、LICENSE/NOTICE、差异和回归，禁止整仓导入。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 比较browser-use候选只读DOM片段与最小自有提取器的范围、依赖、维护成本；拟摘取时检查精确commit/文件许可与隐藏执行。；记录NO_COPY或有限摘取决定；NO_COPY只需有明确比较和理由，后续最小DOM实现交OB-059，不强制vendor或引入browser-use包。；若选择摘取，保留来源/NOTICE/diff并裁剪为限量只读脚本，移除模型/Agent/自动点击/主动fetch；在DOM/iframe/导航/恶意页面fixture验边界。

正向验收 NO_COPY分支有比较与理由即可完成审查；实际摘取分支才要求独立脚本fixture、确定来源hash、额外动作/主动请求为0、输出时间/大小有界及TAINTED_EXTERNAL/page/frame/revision。任何决定都不采用自治Agent.run。

负向验收 不得为关闭任务而整仓导入或强制复制；不得使用browser-use自治循环、自行请求模型或自动执行动作。；DOM脚本来源不会使页面文本变可信，也不能赋予owner/策略/授权。

验证方法 复核NO_COPY理由及与自有方案的比较；实际摘取才执行只读DOM、隐式请求/动作canary、超限与导航fixture，并核对源文件/NOTICE/hash。

完成证据 NO_COPY或有限摘取决定与方案比较；NO_COPY的提取代码/fixture项明确NOT_APPLICABLE。；实际摘取时提供commit/path/license/hash/diff、维护人与只读/限额/副作用计数证据。

设计依据 docs/04_security_approvals.md；docs/06_tools_providers.md；docs/09_testing_operations.md；docs/11_decisions_evidence.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

OB-059 实现结构化浏览器读工具

优先级 P1 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-007、OB-019、OB-057、OB-058、OB-095

需求映射 RQ07、RQ09

风险 HIGH / 不稳定页面引用会让后续动作指向错误目标。

交付路径 services/core/src/openbot/tools/browser/read.py

相关组件 playwright；browser-use

复用方式 依赖适配

复用要求 只采用OB-095核验的DOM只读片段或最小自有提取器；结果带page/frame/revision/provenance，独立预算与输出限额。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 实现open/extract的稳定page/frame/revision引用。；把结构化正文/表格与外部provenance、URL证据返回。；验证导航变化、超量DOM、恶意文本和fixture表格。；按OB-095决定使用有限摘取或NO_COPY后自有最小DOM提取器；执行脚本只读、无模型/自动点击/主动fetch且有输出/时间界限。

正向验收 browser.open/extract返回page/frame/snapshot revision、最终origin与结构化证据；页面文本外部不可信；限时限量；旧元素引用跨导航无效。 DOM脚本只产生带TAINTED_EXTERNAL和page/frame/revision的证据，代码来源不改变页面内容不可信性。

负向验收 旧element index不能跨页面使用；页面文字不能改变工具权限。；不得调用browser-use Agent.run或从页面文字生成权威身份、策略、授权字段。

验证方法 fixture站点读表正确；恶意页面不能改变策略；导航变化使旧元素引用无效。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；DOM来源决定、只读脚本fixture和隐式动作/网络canary计数。

设计依据 docs/06_tools_providers.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-060 实现浏览器写动作提案与确认

优先级 P1 规模 M 职责 Security 状态 TODO

前置依赖 OB-017、OB-018、OB-019、OB-059

需求映射 RQ03、RQ04、RQ09

风险 CRITICAL / 浏览器写通常直接影响外部账户。

交付路径 services/core/src/openbot/tools/browser/actions.py

相关组件 playwright；browser-use；model-runner

复用方式 自研控制语义

复用要求 每个浏览器写动作都经Broker、revision复验与OutcomeVerifier；不采用browser-use Agent.run()或多动作批量越权。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 构造带目标、输入、origin和revision的不可变browser.act提案。；审批后重获资源、重新定位与核对页面条件。；执行后验证目标效果，提交超时转UNKNOWN并提供核对信息。；浏览器SDK只执行单次已批准原语，禁browser-use自治loop和推测多动作；第三方成功返回仍需OutcomeVerifier证据。

正向验收 browser.act绑定page/frame/locator/action/input/revision及origin；写操作批准后重新定位/复验；超时不能当作提交失败，可能已执行时Operation UNKNOWN、Task RECONCILING。

负向验收 金额、目标按钮、页面或frame变化时旧批准必须失效；禁止盲点第二次提交。；不允许页面中的“已成功”文字或库返回无异常直接解除UNKNOWN/quarantine，不能因timeout再点击。

验证方法 页面换按钮、变金额、跨站跳转后旧批准拒绝；外部提交timeout进入UNKNOWN。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/03_runtime_recovery.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-061 建立浏览器结果验证回归

优先级 P1 规模 M 职责 QA 状态 TODO

前置依赖 OB-020、OB-059、OB-060

需求映射 RQ09、RQ12

风险 HIGH / 只测点击成功会漏掉实际提交错误。

交付路径 tests/integration/browser

相关组件 playwright

复用方式 独立资格验证

复用要求 DOM污染/导航/权限变化/点击已成功回执丢失按真实效果计数，驱动返回无异常不能代表用户目标成功。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 建立受控登录、表单、下载、重定向与页面变化fixture。；记录外部效果计数、DOM/receipt和有限截图证据。；将读、写、未知结果和用户介入场景接入回归。；增加Service Worker/重定向出口、sandbox拒绝、DOM脚本隐式动作和提交成功后断流；按真实页面结果、请求和副作用计数判定。

正向验收 测试目标是页面结果和外部副作用计数；失败不能仅靠模型说完成；提供截图/DOM证据限制。 fixture覆盖仅应用层route与更强网络模式的差异，未满足边界的场景明确拒绝。

负向验收 模型说完成或点击API返回成功不能代替业务效果验证。

验证方法 fixture购物/表单/下载/重定向/登录过期场景可复现；对不可确认结果明确unknown。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/06_tools_providers.md；docs/03_runtime_recovery.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-067 交付全MVP能力集回归

优先级 P1 规模 M 职责 QA 状态 TODO

前置依赖 OB-026、OB-056、OB-061、OB-065、OB-066

需求映射 RQ07、RQ08、RQ09、RQ12

风险 HIGH / 功能清单通过但未真正集成会产生虚假完成。

交付路径 docs/demos/mvp.md；tests/integration/scenarios/mvp

复用方式 独立资格验证

复用要求 已选组件的合同/副作用门禁随能力集验证；记录确切组合，不把各库独立通过拼成整系统安全结论。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 逐项映射U1完整MVP到已有模块和证据。；组合两Provider、Feishu、ACI、隔离、Browser和MCP的受控场景。；安全关键失败阻断功能集签核；安装证据交OB-072/080合并。；把已启用组件版本/资产/配置组合与Q门禁关联，核对先前单库合格是否仍满足组合后的预算、egress和恢复语义。

正向验收 M3功能回归覆盖云加本地两Provider、飞书、ACI/隔离进程/Browser/MCP、恢复；每项原研究MVP能力有证据；三OS安装发布在OB-072/080联合完成，不以单环境演示代替。 云+本地Provider、Browser/MCP/飞书真实证据与mock反例分列；未启用的REFERENCE_ONLY/DEFERRED不冒充能力。

负向验收 本地/飞书Alpha不能替代完整MVP；不支持能力不能返回空成功。

验证方法 每项原研究第14页MVP都有证据和任务映射；任一安全关键失败阻止发布。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；启用组件组合清单、关联Q/任务证据与每项能力的真实/模拟区分。

设计依据 docs/00_scope.md；docs/06_tools_providers.md；docs/07_feishu.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-076 建立真实任务质量基准集

优先级 P1 规模 M 职责 QA 状态 TODO

前置依赖 OB-067、OB-075

需求映射 RQ07、RQ12

风险 HIGH / 错误质量指标会掩盖产品做不成任务。

交付路径 evals/scenarios；evals/rubrics；evals/run.py

复用方式 独立资格验证

复用要求 记录选定组件、模型、原生资源及样本n；性能、LOC、成本、工期以本机测量和范围为准，不继承报告保证。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 定义受控任务、产物验证器和分项rubric。；多次真实模型运行并记录n、模型/prompt/tool版本、成本和结果状态。；建立baseline后再冻结质量目标，保留失败案例与回归阈值。；同时记录组件/SDK/model/browser/grammar/镜像版本与配置，测量启动、安装体积、常驻资源、请求/恢复耗时，报告样本与失败。

正向验收 真实Provider受控基准区分协议/安全/能力，记录SUCCEEDED/PARTIAL/FAILED/RECONCILING结果与n、版本、成本、延迟；模型final只有请求完成权，OutcomeVerifier核对产物和未知动作。

负向验收 mock测试或模型final不能作为真实任务成功证据；未知动作未解决不能算成功。；不得把报告Stars、5k–15k行、400行、固定倍数收益或工期作为验收承诺。

验证方法 mock不作为智能效果证据；真实模型至少多次运行记录n和失败样例；模型/提示/工具版本可追踪。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/03_runtime_recovery.md；docs/06_tools_providers.md；docs/00_scope.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-079 完成上手与故障处置文档

优先级 P1 规模 M 职责 Docs 状态 TODO

前置依赖 OB-056、OB-067、OB-068、OB-072、OB-075

需求映射 RQ10、RQ11、RQ12

风险 MEDIUM / 可操作性不足会导致用户错误恢复或扩大权限。

交付路径 README.md；docs/getting-started.md；docs/troubleshooting.md；SECURITY.md

复用方式 独立资格验证

复用要求 列依赖组、安装期资产下载/批准、首次离线启动、缺backend拒绝、组件升级和NOTICE；未验证候选对用户不宣称已支持。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 编写从空环境安装、doctor、配对和首个任务的步骤。；补取消/撤销、UNKNOWN核对、备份恢复、密钥轮换与脱敏报障。；让未参与开发者按文档独立完成，记录阻塞点后修订。；写清依赖组、组件准入、安装期资产准备、首次离线运行、NO_COPY或来源维护、缺backend拒绝、SDK升级与许可证清单阅读路径。

正向验收 M3完成CLI/飞书配对、权限、停止、UNKNOWN核对、密钥轮换、备份恢复和诊断文档；MVP安装路径完整；M4自动升级/桌面步骤由OB-073/074补充。 用户可从能力清单知道哪些已验证、未验证或延期；恢复手册不建议ignore UNKNOWN后重做。

负向验收 不要求用户查源码才能处理常见失败；未完成M4功能不能写成可用。

验证方法 从未使用项目的人按说明独立完成主场景；失败路径无需查源码才能恢复。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/00_scope.md；docs/05_storage_api.md；docs/03_runtime_recovery.md；docs/07_feishu.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-096 验收全量交付资产来源与供应链

优先级 P0 规模 M 职责 QA 状态 TODO

前置依赖 OB-004、OB-067、OB-072、OB-089、OB-094、OB-095

需求映射 RQ05、RQ07、RQ09、RQ11、RQ12

风险 HIGH / 锁文件覆盖Python包却漏浏览器/grammar/tokenizer/rg/镜像及vendored源码。

交付路径 scripts/check_release_components.py；docs/releases/component-supply-chain.md；release/SBOM；release/THIRD_PARTY_NOTICES.md；release/checksums.json

相关组件 sbom-tools；pyinstaller；playwright；tree-sitter-language-pack；tiktoken

复用方式 独立资格验证

复用要求 本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。；component_refs表示相关组件或被审查边界，不表示自动安装或已准入；按catalog类别和当前阶段执行。

实施步骤 按构建输入与实际包枚举全部Python/Rust/前端依赖及CLI、浏览器build、grammar、tokenizer、镜像和实际摘取代码，匹配catalog/各生态锁/来源/NOTICE。；生成明确格式的SPDX或CycloneDX SBOM及校验、checksums和平台资产清单；NO_COPY决定无需虚构vendor资产，条件候选未启用不冒称安装。；在三OS发行环境验证安装期准备与首次禁网使用，缺资产拒绝；检查受管容器/浏览器/parser实际加载配置与构建清单一致。；以篡改/来源或许可缺失/摘要漂移和过期风险例外阻断release，记录可再建范围与差异；M4桌面签名独立，M3不延后来源核验。

正向验收 交付内容与资产清单逐项匹配；SBOM标明实际使用SPDX或CycloneDX且通过相应schema；被篡改资产被拒绝；原生三OS安装证据可关联精确hash。

负向验收 不能把锁定版本当无漏洞保证；不能把CycloneDX输出冒称SPDX；不能以M4签名未做为由跳过M3源/许可证/摘要核验。；不能把仅Python包SBOM当完整供应链，也不能因所有来源已锁就声称没有漏洞。

验证方法 从OB-072三OS实际产物导出内容清单，与catalog/锁/SBOM/NOTICE/checksums逐项比较；校验所选SBOM schema，篡改一项资产必须失败，重建/离线首用记录可追溯。

完成证据 三OS包/资源清单、选定格式SBOM及校验、NOTICE、构建输入hash、禁网首用记录、篡改反例和有限期风险例外。；记录精确来源/版本、OS/架构/配置、测试命令与限制；本包只定义门禁，真实结果未实施前保持NOT_RUN。

设计依据 docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/12_component_reuse.md；docs/13_component_qualification.md；docs/14_revision_v1_2.md

OB-077 建立分层CI门禁

优先级 P1 规模 M 职责 QA 状态 TODO

前置依赖 OB-010、OB-045、OB-067、OB-069、OB-070、OB-071、OB-072、OB-096

需求映射 RQ11、RQ12

风险 HIGH / 门禁虚设会把已知安全缺陷带入发布。

交付路径 .github/workflows/pull_request；.github/workflows/nightly；.github/workflows/release

相关组件 cli-toolchain；sbom-tools

复用方式 独立资格验证

复用要求 早期已执行registry/锁/合同门禁，本任务整合阶段矩阵、上游升级fixture、供应链与release gate；不存在M3才加安全测试。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 盘点M0/M1已存在门禁并按风险归入PR层。；新增真实Provider/租户nightly和三OS安装release层。；注入一次已知失败证明门禁会阻断，并隔离测试凭据。；整合M0准入/合同、M1组件故障和M3全资产门禁；上游版本/来源变更触发对应fixture，锁/来源/SBOM漂移阻断release。

正向验收 将M0/M1已有契约、安全、迁移和故障门禁整合成PR/nightly/release层级；M3才补真实租户和三OS发行验证；不是等到本任务才写安全测试。 新增OB-089—096按阶段验收，PR不因全局列表就安装所有组件；文档改动只跑必要一致性检查。

负向验收 不能等M3才开启安全测试；不得通过跳过失败测试放行。

验证方法 一次故障注入证明门禁能阻断；不要求每小改跑12h或所有付费测试；测试用秘密隔离。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。；至少一例组件版本/来源/资产不匹配导致门禁失败的复现，另附受影响测试选择规则。

设计依据 docs/00_scope.md；docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-080 完成MVP发布验收与风险登记

优先级 P1 规模 S 职责 Lead 状态 TODO

前置依赖 OB-067、OB-072、OB-076、OB-077、OB-078、OB-079、OB-096

需求映射 RQ01、RQ11、RQ12

风险 HIGH / 发布声明必须与实际验证边界一致。

交付路径 docs/releases/mvp-acceptance.md；docs/risks.md

相关组件 sbom-tools

复用方式 独立资格验证

复用要求 M3基础供应链/离线首用/真实OS支持证据为发布前置；M4签名桌面和P2组件仍后置，不逆向阻塞。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 汇总功能、原生平台、安装、安全和真实质量证据。；逐项签核RQ/S场景并登记剩余风险、owner与降级。；在候选版本重新安装演示，发布明确能力矩阵和限制。；将OB-096全量资产供应链与已启用组件资格作为M3退出条件；核对真实能力矩阵、有限期风险例外和未验证项，不等待M4签名替代。

正向验收 M3逐条签核原MVP范围、三平台CLI和受支持能力；安全关键失败阻断；无真实证据不标supported；M4桌面签名与自动升级不作为本gate的逆向依赖。

负向验收 安全关键失败或无三平台CLI证据不能放行MVP；M4签名不是反向前置依赖。；NOT_RUN候选、缺资产或未证实本地/隔离能力不得标MVP通过；安全关键失败不能靠白名单扩大权限。

验证方法 重新安装候选版本演示；安全必阻断失败为零；质量基准与已知限制公开记录。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/00_scope.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

M4 桌面 Beta 与发布

本阶段 4 项任务。按 depends_on 拓扑推进；编号顺序不替代依赖关系。

OB-082 实现Tauri任务与审批UI

优先级 P1 规模 M 职责 Desktop 状态 TODO

前置依赖 OB-003、OB-081、OB-089

需求映射 RQ01、RQ06、RQ10

风险 HIGH / 桌面壳可能成为高权限token泄漏和执行绕过入口。

交付路径 apps/desktop；docs/desktop

相关组件 tauri；macos-permissions

复用方式 依赖适配

复用要求 Tauri v2受限Rust IPC复用，插件逐个准入；WebView无广域token/任意shell，窗口退出不停止daemon；不默认安装所有桌面插件。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 在Tauri Rust层实现固定白名单command调用本地API。；展示服务端快照、提案/影响范围、状态与取消/审批入口。；验证关闭重开、过期页面和token不进入WebView资源。；到M4锁定Tauri和实际使用插件，Rust只暴露白名单command；autostart只协调既有用户级生命周期，不启动第二daemon，也不为非GUI功能先索取屏幕权限。

正向验收 Tauri通过Rust受限command代理连接既有API；任务/审批/配置展示服务端状态；不把广域token放WebView或开放任意shell；只展示计划摘要和执行证据。

负向验收 不得暴露任意shell command；关闭窗口不得停daemon；不展示隐藏推理。；未审查的shell/fs插件capability不能进入WebView；不能因插件存在就把sidecar当已沙箱化。

验证方法 关闭/重开UI任务持续；旧页面审批会被版本校验拒绝；无命令字符串直达shell。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/02_architecture.md；docs/05_storage_api.md；docs/08_desktop_release.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-083 实现桌面接管与事件回放

优先级 P1 规模 M 职责 Desktop 状态 TODO

前置依赖 OB-016、OB-022、OB-075、OB-082

需求映射 RQ03、RQ10

风险 HIGH / 接管与回放竞态可能重复或误执行动作。

交付路径 apps/desktop/src/features/timeline；apps/desktop/src/features/takeover

相关组件 tauri

复用方式 自研控制语义

复用要求 SSE快照重取/只读回放/接管锁仍遵守daemon语义；插件事件不是权威状态。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现snapshot加SSE续订以及410后的快照重取。；实现接管pause和资源互斥，人工修改提升版本。；验证掉线、重放、旧页面批准和human/agent冲突。；Tauri/SSE客户端只呈现权威快照与只读事件，插件事件不改账本；SDK断线重试不能重复批准、接管或派发。

正向验收 使用snapshot加after_seq/Last-Event-ID恢复事件，过保留期410后重取；接管先暂停自动执行并获取资源锁，人工修改使旧proposal失效；回放只读。 UI关闭不改变daemon的资源归属，接管退出后须重取状态再决定恢复。

负向验收 事件回放不得重新执行工具；人工接管期间Agent不得继续点击或改写。

验证方法 掉线重连无漏终态；接管时自动任务不再点击/改写；回放只读不重做副作用。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/05_storage_api.md；docs/03_runtime_recovery.md；docs/02_architecture.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-073 实现版本升级和迁移恢复

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-011、OB-020、OB-030、OB-072、OB-080

需求映射 RQ02、RQ03、RQ11

风险 CRITICAL / 升级失败可能破坏唯一数据库或重复任务。

交付路径 services/core/src/openbot/update；docs/upgrade.md

相关组件 tauri

复用方式 依赖适配

复用要求 Tauri updater只做传输/签名校验，Drain/UNKNOWN处理/DB备份迁移/失败恢复自有；签名升级属M4。；在所属阶段通过组件准入后经Port/Adapter使用；第三方类型、隐式联网、重试与自动执行不能穿透到领域或事务层。

实施步骤 实现更新前drain、运行中操作核对和一致备份。；校验包与schema兼容，执行可恢复替换和迁移。；在下载/替换/迁移/重启失败点验证恢复及旧授权失效。；更新器只负责经验证的传输/签名等原语；OpenBot负责Drain、UNKNOWN核对、GC受保护备份、兼容迁移和失败恢复，组件升级改变工具语义需重新审查旧授权。

正向验收 M4更新先drain新任务、核对运行中操作、备份DB/manifest再迁移；签名校验与版本兼容明确；不兼容DB不能直接运行旧binary；可恢复安装状态不等于逆转外部效果。

负向验收 DB升级不兼容时不能直接降级binary；回滚安装不表示撤回外部动作。；不得由updater插件自动跳过在途效果核对，或新旧资源混装后继续使用旧Operation批准。

验证方法 在下载、替换、迁移、重启各点失败可恢复；待审批动作遇策略/工具变化重新审议。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/05_storage_api.md；docs/03_runtime_recovery.md；docs/02_architecture.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；

docs/12_component_reuse.md；docs/13_component_qualification.md

OB-074 完成桌面安装签名与发布供应链

优先级 P1 规模 M 职责 Platform 状态 TODO

前置依赖 OB-004、OB-072、OB-073、OB-082、OB-083

需求映射 RQ11、RQ12

风险 HIGH / 分发与更新链可成为代码注入入口。

交付路径 .github/workflows/release；dist/sbom.spdx.json；dist/SHA256SUMS；docs/releases

相关组件 tauri；sbom-tools；pyinstaller

复用方式 独立资格验证

复用要求 保留M4桌面签名、公证、更新信任根/通道；M3基础SBOM/来源与摘要前移到OB-096，不等桌面阶段。；本任务产生准入、反例或组合验证证据，不凭示例/import成功标记产品能力可用；未实测的真实能力继续NOT_RUN或不可用。

实施步骤 打包Tauri、daemon与supervisor并整理许可证/SBOM。；按目标OS完成签名/公证和更新签名校验，保管发布密钥。；验证篡改拒绝、测试通道隔离与显式stable发布步骤。；复用OB-096已完成的M3来源/SBOM/NOTICE基线，增加M4桌面签名、公证、更新信任根与通道；SBOM格式须与生成器真实输出一致。

正向验收 M4交付Tauri与daemon/supervisor整体安装产物，按目标OS签名/公证或明确实验状态；SBOM/许可证/checksum随版本；更新校验签名，stable promotion显式。 CycloneDX与SPDX明确标识，签名本身不替代漏洞/许可/资产核验。

负向验收 未签名或未公证产物不得冒充已认证；测试release不能自动晋升stable。；不得等本任务才首次核验MVP来源，或称cyclonedx-bom输出为SPDX。

验证方法 篡改包/错误签名更新失败；测试release不可自动进入stable通道；不会宣称已获认证。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/00_scope.md；docs/02_architecture.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

P2 后续扩展能力

本阶段 6 项任务。按 depends_on 拓扑推进；编号顺序不替代依赖关系。

OB-086 实现可验证记忆与删除

优先级 P2 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-024、OB-030、OB-037、OB-066

需求映射 RQ04、RQ06、RQ07

风险 HIGH / 长期记忆可持久化隐私或攻击指令。

交付路径 services/core/src/openbot/application/memory；docs/privacy.md

复用方式 自研控制语义

复用要求 未新增memory框架或向量库默认依赖；证据、删除、owner/workspace隔离自研。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 实现带owner/workspace/source/有效期的非向量记忆。；提供用户确认、更正、撤销和删除传播。；验证跨workspace隔离、注入内容和摘要事实的不确定性。

正向验收 P2记忆存owner/workspace/source/有效期/删除状态；仅可核对事实和确认偏好；不生成权限规则；删除后不召回，embedding另立ADR。

负向验收 记忆不能成为授权或跨workspace默认召回SENSITIVE；删除后不得继续召回旧事实。

验证方法 用户删除/更正后不再召回旧事实；跨workspace权限不泄漏；未证实摘要不当作用户授权。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/05_storage_api.md；docs/10_project_plan.md；docs/14_revision_v1_2.md

OB-027 补充Anthropic原生Provider

优先级 P2 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-025、OB-026、OB-092

需求映射 RQ07

风险 MEDIUM / 新增适配器可能破坏已有消息与费用语义。

交付路径 services/core/src/openbot/providers/anthropic.py

相关组件 model-anthropic；httpx；model-runner

复用方式 后续能力

复用要求 Anthropic仅P2基础请求API；禁止tool_runner及未经纳管的Provider托管工具、remote MCP和隐藏重试。；只在P2对应能力被实施时准入依赖；不得进入MVP默认runtime，也不得借组件自带循环扩大执行范围。

实施步骤 记录原生Anthropic API实际版本与能力差异。；适配ToolResult、停止原因、流和usage到统一Provider合同。；完成合约回归与受控真实模型证据，再标supported。；只允许审查过的基础messages.create/stream等请求API；禁

tool_runner、托管工具和remote MCP，关闭SDK内建重试并通过统一预算/egress。

正向验收 后续单独支持Anthropic原生Provider，映射ToolResult、usage、stop reason与stream，不把未测试API兼容性当作已支持。 P2才安装原生Anthropic组；官方SDK自动工具helper不能因官方来源被放行。

负向验收 不得用字符串拼接模拟结构消息或未经测试承诺兼容全部模型。；不得调用beta.messages.tool_runner或将可执行Python函数交给SDK自动循环；外部内容不能透传任意服务端工具配置。

验证方法 Provider合约全通过；真实smoke记录模型版本与成本；无默认额外回退。 fake HTTP验证实际请求数、取消后新请求为0与未知usage保留；canary函数审批前为0。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。；允许SDK API表与工具helper拒绝用例、请求/预算对应记录。

设计依据 docs/06_tools_providers.md；docs/09_testing_operations.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-084 为一个OS实现原生桌面观察

优先级 P2 规模 L 职责 Platform 状态 TODO

前置依赖 OB-002、OB-016、OB-037、OB-039、OB-042、OB-082、OB-089

需求映射 RQ06、RQ09、RQ11

风险 HIGH / 桌面观察含大量敏感信息且坐标不稳定。

交付路径 services/core/src/openbot/tools/desktop/observe；docs/desktop-capabilities

相关组件 native-gui；macos-permissions

复用方式 后续能力

复用要求 pywinauto/PyObjC/Portal等单OS选择；权限必须运行时检查并处理撤销，不依据报告声称固定每30天行为，不强绑Tauri。；只在P2对应能力被实施时准入依赖；不得进入MVP默认runtime，也不得借组件自带循环扩大执行范围。

实施步骤 只选一个OS实现控件树观察和必要截图权限检测。；统一window/display/frame/scale与观察版本，分类过滤截图数据。；测试多屏、DPI、锁屏、RDP及权限撤销，报告能力边界。；P2只选一个OS原生UIA/AX/Portal实现，按需审查pywinauto/PyObjC/权限插件；权限运行时可撤销，探测不依赖Tauri窗口存活。

正向验收 P2先单OS实现UIA/accessibility观察与必要截图，带display/window/frame/scale/有效期；权限撤销、锁屏或RDP状态明确不可用；数据按classification处理。 不用固定“每30天”规则推断权限有效；能力状态由实际API/会话/锁屏/远程桌面环境判定。

负向验收 截图可用不等于GUI控制可用；权限不足不能黑屏死循环或自动外发截图。；不得自动提前安装全部OS GUI库、复用UFO自治loop，或缺权限后持续黑屏重试。

验证方法 缩放/多屏/焦点变化可识别；权限不足不会黑屏死循环；截图不会默认发送云或飞书。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供至少一份实际声明平台/服务的受控集成证据及能力矩阵；mock结果单独列出，不能代替真实验证。

设计依据 docs/00_scope.md；docs/06_tools_providers.md；docs/04_security_approvals.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/11_decisions_evidence.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-085 实现受限桌面写动作

优先级 P2 规模 L 职责 Security 状态 TODO

前置依赖 OB-017、OB-018、OB-019、OB-084

需求映射 RQ03、RQ04、RQ09

风险 CRITICAL / GUI写动作难以可靠幂等且可影响任意用户账户。

交付路径 services/core/src/openbot/tools/desktop/action

相关组件 native-gui；model-runner

复用方式 后续能力

复用要求 只复用UIA/AX动作原语，逐动作审批/观察版本/互斥/UNKNOWN不变，不复用UFO推测性多动作自动提交。；只在P2对应能力被实施时准入依赖；不得进入MVP默认runtime，也不得借组件自带循环扩大执行范围。

实施步骤 定义绑定观察快照与目标窗口的桌面动作。；审批后复验焦点、坐标空间、目标语义和资源锁。；验证真实效果或转UNKNOWN，处理人类输入和页面漂移。；第三方UIA/AX库仅执行一次已批准原语；禁推测性多动作批处理和自治loop，helper不得在同一批准下继续下一步。

正向验收 P2桌面写绑定目标应用窗口、观察版本和坐标空间；执行前复验、一次一审；不能确认效果则UNKNOWN；human/agent互斥，不以截图坐标稳定为默认假设。

负向验收 窗口/缩放/目标变化必须拒绝旧动作；不可确认提交不能再点击一次。；不能以库返回成功、坐标未变或视觉文本代替效果核对，未知结果不得再次提交。

验证方法 窗口移动、DPI变化、焦点抢占、金额变化使旧动作失败；并发human与agent动作有互斥。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/06_tools_providers.md；docs/04_security_approvals.md；docs/03_runtime_recovery.md；docs/08_desktop_release.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-087 实现持久定时触发器

优先级 P2 规模 M 职责 Runtime 状态 TODO

前置依赖 OB-013、OB-014、OB-015、OB-023、OB-056、OB-089

需求映射 RQ03、RQ04

风险 HIGH / 自动触发增加用户不在场时的执行风险。

交付路径 services/core/src/openbot/application/schedules

相关组件 scheduling-libs

复用方式 后续能力

复用要求 croniter/触发器仅计算时间，zoneinfo/DST/misfire/occurrence唯一性自有；不启APScheduler自动executor，首次使用不下载时区等资源。；只在P2对应能力被实施时准入依赖；不得进入MVP默认runtime，也不得借组件自带循环扩大执行范围。

实施步骤 定义timezone/DST/misfire/catch-up与唯一occurrence合同。；定时器仅创建普通Task，继承预算/权限/审批和取消。；测试休眠、时钟变化、重启与停用schedule的未开始任务。；仅复用croniter或经过审查的触发器计算模块，固定时区资源；禁APScheduler后台executor，next_time与misfire决定由OpenBot生成持久occurrence。

正向验收 P2持久schedule明确时区、DST、misfire、catch-up与唯一occurrence；生成普通Task且走同一policy/审批；离线错过任务不会批量执行危险动作。 计算库不获得运行函数/调用Broker的权力；首次运行缺时区资源明确失败而非下载。

负向验收 错过触发不能批量执行危险动作；时钟回拨不能重复同一occurrence。；不得把调度库job store变为第二Task权威，或唤醒后自动补做所有高风险积压动作。

验证方法 休眠错过任务不突然批量执行危险动作；时钟变化不重复执行；停用schedule撤销未开始任务。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；保留关键故障注入或并发反例的状态快照、event/operation/attempt关联与实际副作用计数；证明没有盲目重执行。

设计依据 docs/00_scope.md；docs/03_runtime_recovery.md；docs/04_security_approvals.md；docs/09_testing_operations.md；docs/10_project_plan.md；docs/14_revision_v1_2.md；docs/12_component_reuse.md；docs/13_component_qualification.md

OB-088 评估第二设备和团队扩展边界

优先级 P2 规模 M 职责 Lead 状态 TODO

前置依赖 OB-080、OB-083

需求映射 RQ01、RQ04、RQ08、RQ11

风险 HIGH / 扩展会改变授权、队列和持久化的基本假设。

交付路径 docs/adr/future-multi-device.md；docs/adr/future-team.md

复用方式 自研控制语义

复用要求 第二设备/团队仍仅ADR实验，不为组件复用新增中央服务、共享gateway或权限模型。；权威状态、权限和副作用规则由OpenBot掌握；相关组件只能处理边界原语，不得取得直接派发或修改账本的权力。

实施步骤 以单设备基线为前提列第二设备/团队场景和身份边界。；验证显式设备路由、任务归属和审批绑定的小型实验。；形成是否引入中央队列/共享数据库的ADR，不默认启用。

正向验收 P2仅做第二设备/团队路由ADR与隔离实验；审批绑定设备与owner；多gateway竞争消费不等于广播；通过归属/队列证据后再决定中央服务。

负向验收 多个gateway竞争消费不能当广播；一个设备的批准不能授权另一个设备的新动作。

验证方法 只有设计与实验，无默认启用；证明任务归属后再决定是否需要中央队列或Postgres。

完成证据 提交本任务限定范围的文件变更清单；说明新增/修改的接口、状态与数据迁移。；提供验收与反例的可复现命令、环境/依赖版本、预期和实际结果；隐藏全部凭据。；提供可重复的正向用例和负向边界用例，记录任何未实现或受环境限制的能力。

设计依据 docs/00_scope.md；docs/02_architecture.md；docs/04_security_approvals.md；docs/10_project_plan.md；docs/14_revision_v1_2.md

OpenBot 需求与任务追踪矩阵

版本 1.2 · 2026年11月4日 · 12类需求 · 96项待实施任务

RQ01—RQ12继续沿用v1.1分类；既有AC-RQxx-01—03保留，新增AC-RQxx-04描述组件复用的验收增量。组件是实现选择，不据此增加用户产品功能或扩张23表/14API。任务全部TODO，真实组件资格初始NOT_RUN。

每个任务的完整字段、反例与证据见 TASKS.md 和 backlog.json；每次字段变化见 revision_delta.json。Q01—Q16的权威定义见 13_component_qualification.md，下表把它们连接到新旧任务。

用户场景到需求

场景	关联需求	主要证据
S01 代码诊断	RQ02、RQ04、RQ05、RQ06、RQ07、RQ08、RQ10、RQ12	来源路径/hash、诊断、不可变diff及未自动commit/push的证据。
S02 隔离验证	RQ03、RQ04、RQ05、RQ06、RQ08、RQ12	审批binding、输入快照、argv/镜像/权限、退出码与日志。
S03 长任务恢复	RQ01、RQ02、RQ03、RQ04、RQ08、RQ11、RQ12	崩溃点、持久状态、原审批版本、重启决定和副作用次数。
S04 取消与接管	RQ03、RQ04、RQ08、RQ10	cancel_revision、停止新dispatch、核对中的效果及资源锁。
S05 浏览器查阅	RQ04、RQ06、RQ09、RQ12	profile与page revision、origin/网络策略、结构数据和写动作receipt。
S06 离线工作	RQ03、RQ05、RQ06、RQ07、RQ10	模式/依赖组合同、真实model/runner禁云与受管出口证据；M0 fake验证与M3实际本地模型分列。

需求总览

需求ID	名称	关联任务数	首要阶段	新增门禁任务
RQ01	产品范围与生命周期	14	M0	OB-093
RQ02	持久化与数据一致性	16	M0	OB-090、OB-091
RQ03	调度恢复与预算	25	M0	OB-091、OB-092、OB-093
RQ04	身份策略与审批	26	M0	OB-090、OB-091
RQ05	工作区与隔离执行	19	M0	OB-093、OB-096
RQ06	隐私密钥与数据出口	26	M0	OB-092、OB-095

需求ID	名称	关联任务数	首要阶段	新增门禁任务
RQ07	模型上下文与技能	15	M0	OB-089、OB-090、OB-092、OB-096
RQ08	飞书远程闭环	16	M1	OB-092、OB-094
RQ09	浏览器与MCP受控接入	18	M0	OB-090、OB-092、OB-095、OB-096
RQ10	本地接口与用户控制	13	M0	原任务补强
RQ11	跨平台安装与更新	24	M0	OB-089、OB-093、OB-094、OB-095、OB-096
RQ12	可观测评测与工程交付	31	M0	OB-089、OB-090、OB-091、OB-092、OB-093、OB-094、OB-095、OB-096

RQ01

产品范围与生命周期

设计基线：00_scope.md；02_architecture.md；10_project_plan.md；11_decisions_evidence.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ01-01** 单owner、单profile、单设备与单活动gateway的默认范围明确；UI和网络连接不拥有任务权威状态。
2. **AC-RQ01-02** 用户级supervisor负责常驻生命周期与唯一实例；关闭UI不终止daemon，显式stop停止后续派发并清理workers。
3. **AC-RQ01-03** 模块依赖、能力边界和未支持平台有版本化合同；scope变更通过ADR同步任务和验收。
4. **AC-RQ01-04** 组件只能提供锁/进程/服务原语；profile排他锁有唯一持有者且父子不自锁；Windows用户登录会话单独验证，UI不拥有daemon生命周期。

必须阻断的反例

UI关闭不得停止常驻daemon；多gateway竞争消费不能被描述为广播；未测能力不得标supported。 父supervisor和daemon不得同时争抢同一profile排他锁；service-manager系统服务不能替代Windows用户会话。

阶段门槛与证据

M0范围与ADR评审；M1 OB-015/042/046生命周期证据；M4 OB-082关闭重开UI验证。 OB-093首发OS原语PoC先于生产锁/worker；其余OS由OB-069—071证明。

关联任务

ID	任务	阶段	复用职责
OB-001	冻结用户场景与MVP边界	M0	自研控制面
OB-003	冻结daemon与客户端生命周期	M0	原生原语适配

ID	任务	阶段	复用职责
OB-004	核验依赖和许可证	M0	准入与验证
OB-005	建立最小仓库和工具链	M0	准入与验证
OB-008	定义配置与网络模式	M0	依赖薄适配
OB-015	实现单实例daemon和调度租约	M1	原生原语适配
OB-042	实现worker进程树取消与回收	M1	原生原语适配
OB-046	发布最小本地Alpha边界说明	M1	准入与验证
OB-054	实现网关健康探测与重连	M2	依赖薄适配
OB-068	实现用户级daemon安装与卸载	M3	原生原语适配
OB-080	完成MVP发布验收与风险登记	M3	准入与验证
OB-082	实现Tauri任务与审批UI	M4	依赖薄适配
OB-088	评估第二设备和团队扩展边界	P2	自研控制面
OB-093	验证首发OS的Supervisor与隔离后端能力	M1	准入与验证

RQ02

持久化与数据一致性

设计基线：03_runtime_recovery.md；05_storage_api.md；09_testing_operations.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ02-01** inbox、权威状态、事件和outbox按规定事务提交；已提交任务可在进程崩溃后查询。
2. **AC-RQ02-02** 版本迁移、WAL与FULL配置、有限writer队列和磁盘故障处理可验证；不在数据库事务内等待网络或人工。
3. **AC-RQ02-03** 备份包含一致的数据库与Artifact清单；保留/清理不抹去未完成任务及仍被引用的授权证据。
4. **AC-RQ02-04** 严格JSON/JCS与深层不可变有标准向量；WriterCommand稳定request_id可关联持久结果，caller等待取消不等于事务回滚；备份期间Artifact有GC保护。

必须阻断的反例

提交失败不能ACK成功或继续派发；不得只复制.db遗漏WAL；事件回放不得重新运行工具。 aiosqlite await取消不证明rollback；备份不能删secret_ref或遗漏Artifact GC竞态。

阶段门槛与证据

M1 OB-011–014、OB-017/020/021/030；M3 OB-078/080汇总实际平台恢复与备份证明。 M0 OB-090/091先验证合同与故障；M1 writer真实提交和GC pin由OB-012/014/022/030验收。

关联任务

ID	任务	阶段	复用职责
OB-006	定义事件与命令协议	M0	依赖薄适配
OB-011	实现带版本的数据库迁移	M1	依赖薄适配
OB-012	实现串行写事务与数据库背压	M1	依赖薄适配
OB-013	实现持久inbox与作用域去重	M1	自研控制面
OB-014	实现任务状态与事件原子提交	M1	自研控制面
OB-017	实现动作意图与执行attempt日志	M1	自研控制面
OB-020	实现按副作用类型恢复	M1	自研控制面
OB-021	实现durable outbox及投递状态	M1	自研控制面
OB-029	交付首条持久化垂直切片	M1	准入与验证
OB-030	实现数据库备份恢复与保留策略	M1	依赖薄适配
OB-036	实现Artifact存储与可信元数据	M1	自研控制面
OB-049	实现飞书WebSocket入站适配	M2	依赖薄适配
OB-052	实现进度卡节流与更新顺序	M2	自研控制面
OB-073	实现版本升级和迁移恢复	M4	依赖薄适配
OB-090	验证Schema与JCS标准合同向量	M0	准入与验证
OB-091	交付最小claim/dispatch崩溃协议PoC	M0	准入与验证

RQ03

调度恢复与预算

设计基线：03_runtime_recovery.md；02_architecture.md；09_testing_operations.md；11_decisions_evidence.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ03-01** Task、Operation、Attempt分离；CLAIMED、DISPATCHING、UNKNOWN与Task RECONCILING语义确定；dispatch_id属于Attempt，provider_idempotency_key属于Operation。
2. **AC-RQ03-02** 重试按retry_class与证据决定；仅恢复器可复用同Operation的CONSUMED关系且复验原期限、policy、actor、cancel、resource；UNKNOWN外部动作不盲重发，人工说明不能直接改成success。
3. **AC-RQ03-03** CLAIMED到DISPATCHING第二短事务复验取消、epoch与resource；同Attempt重传ID不变、新Attempt新dispatch ID；预算仍采用预留后结算，旧worker不能继续派发。
4. **AC-RQ03-04** 模型/SDK/HTTP transport只有一个重试策略负责人，每次实际请求与预算可对应；M0协议PoC与M1完整切片分开，未知外部效果不以组件成功返回推断。

必须阻断的反例

UNKNOWN外部动作不得盲重试或由人工一句success覆盖；CONSUMED不得退APPROVED；同Attempt重传不能换dispatch ID，新Attempt不能复用旧dispatch ID；取消/epoch/resource必须在DISPATCHING事务再次检查。 SDK与tenacity不能叠加隐式请求；cancel后的隐藏新请求必须为0。

阶段门槛与证据

M1 OB-015–023/029/045；M3 OB-078长时故障；后续OB-087定时触发独立验收。 OB-091早期PoC；OB-092共享故障合同；SDK实际证据随OB-025/026/027及其他适配任务产生。

关联任务

ID	任务	阶段	复用职责
OB-009	统一错误与时钟语义	M0	自研控制面
OB-010	建立确定性系统测试夹具	M0	准入与验证
OB-012	实现串行写事务与数据库背压	M1	依赖薄适配
OB-014	实现任务状态与事件原子提交	M1	自研控制面
OB-015	实现单实例daemon和调度租约	M1	原生原语适配
OB-016	实现执行资源锁与会话排队	M1	自研控制面
OB-017	实现动作意图与执行attempt日志	M1	自研控制面
OB-019	实现执行前授权claim和再校验	M1	自研控制面
OB-020	实现按副作用类型恢复	M1	自研控制面
OB-022	实现取消和停止传播	M1	自研控制面
OB-023	实现任务预算和熔断	M1	依赖薄适配

ID	任务	阶段	复用职责
OB-029	交付首条持久化垂直切片	M1	准入与验证
OB-040	实现结构化进程执行协议	M1	自研控制面
OB-044	实现消息发送用例与受控适配端口	M1	自研控制面
OB-045	交付安全工具威胁回归	M1	准入与验证
OB-055	实现死信检视与安全重投	M2	自研控制面
OB-060	实现浏览器写动作提案与确认	M3	自研控制面
OB-073	实现版本升级和迁移恢复	M4	依赖薄适配
OB-078	建立断网休眠与崩溃浸泡	M3	准入与验证
OB-083	实现桌面接管与事件回放	M4	自研控制面
OB-085	实现受限桌面写动作	P2	后续阶段适配
OB-087	实现持久定时触发器	P2	后续阶段适配
OB-091	交付最小claim/dispatch崩溃协议PoC	M0	准入与验证
OB-092	建立组件副作用和重试取消故障契约	M1	准入与验证
OB-093	验证首发OS的Supervisor与隔离后端能力	M1	准入与验证

RQ04

身份策略与审批

设计基线：04_security_approvals.md；03_runtime_recovery.md；07_feishu.md；11_decisions_evidence.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ04-01** 身份由可信接入校验产生；配对需本地发起与最终确认；撤销后旧owner与旧卡不能继续授权。
2. **AC-RQ04-02** 提案binding覆盖身份、任务、工具、参数、资源、策略、TTL与nonce；批准、首次消费和执行结果分开；CONSUMED永不退APPROVED，安全重试只能由恢复器按原条件复验。
3. **AC-RQ04-03** ALLOW、ASK、DENY、REQUIRE_LOCAL由确定性代码判断；模型、外部文档及工具提示不能赋权或覆盖硬拒绝。
4. **AC-RQ04-04** Python构造权威canonical bytes，frozen不替代嵌套防护；同PENDING/version互斥决定最多一个成功，后续合法撤销仍能阻止未消费授权的claim/dispatch。

必须阻断的反例

外部is_owner/role、过期nonce、旧binding和变化参数必须拒绝；硬拒绝不能靠远程批准覆盖；CONSUMED不能二次消费、用于其他Operation或由客户端自行决定重用。 重复键、非法数值/Unicode、嵌套变异不得改变已批准内容；不提供客户端force-success。

阶段门槛与证据

M1 OB-018/019/031/045/081；M2 OB-048/050/056真实身份与审批；后续新工具继续复用。 OB-090标准合同向量，OB-091审批/派发反例；既有审批/恢复任务仍为生产权威。

关联任务

ID	任务	阶段	复用职责
OB-002	定义信任边界和动作副作用类别	M0	自研控制面
OB-018	实现审批决定与一次性授权	M1	依赖薄适配
OB-019	实现执行前授权claim和再校验	M1	自研控制面
OB-022	实现取消和停止传播	M1	自研控制面
OB-029	交付首条持久化垂直切片	M1	准入与验证
OB-031	实现确定性策略评估器	M1	自研控制面
OB-032	实现工作区路径与文件访问守卫	M1	原生原语适配
OB-034	实现补丁提议与受授权应用	M1	依赖薄适配
OB-037	实现统一数据外发策略	M1	自研控制面
OB-041	实现worker隔离与资源上限	M1	原生原语适配
OB-043	实现本地消息草稿	M1	自研控制面
OB-044	实现消息发送用例与受控适配端口	M1	自研控制面
OB-045	交付安全工具威胁回归	M1	准入与验证
OB-048	实现安全配对与owner撤销	M2	自研控制面
OB-050	实现飞书审批callback处理	M2	依赖薄适配
OB-060	实现浏览器写动作提案与确认	M3	自研控制面
OB-063	实现MCP注册与工具元数据锁定	M3	依赖薄适配
OB-064	实现MCP进程和网络权限	M3	依赖薄适配
OB-066	实现只读技能指令加载	M3	自研控制面

ID	任务	阶段	复用职责
OB-081	在M1实现认证本地HTTP与SSE控制API	M1	依赖薄适配
OB-085	实现受限桌面写动作	P2	后续阶段适配
OB-086	实现可验证记忆与删除	P2	自研控制面
OB-087	实现持久定时触发器	P2	后续阶段适配
OB-088	评估第二设备和团队扩展边界	P2	自研控制面
OB-090	验证Schema与JCS标准合同向量	M0	准入与验证
OB-091	交付最小claim/dispatch崩溃协议PoC	M0	准入与验证

RQ05

工作区与隔离执行

设计基线：06_tools_providers.md；04_security_approvals.md；08_desktop_release.md；09_testing_operations.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ05-01** 文件读取有范围和大小上限；propose_patch只产出草稿，apply_patch核对旧hash并保护用户已有改动。
2. **AC-RQ05-02** 任意解释器/测试/构建都视为代码执行；默认只在明确受控隔离后端执行，不静默回退宿主机。
3. **AC-RQ05-03** worker只得到一次dispatch的文件/网络/凭据能力；超时、取消和崩溃由supervisor回收并保留结果证据。
4. **AC-RQ05-04** rg/Git配置和hook、native grammar与容器独立生命周期纳入执行边界；stop/wait后校验导出再remove，多文件提交使用自身journal/partial恢复而非假定跨文件原子性。

必须阻断的反例

不得自动host回退、挂Docker socket/全HOME或覆盖用户脏改动；测试命令不天然只读。 禁止rg --pre、未审查Git hooks/filter、运行时下载grammar和仅kill容器CLI后宣布回收。

阶段门槛与证据

M1 OB-032–035/040–042/045/046；M3 OB-069–072原生平台与干净安装，能力边界据实标记。 OB-093先认证首发backend；OB-096核对实际执行资产，后期原生OS分别通过。

关联任务

ID	任务	阶段	复用职责
OB-002	定义信任边界和动作副作用类别	M0	自研控制面

ID	任务	阶段	复用职责
OB-007	定义工具和模型Provider契约	M0	自研控制面
OB-016	实现执行资源锁与会话排队	M1	自研控制面
OB-019	实现执行前授权claim和再校验	M1	自研控制面
OB-032	实现工作区路径与文件访问守卫	M1	原生原语适配
OB-033	实现list read search文件工具	M1	依赖薄适配
OB-034	实现补丁提议与受授权应用	M1	依赖薄适配
OB-035	实现显式语言验证与修改事务	M1	依赖薄适配
OB-040	实现结构化进程执行协议	M1	自研控制面
OB-041	实现worker隔离与资源上限	M1	原生原语适配
OB-042	实现worker进程树取消与回收	M1	原生原语适配
OB-045	交付安全工具威胁回归	M1	准入与验证
OB-046	发布最小本地Alpha边界说明	M1	准入与验证
OB-064	实现MCP进程和网络权限	M3	依赖薄适配
OB-069	建立macOS原生运行门禁	M3	准入与验证
OB-070	建立Windows原生运行门禁	M3	准入与验证
OB-071	建立Linux原生运行门禁	M3	准入与验证
OB-093	验证首发OS的Supervisor与隔离后端能力	M1	准入与验证
OB-096	验收全量交付资产来源与供应链	M3	准入与验证

RQ06

隐私密钥与数据出口

设计基线：04_security_approvals.md；05_storage_api.md；06_tools_providers.md；07_feishu.md；08_desktop_release.md；09_testing_operations.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ06-01** CONNECTED、LOCAL_MODEL、OFFLINE分别控制模型、飞书和工具网络；OFFLINE禁止外部连接。
2. **AC-RQ06-02** SECRET不进入模型或普通日志；SENSITIVE不自动发送云端或飞书；数据经过摘要、Artifact和通知仍保留限制。
3. **AC-RQ06-03** 凭据按用途最小注入；Artifact有hash、权限、大小与保留策略，诊断/导出经过脱敏和显式授权。
4. **AC-RQ06-04** 本地runner需model/禁云配置/实际egress证据，localhost不单独证明本地；扫描器运行时无网络验证，外部allowlist无效，扫描阴性不降低classification。

必须阻断的反例

OFFLINE不得连飞书或外部模型；SECRET不得进入模型/普通日志/默认诊断；摘要不能洗白数据分类。 禁止localhost转云、scanner在线验证和来自外部内容的allowlist；固定窗口不构成全面保密证明。

阶段门槛与证据

M1 OB-008/024/030/036–039/045/081；M2卡片与M3 Browser/MCP出口分别补真实证据。 M0 OB-008做配置/fake边界，M3 OB-026真实本地runner；OB-092/095分别验证组件/DOM出口。

关联任务

ID	任务	阶段	复用职责
OB-002	定义信任边界和动作副作用类别	M0	自研控制面
OB-008	定义配置与网络模式	M0	依赖薄适配
OB-024	实现上下文快照与摘要	M1	自研控制面
OB-025	实现首个云模型适配器	M1	依赖薄适配
OB-026	实现Ollama或第二Provider	M3	依赖薄适配
OB-030	实现数据库备份恢复与保留策略	M1	依赖薄适配
OB-033	实现list read search文件工具	M1	依赖薄适配
OB-036	实现Artifact存储与可信元数据	M1	自研控制面
OB-037	实现统一数据外发策略	M1	自研控制面
OB-038	实现密钥存储与最小注入	M1	依赖薄适配
OB-039	实现敏感数据输出过滤	M1	依赖薄适配
OB-041	实现worker隔离与资源上限	M1	原生原语适配
OB-043	实现本地消息草稿	M1	自研控制面
OB-044	实现消息发送用例与受控适配端口	M1	自研控制面
OB-045	交付安全工具威胁回归	M1	准入与验证

ID	任务	阶段	复用职责
OB-051	实现普通卡片与结果回执	M2	依赖薄适配
OB-057	实现专用浏览器profile与会话锁	M3	依赖薄适配
OB-058	实现浏览器网络与下载策略	M3	依赖薄适配
OB-064	实现MCP进程和网络权限	M3	依赖薄适配
OB-075	实现统一可观测性与诊断	M3	依赖薄适配
OB-081	在M1实现认证本地HTTP与SSE控制API	M1	依赖薄适配
OB-082	实现Tauri任务与审批UI	M4	依赖薄适配
OB-084	为一个OS实现原生桌面观察	P2	后续阶段适配
OB-086	实现可验证记忆与删除	P2	自研控制面
OB-092	建立组件副作用和重试取消故障契约	M1	准入与验证
OB-095	审查DOM提取脚本的最小源码复用	M3	源码参考/摘取审查

RQ07

模型上下文与技能

设计基线：06_tools_providers.md；00_scope.md；09_testing_operations.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ07-01** M1具备一个Provider适配合同；完整MVP至少一个云Provider与一个本地Provider，能力差异明确。
2. **AC-RQ07-02** 半包或畸形tool call不执行；调用用量与错误可追踪；模型重试不会触发重复工具效果或隐式云回退。
3. **AC-RQ07-03** 上下文、摘要和技能保留来源与用户约束；模型文字和学习到的偏好不能变成授权。
4. **AC-RQ07-04** SDK只用获准基础请求API；禁止tool_runner、未纳管Provider托管工具/remote MCP；tokenizer按模型预估并预置资产，未知usage保守保留。

必须阻断的反例

半包/畸形工具调用不能执行；Provider重试不能重放工具；未知能力不能伪装成功。 官方SDK自动helper、任意extra_body/extra_headers和Provider托管执行不得穿透Broker。

阶段门槛与证据

M1 OB-007/023–025；M3 OB-026/066/067/076；OB-027第三Provider后续独立验收。 OB-089分组准入、OB-090完整Schema、OB-092唯一重试/自动执行反例，OB-096发布tokenizer等资产。

关联任务

ID	任务	阶段	复用职责
OB-007	定义工具和模型Provider契约	M0	自研控制面
OB-023	实现任务预算和熔断	M1	依赖薄适配
OB-024	实现上下文快照与摘要	M1	自研控制面
OB-025	实现首个云模型适配器	M1	依赖薄适配
OB-026	实现Ollama或第二Provider	M3	依赖薄适配
OB-027	补充Anthropic原生Provider	P2	后续阶段适配
OB-059	实现结构化浏览器读工具	M3	依赖薄适配
OB-066	实现只读技能指令加载	M3	自研控制面
OB-067	交付全MVP能力集回归	M3	准入与验证
OB-076	建立真实任务质量基准集	M3	准入与验证
OB-086	实现可验证记忆与删除	P2	自研控制面
OB-089	建立组件准入目录和分阶段依赖门禁	M0	准入与验证
OB-090	验证Schema与JCS标准合同向量	M0	准入与验证
OB-092	建立组件副作用和重试取消故障契约	M1	准入与验证
OB-096	验收全量交付资产来源与供应链	M3	准入与验证

RQ08

飞书远程闭环

设计基线：00_scope.md；02_architecture.md；04_security_approvals.md；05_storage_api.md；07_feishu.md；09_testing_operations.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ08-01** 单gateway将经过校验的入站交给daemon，提交成功后才确认；重复/乱序事件只产生一个逻辑任务。
2. **AC-RQ08-02** 消息事件与审批callback分开处理；同步响应不等待模型；普通卡片基线可用，更新具有顺序、节流与降级。
3. **AC-RQ08-03** 重连、网络半开、休眠、死信和外发结果不明均可诊断；冷启动、WS连接与callback响应分别度量。
4. **AC-RQ08-04** 锁定SDK真实协议与分段启动/回调证据；hard deadline位于可能阻塞进程之外；模板NO_COPY或有限摘取不改变owner、CAS、outbox权威。

必须阻断的反例

gateway不能自定owner或直连DB；数据库提交失败不能回复已批准；迟到进度不能覆盖终态。 不能套用固定冷启动数字/所有卡片通用时限，也不能在旧gateway未退出时重建第二消费者。

阶段门槛与证据

M1 inbox/outbox端口；M2 OB-047–056真实租户整体验证；M3 OB-078浸泡。 OB-094明确NO_COPY或有限摘取；OB-047/054分别核对版本事实和进程外监督。

关联任务

ID	任务	阶段	复用职责
OB-013	实现持久inbox与作用域去重	M1	自研控制面
OB-021	实现durable outbox及投递状态	M1	自研控制面
OB-047	核验飞书真实租户协议与权限	M2	准入与验证
OB-048	实现安全配对与owner撤销	M2	自研控制面
OB-049	实现飞书WebSocket入站适配	M2	依赖薄适配
OB-050	实现飞书审批callback处理	M2	依赖薄适配
OB-051	实现普通卡片与结果回执	M2	依赖薄适配
OB-052	实现进度卡节流与更新顺序	M2	自研控制面
OB-053	实现CardKit与更新通道降级	M2	依赖薄适配
OB-054	实现网关健康探测与重连	M2	依赖薄适配
OB-055	实现死信检视与安全重投	M2	自研控制面
OB-056	飞书端到端真实验收	M2	准入与验证
OB-067	交付全MVP能力集回归	M3	准入与验证
OB-088	评估第二设备和团队扩展边界	P2	自研控制面
OB-092	建立组件副作用和重试取消故障契约	M1	准入与验证
OB-094	审查飞书模板的最小源码复用	M2	源码参考/摘取审查

RQ09

浏览器与MCP受控接入

设计基线：06_tools_providers.md；04_security_approvals.md；03_runtime_recovery.md；09_testing_operations.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ09-01** 专用浏览器profile与page revision控制会话和动作；写操作绑定目标、输入与页面版本，外部结果需要证据。
2. **AC-RQ09-02** 导航、重定向、上传下载和子请求遵守网络/数据策略；无法强制所需边界时能力不可用。
3. **AC-RQ09-03** MVP先支持固定版本stdio MCP；安装与运行分离，工具元数据变化隔离；外部annotations不直接决定权限或重试。
4. **AC-RQ09-04** Chromium sandbox显式配置并验证，Service Worker绕过路由须阻断或由独立网络边界覆盖；完整MCP manifest、受限stdio与本地Schema refs不因SDK默认值放宽。

必须阻断的反例

不得复制默认浏览器profile、沿用变化页面的旧批准或在任务运行中安装MCP latest；未知效果不能再提交。 不得暗加--no-sandbox或仅靠BrowserContext.route / Page.route声称强隔离；DOM源码参考不能引入自治循环。

阶段门槛与证据

M3 OB-057–065/067；原生GUI在P2 OB-084/085独立验收，不能计入MVP已实现能力。 OB-095源码比较决定，OB-090/092共享合同，OB-096核对浏览器/MCP及grammar资产。

关联任务

ID	任务	阶段	复用职责
OB-007	定义工具和模型Provider契约	M0	自研控制面
OB-016	实现执行资源锁与会话排队	M1	自研控制面
OB-057	实现专用浏览器profile与会话锁	M3	依赖薄适配
OB-058	实现浏览器网络与下载策略	M3	依赖薄适配
OB-059	实现结构化浏览器读工具	M3	依赖薄适配
OB-060	实现浏览器写动作提案与确认	M3	自研控制面
OB-061	建立浏览器结果验证回归	M3	准入与验证
OB-062	实现MCP版本协商与生命周期	M3	依赖薄适配
OB-063	实现MCP注册与工具元数据锁定	M3	依赖薄适配
OB-064	实现MCP进程和网络权限	M3	依赖薄适配

ID	任务	阶段	复用职责
OB-065	建立MCP恶意与故障服务器测试	M3	准入与验证
OB-067	交付全MVP能力集回归	M3	准入与验证
OB-084	为一个OS实现原生桌面观察	P2	后续阶段适配
OB-085	实现受限桌面写动作	P2	后续阶段适配
OB-090	验证Schema与JCS标准合同向量	M0	准入与验证
OB-092	建立组件副作用和重试取消故障契约	M1	准入与验证
OB-095	审查DOM提取脚本的最小源码复用	M3	源码参考/摘取审查
OB-096	验收全量交付资产来源与供应链	M3	准入与验证

RQ10

本地接口与用户控制

设计基线：02_architecture.md；05_storage_api.md；03_runtime_recovery.md；08_desktop_release.md；10_project_plan.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ10-01** M1即提供认证loopback HTTP与SSE；Host、Origin、profile范围、大小限制和受保护token传递得到验证。
2. **AC-RQ10-02** CLI/gateway调用application/API，不直连DB；用户可查看、批准、取消、恢复并提交核对证据，不能以指定success覆盖账本或自行允许CONSUMED复用。
3. **AC-RQ10-03** M4 Tauri通过受限接口展示计划摘要、提案、策略和执行证据；重连与接管不重放工具或显示隐藏推理。
4. **AC-RQ10-04** API/CLI/UI组件只提供传输和呈现；严格输入、Host/Origin/proxy/scope、SSE游标/背压和writer断连后持久结果均能核对；不要求UI重复实现权威JCS。

必须阻断的反例

跨源/非loopback/错profile请求必须拒绝；WebView不持广域token；客户端不得绕过application，reconcile不得接收force-success或grant恢复许可。 框架默认CORS/proxy/Schema处理不得扩大owner权限；终端输出不能注入控制序列或伪造审批。

阶段门槛与证据

M1 OB-081先于OB-028/029；M2 gateway接入；M4 OB-082/083桌面观察与接管。 OB-081复用标准校验和API框架，OB-090以Python权威端验证；窗口退出不改daemon。

关联任务

ID	任务	阶段	复用职责
OB-006	定义事件与命令协议	M0	依赖薄适配
OB-009	统一错误与时钟语义	M0	自研控制面
OB-028	提供CLI任务和审批操作	M1	依赖薄适配
OB-029	交付首条持久化垂直切片	M1	准入与验证
OB-046	发布最小本地Alpha边界说明	M1	准入与验证
OB-048	实现安全配对与owner撤销	M2	自研控制面
OB-049	实现飞书WebSocket入站适配	M2	依赖薄适配
OB-055	实现死信检视与安全重投	M2	自研控制面
OB-075	实现统一可观测性与诊断	M3	依赖薄适配
OB-079	完成上手与故障处置文档	M3	准入与验证
OB-081	在M1实现认证本地HTTP与SSE控制API	M1	依赖薄适配
OB-082	实现Tauri任务与审批UI	M4	依赖薄适配
OB-083	实现桌面接管与事件回放	M4	自研控制面

RQ11

跨平台安装与更新

设计基线：00_scope.md；02_architecture.md；05_storage_api.md；08_desktop_release.md；10_project_plan.md；11_decisions_evidence.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ11-01** 基础合同从M0运行三OS CI；M3在macOS、原生Windows、Linux分别验证CLI和所声明能力，未通过不标supported。
2. **AC-RQ11-02** 安装器声明Python/浏览器/隔离后端依赖，用户级服务可启停/卸载，不能误删工作区或秘密数据。
3. **AC-RQ11-03** M4签名与升级流程校验产物、先drain和备份再迁移；数据库不兼容时不能盲降级旧程序。
4. **AC-RQ11-04** 按阶段准入并锁定包与非包资产，M3全量SBOM/NOTICE/hash/离线首用已经完成；M4桌面签名独立，不借SDK或安装器的跨平台名称冒称原生资格。

必须阻断的反例

WSL不能替代Windows原生资格；未签名产物不能称已签名；不兼容DB不能直接降级旧binary。 M0不得整包安装后续候选；不能混淆SPDX/CycloneDX、漏非Python资产或把未签名包称签名Beta。

阶段门槛与证据

M0 OB-005基础矩阵；M3 OB-068–072与OB-080完整CLI安装；M4 OB-073/074更新签名。 M0 OB-089、M1 OB-093、M2 OB-094、M3 OB-095/096随阶段落地，禁止M0一次预装全部候选。

关联任务

ID	任务	阶段	复用职责
OB-003	冻结daemon与客户端生命周期	M0	原生原语适配
OB-004	核验依赖和许可证	M0	准入与验证
OB-005	建立最小仓库和工具链	M0	准入与验证
OB-030	实现数据库备份恢复与保留策略	M1	依赖薄适配
OB-038	实现密钥存储与最小注入	M1	依赖薄适配
OB-042	实现worker进程树取消与回收	M1	原生原语适配
OB-068	实现用户级daemon安装与卸载	M3	原生原语适配
OB-069	建立macOS原生运行门禁	M3	准入与验证
OB-070	建立Windows原生运行门禁	M3	准入与验证
OB-071	建立Linux原生运行门禁	M3	准入与验证
OB-072	建立可复现打包与运行资源清单	M3	准入与验证
OB-073	实现版本升级和迁移恢复	M4	依赖薄适配
OB-074	完成桌面安装签名与发布供应链	M4	准入与验证
OB-077	建立分层CI门禁	M3	准入与验证
OB-078	建立断网休眠与崩溃浸泡	M3	准入与验证
OB-079	完成上手与故障处置文档	M3	准入与验证
OB-080	完成MVP发布验收与风险登记	M3	准入与验证
OB-084	为一个OS实现原生桌面观察	P2	后续阶段适配
OB-088	评估第二设备和团队扩展边界	P2	自研控制面
OB-089	建立组件准入目录和分阶段依赖门禁	M0	准入与验证

ID	任务	阶段	复用职责
OB-093	验证首发OS的Supervisor与隔离后端能力	M1	准入与验证
OB-094	审查飞书模板的最小源码复用	M2	源码参考/摘取审查
OB-095	审查DOM提取脚本的最小源码复用	M3	源码参考/摘取审查
OB-096	验收全量交付资产来源与供应链	M3	准入与验证

RQ12

可观测评测与工程交付

设计基线：00_scope.md；01_gap_review.md；03_runtime_recovery.md；05_storage_api.md；06_tools_providers.md；09_testing_operations.md；10_project_plan.md；11_decisions_evidence.md；12_component_reuse.md；13_component_qualification.md；14_revision_v1_2.md。

验收条款

1. **AC-RQ12-01** 关键边界在M1/M2随功能测试，不拖至发布前；PR、nightly和release门禁按风险分层。
2. **AC-RQ12-02** 真实任务基准区分安全、协议和模型能力；记录样本、版本、成功/部分/失败/待核对结果、成本和延迟。
3. **AC-RQ12-03** 任务具备依赖、反例和证据；仓库接口与迁移有owner，交接文件、运行手册和风险登记可以独立复现。
4. **AC-RQ12-04** 组件选择、当前真实资格NOT_RUN/证据、复用边界与变更delta可追踪；只重跑受影响门禁，不以LOC、Stars、固定倍数或工期承诺代替测量。

必须阻断的反例

mock不代表真实能力；模型final不代表效果完成；不得删除门禁或扩大权限换取“通过”。 审阅源码不等于真实环境测试；NOT_RUN不能被文档完成、import成功或fake通过自动改成资格通过。

阶段门槛与证据

各阶段随任务提交证据；M1 OB-029/045、M2 OB-056、M3 OB-076–080组成集成与发布门槛。 OB-089—096提供独立门禁；每次变更记录受影响Q项，NO_COPY无须虚构vendor测试。

关联任务

ID	任务	阶段	复用职责
OB-001	冻结用户场景与MVP边界	M0	自研控制面
OB-004	核验依赖和许可证	M0	准入与验证
OB-005	建立最小仓库和工具链	M0	准入与验证
OB-010	建立确定性系统测试夹具	M0	准入与验证
OB-029	交付首条持久化垂直切片	M1	准入与验证

ID	任务	阶段	复用职责
OB-035	实现显式语言验证与修改事务	M1	依赖薄适配
OB-039	实现敏感数据输出过滤	M1	依赖薄适配
OB-045	交付安全工具威胁回归	M1	准入与验证
OB-046	发布最小本地Alpha边界说明	M1	准入与验证
OB-047	核验飞书真实租户协议与权限	M2	准入与验证
OB-054	实现网关健康探测与重连	M2	依赖薄适配
OB-056	飞书端到端真实验收	M2	准入与验证
OB-061	建立浏览器结果验证回归	M3	准入与验证
OB-065	建立MCP恶意与故障服务器测试	M3	准入与验证
OB-067	交付全MVP能力集回归	M3	准入与验证
OB-072	建立可复现打包与运行资源清单	M3	准入与验证
OB-074	完成桌面安装签名与发布供应链	M4	准入与验证
OB-075	实现统一可观测性与诊断	M3	依赖薄适配
OB-076	建立真实任务质量基准集	M3	准入与验证
OB-077	建立分层CI门禁	M3	准入与验证
OB-078	建立断网休眠与崩溃浸泡	M3	准入与验证
OB-079	完成上手与故障处置文档	M3	准入与验证
OB-080	完成MVP发布验收与风险登记	M3	准入与验证
OB-089	建立组件准入目录和分阶段依赖门禁	M0	准入与验证
OB-090	验证Schema与JCS标准合同向量	M0	准入与验证
OB-091	交付最小claim/dispatch崩溃协议PoC	M0	准入与验证
OB-092	建立组件副作用和重试取消故障契约	M1	准入与验证

ID	任务	阶段	复用职责
OB-093	验证首发OS的Supervisor与隔离后端能力	M1	准入与验证
OB-094	审查飞书模板的最小源码复用	M2	源码参考/摘取审查
OB-095	审查DOM提取脚本的最小源码复用	M3	源码参考/摘取审查
OB-096	验收全量交付资产来源与供应链	M3	准入与验证

组件资格场景到任务

Q场景按所在阶段运行实际实现，M0的合同/夹具不会提前安装后续组件。NO_COPY只需明确比较与理由；摘取专属测试只有选择实际摘取时适用。

Q ID	验证主题	时点	任务
Q01	最小依赖、导入/首次使用与离线资产	M0合同；后续实际组件随阶段	OB-005、OB-008、OB-072、OB-089、OB-092
Q02	严格JSON与标准JCS向量	M0；生产binding随M1/M3	OB-006、OB-007、OB-018、OB-063、OB-090
Q03	深层不可变、完整Schema/format/refs	M0；API和MCP接入时复验	OB-006、OB-007、OB-081、OB-090
Q04	模型请求重试、预算、本地runner转云	M1云；M3本地；P2原生Anthropic	OB-023、OB-025、OB-026、OB-027、OB-092
Q05	writer、caller取消、迁移/备份/GC pin	M0协议；M1生产	OB-011、OB-012、OB-013、OB-014、OB-018、OB-019、OB-020、OB-022、OB-030、OB-091
Q06	路径、rg/Git配置、补丁、partial提交	M1	OB-032、OB-033、OB-034、OB-035
Q07	native parser、资产与有界worker	M1；M3三OS发行	OB-035、OB-041、OB-093、OB-096
Q08	容器隔离、独立归属、导出与清理	M1	OB-040、OB-041、OB-042、OB-093
Q09	原生锁/Job/进程树/用户会话	M1首发；M3三OS	OB-015、OB-042、OB-068、OB-069、OB-070、OB-071、OB-093
Q10	飞书SDK/外部watchdog/真实回调	M2	OB-047、OB-049、OB-050、OB-051、OB-052、OB-053、OB-054、OB-055、OB-056
Q11	Browser sandbox/SW/页面绑定/UNKNOWN	M3	OB-057、OB-058、OB-059、OB-060、OB-061、OB-095

Q ID	验证主题	时点	任务
Q12	MCP协议/环境/定义固定/恶意server	M3	OB-062、OB-063、OB-064、OB-065、OB-092
Q13	跨chunk、scanner离线/allowlist、日志	M1；M3观测汇总	OB-037、OB-038、OB-039、OB-075、OB-092
Q14	来源比较、NO_COPY或有限摘取	M0规则；M2/M3来源决定	OB-004、OB-051、OB-059、OB-089、OB-094、OB-095
Q15	全生态锁、非包资产、SBOM/NOTICE	M0记录；M3发布；M4签名增量	OB-066、OB-072、OB-073、OB-074、OB-089、OB-096
Q16	早期claim/dispatch协议PoC与M1切片	M0 PoC；M1完整集成	OB-010、OB-017、OB-018、OB-019、OB-020、OB-029、OB-090、OB-091

新报告到工程验收的增量

页码为U3《OpenBot 开源组件复用评估》PDF物理页码。下表将候选建议、修订及可检查证据分开，具体官方来源和事实核验见docs/12—14。

U3位置与主题	修订	任务及证据
p1—3、21、26：自研控制面	保留四对象/两事务/UNKNOWN/egress，增最早协议PoC	OB-017—022、091；持久状态与效果计数
p7、20—21：Pydantic/JCS/Schema	UTF-16标准向量、深层不可变、重复键/完整Schema/format/本地refs；Python权威	OB-006/007/018/063/090；规范字节与拒绝用例
p7、20—21：异步SQLite与backup	完整WriterCommand独占、稳定请求ID、取消后持久重查、Artifact GC pin和secret_ref有效性	OB-011/012/014/022/030；并发/提交/GC反例
p8—9、16、21—22：官方SDK与重试	API白名单、SDK/transport重试关闭、统一预算、禁tool_runner/托管工具；本地runner另验云路由	OB-008/023/025—027/037/092；HTTP尝试计数与实际egress
p12、17、22：ACI与grammar	rg --no-config/禁--pre；Git hooks/filter；确切新字节hash；有界native parser和安装期资产	OB-032—035/040/045/096；canary、journal与禁网首parse
p9—10、23：飞书SDK/社区模板	真实版本/分段计时/外部watchdog；模板NO_COPY或有限摘取	OB-047—056/094；真实payload、回调和来源决定
p12—14、18、23、25：进程/容器/服务	原语逐OS验证、唯一锁所有者、容器独立stop/wait→导出校验→remove、Windows用户会话单独设计	OB-015/041/042/068—072/093；进程/容器归属证据
p13、18、24：Browser/MCP	Chromium sandbox、Service Worker边界、完整manifest/受限stdio；DOM允许NO_COPY	OB-057—065/095；实际网络/页面效果和恶意server
p14、18—19、22—23：脱敏/观测	禁scanner网络验证、外部allowlist；跨chunk和最小出口，拒绝100%保证	OB-037—039/075/092；合成canary与观察范围

U3位置与主题	修订	任务及证据
p19、25—26：全量M0安装/供应链	阶段分组，完整资产锁/NOTICE，M3 SBOM区分格式；桌面签名仍M4	OB-004/005/072/074/089/096；包/非包资产对应

v1.1原缺口继续保持的闭环

原材料问题	持续保留的修正	任务
U2 p27 把状态机/预算/Provider合成大工作包	分别合同、权威状态、预算、上下文与适配器，逐项失败证据	OB-007/014/023—027
U2 p28 Browser/MCP共用验收	浏览器页面效果与MCP恶意server独立；接同一Broker	OB-057—065
U2 p29—30 审批CAS与执行一次混淆	CONSUMED不可逆、Attempt/Operation键分离、第二事务复验、UNKNOWN证据核对	OB-017—022/029/045
U1长期daemon与U2 p24/31 UI退出杀全树矛盾	用户级supervisor托管，UI退出不停止daemon；真实原生清理	OB-003/015/042/068/082
原WBS未安排最早认证本地API	M1 OB-081作为CLI/gateway前置，不拖到桌面阶段	OB-081→OB-028/049
原打包未覆盖完整安装/数据恢复	M3三OS CLI与备份，M4桌面签名升级单独验证	OB-030/068—074/080

一致性核验

96项任务全部关联至少一类RQ，RQ01—RQ12无空项；48条命名AC包含原36条及12条组件增量。Q01—Q16均有明确任务和证据入口。M0=13、M1=37、M2=11、M3=25、M4=4、P2=6。

原88个ID和阶段保留、原依赖未删除；拓扑排序96/96，无环、无缺失依赖或跨阶段逆向边。OB-034拥有自己的最小安全提交journal，不依赖其后续OB-035才能完成；OB-008不要求M0实测M3模型；OB-096不依赖M4。

这些是设计结构检查，不能代替真实源码、OS、租户、模型、隔离或签名资格。

AI 编码启动与交接

首次交给编码助手的提示

请以当前目录中的OpenBot v1.2工程设计包为基线开始实施。

先读取README.md、AGENTS.md、docs/00_scope.md、docs/02_architecture.md、docs/10_project_plan.md、docs/12_component_reuse.md、docs/14_revision_v1_2.md、tasks/backlog.json与components/catalog.json。只读检查现有仓库；如已有实现，先列出与基线的差异，不覆盖已有工作。

本轮完成OB-001至OB-005和依赖满足的OB-089；按依赖顺序推进。目标是冻结范围/威胁模型/生命周期、记录当前所需组件的来源/许可证与阶段准入、建立能运行验证的最小Python仓库和CI骨架。不要在M0一次安装所有候选；Browser、MCP、Tauri与P2重依赖在对应任务再引入。

保持以下不变量：daemon与UI分离；所有副作用经Broker；Task/Operation/Approval/Attempt分开；结果未知不能盲重试；模型与外部内容不能赋权；没有隔离后端不降级host执行。接口或状态有疑问先记录ADR，不能悄悄改语义。

交付本轮真实代码与文档、实际运行的检查命令和结果、没有验证的环境、更新后的任务证据。所有任务状态必须依据仓库真实产物；不得把设计包现有文档或SQL直接当作应用完成证据。

完成本轮门禁后报告实际结果。下一批做OB-006至OB-010、OB-090标准合同向量和OB-091最小协议PoC；OB-029继续作为M1真实API与隔离路径的集成门禁。若用户已要求持续实施，请转prompts/05_autonomous_project.md连续推进，不为每个常规步骤重复询问。

单任务执行模板

本轮任务ID为：填写一个tasks/backlog.json中的稳定ID。

请读取该任务、depends_on任务的实际验证证据、相关design_refs和AGENTS.md。先检查当前代码，说明本轮会修改的模块与输出，不扩展到没有授权的功能。

按implementation_steps实现，满足acceptance与negative_acceptance。涉及持久化、审批、恢复或外部副作用时，加入与实际风险对应的失败测试；不要为简单可逆改动堆无价值测试。

不得修改权限边界、删除失败测试或用mock成功掩盖实际未实现功能。遇到合同冲突，记录具体问题与建议，先完成不受影响的部分。只有真实外部服务或平台环境不可用才标BLOCKED，并给出已完成部分和最小缺失条件。

最后输出：任务ID、修改摘要、实际命令和结果、负向场景证据、未跑验证、风险、任务状态建议。不要自动发布或发送消息。

v1.2组件要求

读取本任务component_refs、reuse_type、reuse_notes及components/catalog.json。只引入当前任务必要组件，记录精确版本与相关Q场景证据；官方SDK同样检查重试、自动工具helper与网络出口。候选和源码参考不因被引用就自动获准安装或复制。

独立评审模板

请仅评审当前任务实现与OpenBot设计基线的差异。读取AGENTS.md、相关任务卡、git diff、实际测试结果和相关contracts。不要先修改代码或重构无关模块。

优先检查：模型/渠道能否绕过Broker；身份是否来自外部字段；批准与claim是否混淆；CONSUMED是否复活；dispatch和provider幂等键是否混用；DISPATCHING前是否复核取消；UNKNOWN是否被自动重放；数据库事务与outbox是否原子；隔离器是否实际限制资源；是否误报真实平台能力。

按严重度给出可定位的问题、触发路径、影响、最小修复和复验建议。没有发现问题时也说明已核对范围、未验证环境与剩余风险。不得仅因为测试通过就判定安全。

v1.2复用审查

检查依赖阶段、源码来源与许可、实际SDK API面、隐藏重试、首用下载、环境与子进程、取消后的未知结果、非Python资产和平台证据。特别查frozen嵌套漂移、localhost转云、rg/Git隐藏执行、parser下载、容器独立生命周期和脱敏网络验证；不以文档推荐或mock通过替代实测。

阶段交接模板

阶段或任务范围： 当前commit与分支： 真实完成的用户场景： 已通过的验收及原始证据： 未通过或未运行的验收： 接口、schema、migration和依赖版本变化： 已知缺陷与风险： UNKNOWN或待核对的外部结果： 下一个可启动的任务及依赖： 恢复当前开发环境所需的命令： 凭据只写引用位置，不填写值：

下一编码助手先核对这些信息与仓库实际状态，再接续任务。不得把前一助手的文字总结替代实际代码和测试。

v1.2交接补充

同时交接组件目录变更、精确依赖/资产锁、准入证据、上游补丁及NO_COPY决定。明确哪些是文档核验、哪些是真实运行；保存当前96任务ID、实际状态和阻塞条件，供下一助手按DAG继续。

持续实施到MVP的交接提示

请按当前目录的OpenBot v1.2工程设计包实施到M3产品MVP。先读取README.md、AGENTS.md、docs/00_scope.md、docs/10_project_plan.md、docs/12_component_reuse.md、docs/13_component_qualification.md、docs/14_revision_v1_2.md、components/catalog.json和tasks/backlog.json，检查真实仓库状态，再从第一个依赖满足的TODO任务开始。任务总数96，保持原ID，不因文档或SQL存在就标记DONE。

先完成M0的组件目录、标准合同向量与OB-091最小崩溃协议PoC，之后按DAG连续推进。M1优先降低SDK副作用和首发OS隔离风险，再通过OB-029正式集成门禁。每个任务保持独立可审查的改动，实际跑验收，记录证据后再选下一项。常规可逆的本地实现、修复、测试和集成不必每完成一个小步骤就停下来询问。每个里程碑输出实际通过与未通过的门禁。

每轮读取component_refs、reuse_type与reuse_notes；按catalog的采用层级处理，不在M0全量安装候选。版本、许可证、非Python资产与真实副作用都要验证。源码审查可以决定NO_COPY。真实组件资格不得由目录里的NOT_RUN模板改名伪造。

SDK自动重试与应用重试不能叠加；不调用官方或第三方自动工具运行器；模型提出动作后仍由Broker授权。Ollama localhost不证明本地推理，grammar/词表不得运行期下载。不要用128字节窗口、单一regex、Drop或进程组宣称100%安全。

你可以并行分配互不改同一文件的工作包，并使用独立worktree。schema、迁移编号、锁文件、公共接口与安全策略由一个Integrator负责。集成后必须重新验证真实合并结果。

Task、Operation、Approval、Attempt四个概念不能合并。CONSUMED不可复活，dispatch_id属于Attempt，provider幂等键属于Operation。审批预览不能泄露内部提案和SECRET；任何UNKNOWN须保留资源quarantine并核对，不允许换ID重发。所有副作用经Broker，无隔离后端不得降级宿主执行。

遇到缺少真实飞书租户、模型凭据、OS机器或签名环境时，完成能独立实现和验证的部分，把受影响任务标BLOCKED并明确最小缺失条件，继续其他就绪任务。不要伪造真实服务通过结果，不为了通过测试放宽策略。

本次范围是代码实现与验收。生产部署、正式发布、对真实第三方发送内容或破坏性数据操作必须依据用户另行给出的具体授权。需要交接或结束时更新任务状态、证据、风险和下一任务，保证另一个编码助手能够从仓库真实状态继续。

单个组件接入与升级提示

请在当前已就绪任务范围内接入或升级指定component_id。先读任务卡、components/catalog.json、docs/12_component_reuse.md、docs/13_component_qualification.md和现有依赖/平台证据。

确认该组件处于当前阶段，选择一种实现，记录精确版本/commit、来源、hash、LICENSE/NOTICE、可选特性与附属资产。使用分阶段依赖组，不把候选表全部安装。默认组件也需要资格验证；REFERENCE_ONLY先审查再决定COPY或NO_COPY，禁止复制自治执行循环。

按templates/component-qualification.md记录允许API、网络/代理、首次下载、重试、线程/子进程、文件、凭据、取消和cleanup。明确唯一重试与生命周期所有者，运行相关Q场景和任务负向验收。mock只证明其覆盖的transport，不证明所有外网路径都被阻断。

如果库不能满足现有合同，先尝试收窄API或采用有证据的替代件；必要窄补丁登记templates/UPSTREAM_PATCHES.md字段。不要通过host fallback、关闭sandbox、忽略UNKNOWN或扩大网络权限使测试通过。版本改变影响manifest或授权内容时，按原规则使旧授权失效。

提交适配代码、依赖/资产锁定、来源记录、实际测试与未验证范围，更新任务证据。常规可逆修改可继续执行；改变产品范围或信任边界须遵循已有用户授权和项目变更流程，不自行推断新的外部行动许可。